Pemikiran Tentang Keamanan dan Ketahanan Siber Indonesia

Onno W. Purbo
onno@indo.net.id
onno@itts.ac.id
Twitter onnowpurbo

Institut Teknologi Tangerang Selatan (ITTS)
XecureIT
OnnoCenter
2026

Lisensi: Karya ini dilisensikan di bawah **Creative Commons Attribution (CC BY) 4.0 International**. Anda bebas menggunakan, membagikan, dan mengadaptasi karya ini untuk tujuan apa pun, termasuk komersial, dengan tetap mencantumkan atribusi yang layak kepada penulis.

Disclaimer: Buku ini disusun untuk tujuan edukasi berdasarkan sumber yang dipercaya kredibel. Penulis memanfaatkan AI sebagai alat bantu penulisan, namun seluruh isi telah diverifikasi dan menjadi tanggung jawab penuh penulis. Penulis berkomitmen menjaga akurasi, presisi, dan meminimalkan halusinasi AI, serta terbuka terhadap koreksi dan masukan untuk penyempurnaan.

Kedaulatan siber bukan tentang memiliki semua teknologi, melainkan memastikan tidak ada teknologi, kekuasaan, atau bangsa lain yang dapat menentukan masa depan Indonesia tanpa persetujuan kita.

KATA PENGANTAR

Keamanan siber Indonesia bukan hanya persoalan serangan dan pertahanan, melainkan **kemampuan bangsa menjaga pelayanan publik, ekonomi, demokrasi, data, pengetahuan, serta kebebasan mengambil keputusan teknologi**. Negara yang aman bukan sekadar negara yang mampu menahan serangan, tetapi negara yang dapat mempertahankan fungsi penting, memulihkan layanan, melindungi hak warga, dan menentukan arah teknologinya sendiri.

Buku ini ditulis sebagai sumbangan pemikiran untuk pembahasan **Regulasi Keamanan dan Ketahanan Siber** serta pembangunan strategi kedaulatan teknologi Indonesia. Pembahasannya diarahkan kepada para pengambil keputusan negara agar regulasi siber tidak berhenti sebagai kumpulan kewajiban dan sanksi, melainkan menjadi fondasi bagi tata kelola yang jelas, respons yang cepat, inovasi nasional, perlindungan demokrasi, dan kemandirian teknologi.

Kecerdasan artifisial digunakan untuk membantu penelusuran referensi, penyusunan struktur, pengembangan gagasan, dan pemeriksaan konsistensi. Namun, **penulis tetap bertanggung jawab atas isi buku**, berusaha memeriksa informasi melalui sumber primer, menjaga akurasi, mengurangi risiko *hallucination*, serta membedakan fakta, analisis, dan usulan kebijakan. Pengetahuan dan regulasi terus berkembang; karena itu, penulis terbuka terhadap koreksi, pengujian ulang, dan revisi berbasis bukti.

Sebagian contoh kode atau konfigurasi yang dirujuk dari buku pendukung mungkin tidak langsung berjalan pada setiap sistem. Perbedaan versi, perangkat keras, dependensi, hak akses, jaringan, dan konfigurasi lokal dapat menghasilkan keluaran yang berbeda. **Jangan hanya menyalin—pahami tujuan, periksa dokumentasi, baca pesan kesalahan, dan bersiap melakukan *debugging*.**

Pesan utama buku ini sederhana: **Indonesia tidak harus membuat semua teknologi sendiri, tetapi Indonesia harus mampu memahami, mengaudit, mengendalikan, memperbaiki, memulihkan, dan mengganti teknologi yang menentukan masa depannya.**

Semoga buku ini membantu melahirkan kebijakan siber yang tegas tanpa sewenang-wenang, kuat tanpa menjadi *superbody*, terbuka terhadap dunia tanpa kehilangan kendali, dan berani menjadikan kemampuan nasional sebagai dasar kedaulatan.

Jakarta, 2026
Onno W. Purbo

EXECUTIVE SUMMARY

Buku Pemikiran tentang Keamanan dan Ketahanan Siber Indonesia, 2026 ditujukan kepada Presiden, menteri, pimpinan DPR, kepala badan, pimpinan TNI dan Polri, kepala daerah, regulator sektoral, serta pengambil keputusan nasional yang menentukan masa depan digital Indonesia. Buku ini menempatkan keamanan siber sebagai persoalan kedaulatan, kesinambungan pemerintahan, ekonomi, demokrasi, dan penguasaan teknologi—bukan sekadar pekerjaan teknis pengelola server. Pesan utamanya tegas: **Indonesia tidak akan berdaulat apabila hanya menjadi pembeli teknologi, penyewa *cloud*, pengguna platform asing, dan konsumen data tanpa menguasai arsitektur, talenta, standar, komputasi, serta rantai pasoknya sendiri.** Karena itu, Regulasi Keamanan dan Ketahanan Siber harus menghasilkan sepuluh keputusan strategis: membentuk satu komando nasional tanpa mematikan kewenangan sektoral; menetapkan Infrastruktur Informasi Kritikal berdasarkan fungsi, ketergantungan, risiko, dan dampak; membangun tangga Normal–Eskalasi–Tegang–Darurat yang terukur serta dapat diawasi; menerapkan kewajiban keamanan secara proporsional; menyediakan satu saluran pelaporan insiden nasional; menangani operasi pengaruh berdasarkan perilaku manipulatif, bukan isi pendapat; menguasai AI, data, komputasi, dan rantai pasokan; membangun manusia, bukan sekadar menerbitkan sertifikat; membatasi kewenangan negara melalui privasi, HAM, *proportionality*, dan *due process*; serta menjadikan hukum Indonesia efektif lintas batas. Arsitektur ini menuntut BSSN yang kuat sebagai koordinator teknis, regulator yang disiplin, industri domestik yang tumbuh, peneliti yang terlindungi, daerah yang berdaya, dan pengawasan demokratis yang efektif. Semakin besar kewenangan negara, semakin jelas batas, durasi, audit, transparansi, serta pertanggungjawabannya kepada rakyat, konstitusi, dan hukum yang berlaku. Buku ini tidak menawarkan tutorial, kode, instalasi, atau simulasi serangan, melainkan arah *technology policy* yang dapat diterjemahkan menjadi kelembagaan, anggaran, regulasi, pengadaan, diplomasi, dan peta jalan 2026–2035. Ukuran keberhasilannya bukan banyaknya alat, lembaga, laporan, atau pidana, tetapi kemampuan Indonesia mencegah gangguan, mengambil keputusan cepat, memulihkan layanan, mengaudit teknologi, mengganti pemasok, mempertahankan hak warga, dan membangun solusi sendiri. **Kedaulatan siber bukan isolasi; ia adalah kebebasan untuk bekerja sama dengan dunia dari posisi mampu, setara, dan tetap memegang kendali atas masa depan bangsa.**

DARI KEAMANAN SISTEM MENUJU KETAHANAN NEGARA

1. **Ruang Siber sebagai Domain Strategis Negara**

   Menjelaskan perubahan ruang siber dari sarana komunikasi menjadi fondasi pemerintahan, perbankan, energi, transportasi, kesehatan, pertahanan, pendidikan, dan kehidupan demokrasi.

2. **Ancaman Siber sebagai Risiko Sistemik**

   Menunjukkan bahwa kerusakan pada satu sistem kritikal dapat menjalar ke banyak sektor dan melumpuhkan pelayanan publik serta perekonomian.

3. **Keamanan Tidak Sama dengan Ketahanan**

   Keamanan berusaha mencegah serangan, sedangkan ketahanan memastikan negara tetap dapat berfungsi ketika pertahanan ditembus.

4. **Ketergantungan Teknologi sebagai Kerentanan Nasional**

   Membahas risiko ketergantungan terhadap cloud, perangkat keras, perangkat lunak, platform komunikasi, model AI, basis data, dan tenaga ahli asing.

5. **Dari Kepatuhan Menuju Kapabilitas**

   Menegaskan bahwa audit dan sertifikat tidak otomatis menghasilkan keamanan jika organisasi tidak mempunyai kemampuan mendeteksi, merespons, memulihkan, dan belajar dari insiden.

6. **Sepuluh Keputusan Besar Keamanan Ketahanan Siber**

   Memberikan peta masalah dan menjelaskan hubungan antara sepuluh bab dengan sepuluh isu strategis dalam Keamanan Ketahanan Siber.

DAFTAR ISI

KATA PENGANTAR..... 4
EXECUTIVE SUMMARY..... 5
DARI KEAMANAN SISTEM MENUJU KETAHANAN NEGARA.....6
DAFTAR ISI..... 7
BAB 1 - SATU KOMANDO NASIONAL, BUKAN BANYAK PUSAT KEKUASAAN..... 11
1.1 Fragmentasi Kewenangan Siber Indonesia..... 12
1.2 Memisahkan Fungsi Kebijakan, Operasi, Intelijen, Penegakan Hukum, dan Pertahanan.....14
1.3 BSSN sebagai Koordinator Teknis Nasional..... 16
1.4 Peran BIN, Polri, TNI, Komdigi, Kemendagri, dan Regulator Sektoral.....18
1.5 Model Komando Normal dan Komando Krisis..... 20
1.6 National Cyber Situation Room.....21
1.7 Pengawasan, Audit, dan Pertanggungjawaban..... 23
1.8 Keputusan Strategis Bab 1.....25
RANGKUMAN BAB 1.....27
REFERENSI BAB 1.....28
BAB 2 - INFRASTRUKTUR INFORMASI KRITIKAL: LINDUNGI FUNGSI, BUKAN SEKADAR INSTITUSI..... 29
2.1 Apa yang Benar-Benar Kritikal bagi Negara..... 30
2.2 Kriteria Dampak Sistemik.....32
2.3 Ketergantungan dan Dampak Kaskade..... 34
2.4 Tingkatan Kekritisan Nasional.....36
Tingkat I – Strategis Nasional.....36
Tingkat II – Kritikal Sektoral.....36
Tingkat III – Esensial Regional atau Rantai Pasokan.....36
Tingkat IV – Infrastruktur Penting dengan Kewajiban Dasar.....36
2.5 Penetapan, Evaluasi, dan Pengakhiran Status IIK.....38
2.6 Informasi IIK yang Terbuka dan yang Harus Dirahasiakan..... 40
2.7 Perlindungan terhadap Pelaku Kecil dan Rantai Ketergantungan..... 42
2.8 Keputusan Strategis Bab 2.....44
RANGKUMAN BAB 2.....46
REFERENSI UTAMA BAB 2..... 47
BAB 3 - NORMAL, ESKALASI, TEGANG, DARURAT: TANGGA KRISIS YANG DAPAT DIUKUR..... 48
3.1 Mengapa Model Biner Tidak Memadai.....49
3.2 Kondisi Normal.....51
3.3 Kondisi Eskalasi..... 53
3.4 Kondisi Tegang.....55
3.5 Kondisi Darurat.....57
3.6 Indikator, Ambang Batas, dan Pejabat Penetap.....59
3.7 Batas Waktu, Sunset Clause, dan Pengakhiran Status..... 61
3.8 Keputusan Strategis Bab 3.....63

RANGKUMAN BAB 3.....64
REFERENSI UTAMA BAB 3.....65
BAB 4 - REGULASI BERBASIS RISIKO: AMAN TANPA MEMATIKAN INOVASI.....66
4.1 DARI KEWAJIBAN SERAGAM MENUJU KEWAJIBAN PROPORSIONAL.....67
4.2 BASELINE KEAMANAN NASIONAL.....69
4.3 SECURE BY DESIGN DAN SECURE BY DEFAULT.....70
4.4 TANGGUNG JAWAB SEPANJANG SIKLUS HIDUP PRODUK.....71
4.5 KEWAJIBAN PENYEDIA ASING.....72
4.6 PERLINDUNGAN INOVASI, STARTUP, DAN UMKM.....73
4.7 PENGADAAN PEMERINTAH SEBAGAI PENGUNGKIT KEAMANAN.....74
4.8 KEPUTUSAN STRATEGIS BAB 4.....76
RANGKUMAN BAB 4.....77
REFERENSI UTAMA BAB 4.....78
BAB 5 - SATU INSIDEN, SATU LAPORAN, SATU GAMBARAN NASIONAL.....79
5.1 MASALAH PELAPORAN YANG TERFRAGMENTASI.....80
5.2 DEFINISI INSIDEN YANG WAJIB DILAPORKAN.....82
5.3 AMBANG BATAS MATERIALITAS.....84
5.4 PELAPORAN BERTAHAP.....86
5.5 SALURAN PELAPORAN NASIONAL TERPADU.....88
5.6 HARMONISASI DENGAN UU PDP DAN REGULASI SEKTORAL.....90
5.7 SAFE HARBOR DAN PERLINDUNGAN PELAPOR.....92
5.8 KEPUTUSAN STRATEGIS BAB 5.....94
RANGKUMAN BAB 5.....95
REFERENSI UTAMA BAB 5.....96
BAB 6 - MEMPERTAHANKAN RUANG INFORMASI TANPA MEMBUNUH DEMOKRASI97
6.1 RUANG SIBER MEMILIKI LAPISAN INFRASTRUKTUR, SISTEM, DATA, DAN INFORMASI.....98
6.2 DEFINISI OPERASI PENGARUH TERKOORDINASI.....99
6.3 PERILAKU, BUKAN ISI PENDAPAT.....101
6.4 BOT, BUZZER, DAN AKUN SEMU.....103
6.5 ATRIBUSI DAN STANDAR PEMBUKTIAN.....105
6.6 PERAN PLATFORM DIGITAL.....107
6.7 SAFEGUARD KEBEBASAN BEREKSPRESI.....109
6.8 KEPUTUSAN STRATEGIS BAB 6.....111
RANGKUMAN BAB 6.....112
REFERENSI UTAMA BAB 6.....113
BAB 7 - AI DAN RANTAI PASOKAN: MEDAN BARU KEDAULATAN TEKNOLOGI..... 114
7.1 AI SEBAGAI PEDANG BERMATA DUA.....115
7.2 HUMAN-IN-THE-LOOP UNTUK KEPUTUSAN BERISIKO TINGGI.....117
7.3 TATA KELOLA RISIKO AI.....119
7.4 KEAMANAN RANTAI PASOKAN DIGITAL.....121
7.5 TRANSPARANSI KOMPONEN DAN KERENTANAN.....123
7.6 OPEN SOURCE, PROPRIETARY, DAN ARSITEKTUR HIBRIDA.....125
7.7 INFRASTRUKTUR AI NASIONAL.....127

7.8 KEPUTUSAN STRATEGIS BAB 7 129
RANGKUMAN BAB 7 131
REFERENSI UTAMA BAB 7 132
BAB 8 - MEMBANGUN MANUSIA, BUKAN SEKADAR MENERBITKAN SERTIFIKAT .. 133
8.1 Kesenjangan Talenta sebagai Risiko Kedaulatan 133
8.2 Peta Peran dan Kompetensi Nasional 135
8.3 Sertifikasi Bukan Pengganti Pengalaman 137
8.4 Integrasi dengan Sistem Sertifikasi Nasional 138
8.5 Penerapan Bertahap 139
8.6 Akademi Siber Nasional dan Jaringan Daerah 140
8.7 Retensi, Jalur Karier, dan Mobilitas Talenta 141
8.8 Keputusan Strategis Bab 8 142
RANGKUMAN BAB 8 143
Penutup 144
Referensi Bab 8 144
BAB 9 - NEGARA YANG KUAT HARUS TETAP TERBATAS OLEH HUKUM 145
9.1 Dilema Keamanan dan Kebebasan 146
9.2 Batas Kewenangan Pemantauan dan Audit 148
9.3 Prinsip Necessity dan Proportionality 150
9.4 Due Process dan Pengawasan Independen 152
9.5 Tangga Sanksi Administratif 154
9.6 Pidana sebagai Ultimum Remedium 156
9.7 Perlindungan Peneliti Keamanan dan Responsible Disclosure 158
9.8 Keputusan Strategis Bab 9 160
RANGKUMAN BAB 9 162
PENUTUP 163
REFERENSI BAB 9 164
BAB 10 - KEAMANAN KETAHANAN SIBER UNTUK DUNIA TANPA BATAS DAN INDONESIA YANG BERDAULAT 165
10.1 Mengapa Serangan Siber Melampaui Yurisdiksi Negara 166
10.2 Ekstrateritorialitas yang Dapat Ditegakkan 167
10.3 Atribusi Bukan Tebakan Politik 169
10.4 Kerja Sama Internasional 171
10.5 Harmonisasi Hukum Nasional 173
10.6 Norma yang Wajib Berada dalam Undang-Undang 175
10.7 Peta Jalan Kedaulatan Siber 2026–2035 177
Tahap I: 2026–2027 — Menertibkan Tata Kelola dan Mengetahui Apa yang Dimiliki 177
Tahap II: 2028–2030 — Memperkuat Kapasitas Nasional 177
Tahap III: 2031–2033 — Menguasai Rantai Pasokan Strategis 178
Tahap IV: 2034–2035 — Menjadi Produsen dan Mitra Strategis Dunia 179
10.8 Sepuluh Keputusan untuk Pemimpin Negara 180
Keputusan 1 — Tetapkan Satu Komando, Bukan Satu Penguasa 180
Keputusan 2 — Lindungi Fungsi Kritikal, Bukan Sekadar Nama Institusi 180

Keputusan 3 — Bangun Tangga Krisis yang Terukur.....180
Keputusan 4 — Atur Berdasarkan Risiko, Bukan Ketakutan..... 180
Keputusan 5 — Satu Insiden, Satu Laporan, Satu Gambaran Nasional.....181
Keputusan 6 — Pertahankan Ruang Informasi Tanpa Membungkam Demokrasi... 181
Keputusan 7 — Kuasai AI dan Rantai Pasokan melalui Kemampuan Keluar.....181
Keputusan 8 — Bangun Manusia, Jangan Mengejar Jumlah Sertifikat..... 181
Keputusan 9 — Berikan Kewenangan, tetapi Bangun Pagar Hukum..... 182
Keputusan 10 — Jadikan Kedaulatan sebagai Kemampuan, Bukan Slogan.....182
RANGKUMAN BAB 10.....183
PENUTUP..... 184
REFERENSI BAB 10.....186
PENUTUP BUKU.....187
GLOSSARY..... 188
REFERENSI.....201
CATATAN PENGGUNAAN REFERENSI..... 205
TENTANG PENULIS.....206

BAB 1 - SATU KOMANDO NASIONAL, BUKAN BANYAK PUSAT KEKUASAAN

Keamanan siber tidak dapat dikelola seperti proyek teknologi informasi biasa. Ketika serangan menghentikan sistem pembayaran, mengganggu energi, membocorkan data strategis, atau melumpuhkan layanan pemerintahan, persoalannya bukan lagi sekadar "server siapa yang rusak". Persoalannya adalah: **siapa memimpin, siapa mengambil keputusan, siapa melaksanakan respons, dan siapa mempertanggungjawabkan akibatnya kepada negara dan masyarakat?**

Indonesia sebenarnya tidak kekurangan lembaga. Indonesia memiliki BSSN, BIN, Polri, TNI, Kementerian Komunikasi dan Digital, Kementerian Dalam Negeri, kementerian teknis, regulator sektor, pemerintah daerah, serta berbagai tim respon insiden. Yang belum sepenuhnya kuat adalah **arsitektur komando yang mampu menyatukan informasi dan keputusan tanpa mencampuradukkan mandat setiap lembaga**.

Peraturan Presiden Nomor 47 Tahun 2023 telah menempatkan Strategi Keamanan Siber Nasional dan Manajemen Krisis Siber sebagai acuan bagi instansi penyelenggara negara dan para pemangku kepentingan. Ini merupakan fondasi penting. Namun, Regulasi Keamanan dan Ketahanan Siber harus melangkah lebih jauh dengan menetapkan norma dasar mengenai kepemimpinan, koordinasi, aktivasi krisis, pembatasan kewenangan, pertanggungjawaban, dan pengawasan.

> **Satu komando nasional tidak berarti satu lembaga menguasai semuanya. Satu komando berarti negara mempunyai satu arah strategis, satu gambaran situasi, satu mekanisme eskalasi, dan satu keputusan nasional ketika keselamatan serta kedaulatan negara terancam.**

1.1 Fragmentasi Kewenangan Siber Indonesia

Keamanan siber Indonesia tumbuh dari mandat sektoral yang berbeda. BSSN bekerja pada ranah keamanan siber dan persandian; BIN menjalankan fungsi intelijen negara; Polri menangani penegakan hukum; TNI menjalankan fungsi pertahanan; Komdigi mengatur ekosistem komunikasi, informatika, dan sistem elektronik; Kemendagri membina penyelenggaraan pemerintahan daerah; sementara kementerian teknis dan regulator menjaga sektor seperti keuangan, energi, transportasi, kesehatan, telekomunikasi, dan pelayanan publik.

Pembagian tersebut dapat dipahami karena setiap sektor mempunyai karakter ancaman, teknologi, kewajiban, dan risiko yang berbeda. Gangguan pada jaringan listrik tidak dapat diperlakukan sama dengan serangan terhadap layanan perdagangan elektronik. Kebocoran data penduduk memerlukan pendekatan yang berbeda dari operasi siber yang mengancam sistem pertahanan. Namun, perbedaan mandat juga menciptakan risiko fragmentasi.

Fragmentasi muncul ketika beberapa lembaga merasa sama-sama berwenang, tetapi tidak ada satu pihak yang bertanggung jawab atas hasil akhir. Pada situasi lain, setiap lembaga menunggu pihak lain bergerak karena batas kewenangannya tidak jelas. Akibatnya, respons menjadi lambat, instruksi dapat bertentangan, informasi terpecah, dan pemulihan berjalan tanpa prioritas nasional.

Masalah utama fragmentasi bukan banyaknya lembaga, melainkan **ketidakjelasan hubungan antarlembaga pada saat sebuah insiden melampaui batas organisasi dan sektor**. Selama insiden masih terbatas pada satu organisasi, struktur sektoral mungkin memadai. Ketika dampaknya menyentuh beberapa sektor, beberapa wilayah, atau keselamatan publik, negara memerlukan mekanisme yang berbeda.

Fragmentasi juga terjadi pada data. Setiap institusi dapat mempunyai sistem pemantauan, klasifikasi, format laporan, indikator, dan definisi insiden sendiri. Negara akhirnya memiliki banyak data, tetapi tidak mempunyai satu gambaran situasi yang dapat dipercaya. Banyak laporan tidak otomatis menghasilkan pemahaman. Banyak pusat operasi tidak otomatis menghasilkan koordinasi.

Dalam buku *Strategic Blueprint: AI Integration in the Corporate SOC*, persoalan serupa digambarkan sebagai fragmentasi data, keputusan, dan tanggung jawab. Pelajarannya berlaku pada tingkat nasional: **masalah strategis bukan semata-mata kekurangan alat, melainkan tidak adanya gambaran risiko terpadu yang dapat digunakan untuk mengambil keputusan.**

Karena itu, Keamanan Ketahanan Siber tidak perlu menghapus kewenangan sektoral. Yang dibutuhkan adalah menetapkan:

Pertama, siapa yang menjadi **pemilik risiko** pada setiap tingkat.
Kedua, siapa yang bertindak sebagai **koordinator teknis nasional**.
Ketiga, kapan suatu insiden tetap ditangani secara sektoral.
Keempat, kapan **koordinasi lintas sektor** mulai diaktifkan.
Kelima, siapa yang berwenang mengusulkan dan **menetapkan kondisi krisis**.
Keenam, siapa yang **mengawasi** penggunaan kewenangan luar biasa.

Indonesia membutuhkan federasi kemampuan dengan kesatuan arah, bukan sentralisasi seluruh kekuasaan.

1.2 Memisahkan Fungsi Kebijakan, Operasi, Intelijen, Penegakan Hukum, dan Pertahanan

Salah satu resiko terbesar dalam tata kelola siber adalah mencampur semua fungsi ke dalam satu kewenangan. Dalam ruang siber, kegiatan pemantauan teknis, pengumpulan intelijen, pertahanan negara, penyidikan pidana, pengaturan industri, dan pemulihan layanan dapat menggunakan teknologi yang serupa. Namun, kesamaan teknologi tidak berarti kesamaan mandat hukum.

Pemantauan lalu lintas jaringan untuk menjaga layanan tidak sama dengan intersepsi untuk kepentingan intelijen. Analisis malware untuk memulihkan sistem tidak sama dengan penyitaan barang bukti dalam proses pidana. Penanggulangan serangan terhadap infrastruktur sipil tidak selalu sama dengan operasi pertahanan menghadapi ancaman militer.

Keamanan Ketahanan Siber harus memisahkan sedikitnya lima fungsi utama.

> **Fungsi kebijakan** menentukan arah nasional, sasaran, pembagian tanggung jawab, standar minimum, prioritas investasi, dan ukuran keberhasilan. Fungsi ini berada pada tingkat politik dan pemerintahan tertinggi karena keputusan keamanan siber dapat mempengaruhi ekonomi, hak warga, hubungan luar negeri, dan pertahanan.
>
> **Fungsi operasi teknis** mencakup deteksi, validasi insiden, pemberian peringatan, koordinasi CSIRT, pembatasan dampak, pemulihan, analisis teknis, dan pembelajaran pasca insiden. Operasi teknis membutuhkan kecepatan, kompetensi, interoperabilitas, dan hubungan kepercayaan dengan penyelenggara sistem.
>
> **Fungsi intelijen** berfokus pada peringatan dini, identifikasi maksud dan kemampuan aktor, analisis ancaman strategis, serta dukungan kepada pengambil keputusan. Informasi intelijen dapat memperkuat respons, tetapi tidak otomatis dapat digunakan sebagai bukti hukum atau diumumkan kepada publik.
>
> **Fungsi penegakan hukum** bertujuan menemukan tindak pidana, mengamankan barang bukti, mengidentifikasi pelaku, melakukan penyidikan, dan membawa perkara ke proses peradilan. Proses ini harus tunduk pada hukum acara, standar pembuktian, kewenangan yang sah, dan hak pihak yang diperiksa.
>
> **Fungsi pertahanan** berlaku ketika ancaman berkaitan dengan pertahanan negara, operasi militer, serangan oleh aktor negara, atau situasi yang menurut hukum memerlukan pengerahan instrumen pertahanan. Fungsi pertahanan tidak boleh otomatis mengambil alih setiap serangan siber terhadap sistem sipil.

Pemisahan fungsi tidak berarti setiap pihak bekerja sendiri. Justru karena fungsinya berbeda, mereka membutuhkan prosedur kerja sama yang jelas. Sebuah insiden dapat menghasilkan tiga jalur paralel: jalur teknis untuk memulihkan layanan, jalur intelijen untuk memahami aktor dan motif, serta jalur penegakan hukum untuk mengumpulkan bukti. Jika ancamannya mencapai dimensi pertahanan, jalur pertahanan dapat diaktifkan berdasarkan ketentuan yang sah.

> **Satu insiden dapat melibatkan banyak fungsi, tetapi setiap fungsi harus tetap berada dalam mandat, prosedur, dan mekanisme pertanggungjawabannya sendiri.**

Prinsip ini penting untuk mencegah dua kegagalan. Kegagalan pertama adalah kelambatan karena semua pihak menunggu penetapan kewenangan. Kegagalan kedua adalah konsentrasi kekuasaan karena satu lembaga mengklaim seluruh fungsi hanya karena memiliki kemampuan teknis.

1.3 BSSN sebagai Koordinator Teknis Nasional

Keamanan Ketahanan Siber sebaiknya menempatkan BSSN sebagai **koordinator teknis keamanan dan ketahanan siber nasional**, bukan sebagai pemegang seluruh kewenangan di ruang siber. Posisi ini konsisten dengan kebutuhan negara terhadap satu pusat koordinasi teknis, tetapi tetap menghormati mandat intelijen, penegakan hukum, pertahanan, regulasi komunikasi, pemerintahan daerah, serta regulator sektoral.

Sebagai koordinator teknis nasional, BSSN perlu mempunyai lima kemampuan inti.

Pertama, membangun *situational awareness* nasional. BSSN harus mampu menyusun gambaran mengenai ancaman, kerentanan, insiden, dependensi, dan dampak lintas sektor. Gambaran ini bukan sekadar kumpulan log, tetapi informasi yang dapat membantu Presiden, menteri, kepala badan, dan regulator mengambil keputusan.

Kedua, mengembangkan standar minimum dan kerangka interoperabilitas. Lembaga serta sektor boleh menggunakan teknologi berbeda, tetapi klasifikasi insiden, tingkat keparahan, format pertukaran informasi, dan prosedur eskalasinya harus dapat saling dipahami.

Ketiga, mengoordinasikan jejaring CSIRT. Tim respons pada kementerian, pemerintah daerah, sektor kritikal, perusahaan, dan penyelenggara layanan perlu tetap dekat dengan sistem yang mereka lindungi. BSSN tidak perlu mengambil alih pekerjaan mereka, tetapi memastikan mereka mampu berkomunikasi dan bekerja sebagai satu jaringan nasional.

Keempat, mengelola peringatan dini dan bantuan teknis lintas sektor. Ketika pola serangan yang sama ditemukan pada satu sektor, sektor lain harus dapat memperoleh peringatan yang cepat, relevan, dan dapat ditindaklanjuti.

Kelima, mengorkestrasi respons teknis nasional ketika suatu insiden tidak lagi dapat ditangani oleh satu organisasi atau regulator. Dalam keadaan demikian, BSSN menyelaraskan prioritas pemulihan, dukungan ahli, pertukaran indikator, serta komunikasi teknis lintas sektor.

Posisi koordinator tidak boleh ditafsirkan sebagai hak untuk mengambil seluruh data mentah dari semua penyelenggara. Prinsip yang lebih aman adalah **berbagi informasi sebanyak yang diperlukan, tetapi memindahkan data sensitif sesedikit mungkin**. Negara perlu memperoleh informasi yang cukup untuk memahami risiko tanpa menciptakan gudang data nasional yang justru menjadi sasaran bernilai sangat tinggi.

NIST Cybersecurity Framework 2.0 menempatkan *Govern* sebagai salah satu fungsi inti tata kelola risiko siber. Pelajarannya jelas: teknologi deteksi dan respons tidak akan efektif apabila strategi, peran, kebijakan, pengawasan, serta akuntabilitas tidak ditentukan terlebih dahulu. NIST Cybersecurity Framework 2.0

> **Koordinator teknis nasional harus dinilai dari kemampuannya menyatukan keputusan dan mempercepat pemulihan, bukan dari besarnya data atau kewenangan yang berhasil dikumpulkan.**

1.4 Peran BIN, Polri, TNI, Komdigi, Kemendagri, dan Regulator Sektoral

Keberadaan satu koordinator teknis harus diikuti pembagian peran yang tegas. Pembagian ini tidak harus mengunci struktur organisasi selamanya, tetapi undang-undang perlu menetapkan fungsi dasarnya agar tidak mudah berubah karena kepentingan kelembagaan.

BIN berperan memberikan intelijen strategis, peringatan dini, dan analisis mengenai aktor, motif, kemampuan, serta kemungkinan eskalasi ancaman. BIN tidak menggantikan fungsi respons teknis ataupun proses pembuktian pidana. Informasi intelijen harus masuk ke proses keputusan melalui kanal yang sah dan terlindungi.

Polri berperan dalam penyelidikan dan penyidikan tindak pidana siber, pengamanan barang bukti, perlindungan korban, kerjasama penegakan hukum, dan proses hukum terhadap pelaku. Tindakan penegakan hukum harus dirancang agar tidak menghambat pemulihan layanan kritikal. Menyelamatkan bukti penting, tetapi menyelamatkan fungsi publik juga penting.

TNI berperan dalam pertahanan siber yang terkait dengan pertahanan negara, sistem militer, serta ancaman yang secara hukum masuk ke ranah pertahanan. Keterlibatan TNI pada sistem sipil harus mempunyai dasar, kondisi aktivasi, ruang lingkup, dan batas waktu yang jelas.

Komdigi berperan pada kebijakan serta pengaturan ekosistem komunikasi dan informatika, penyelenggara sistem elektronik, telekomunikasi, platform digital, dan transformasi digital. Komdigi mengatur ekosistem; BSSN mengkoordinasikan keamanan teknis; Polri menegakkan hukum. Ketiga fungsi tersebut harus saling menguatkan tanpa menjadi tiga jalur perintah yang bertentangan.

Kemendagri berperan memastikan kebijakan keamanan siber dapat diterapkan oleh pemerintah provinsi, kabupaten, dan kota. Pemerintah daerah bukan sekadar penerima instruksi. Mereka menyelenggarakan layanan publik yang langsung menyentuh masyarakat dan sering mempunyai kapasitas keamanan yang tidak merata. Kemendagri diperlukan untuk menyelaraskan pembinaan, anggaran, organisasi, serta kesiapan daerah.

Kementerian teknis dan regulator sektoral tetap bertanggung jawab terhadap ketahanan sektornya. Regulator keuangan memahami risiko sistem pembayaran; kementerian energi memahami ketergantungan listrik dan bahan bakar; kementerian kesehatan memahami keselamatan pasien dan data kesehatan. Pengetahuan sektoral tersebut tidak dapat digantikan oleh satu lembaga pusat.

Pembagian yang sehat dapat dirumuskan secara sederhana:

- BSSN mengoordinasikan aspek teknis nasional.
- BIN memberikan intelijen strategis dan peringatan dini.
- Polri menjalankan penegakan hukum.
- TNI menjalankan pertahanan sesuai mandatnya.
- Komdigi mengatur ekosistem komunikasi dan sistem elektronik.
- Kemendagri memastikan kesiapan dan koordinasi pemerintahan daerah.
- Regulator sektoral menetapkan serta mengawasi ketahanan pada sektornya.
- Presiden menetapkan arah strategis dan mengambil keputusan politik pada krisis nasional.

Praktik internasional juga menunjukkan pentingnya pemisahan antara koordinasi strategis, jejaring tim respons, pengawasan sektor, dan manajemen krisis. NIS2 Uni Eropa, misalnya, tidak hanya mengatur kewajiban entitas, tetapi juga kerja sama, pertukaran informasi, jejaring CSIRT, dan koordinasi krisis lintas negara melalui EU-CyCLONe. Indonesia tidak perlu menyalin strukturnya, tetapi dapat mengambil prinsip bahwa **koordinasi strategis, koordinasi teknis, dan respons krisis perlu dihubungkan secara formal**. European Commission – NIS2

1.5 Model Komando Normal dan Komando Krisis

Struktur yang tepat dalam kondisi normal belum tentu memadai ketika negara menghadapi krisis. Karena itu, Keamanan Ketahanan Siber perlu membedakan **model komando normal** dan **model komando krisis**.

Dalam kondisi normal, pendekatan yang paling sehat adalah koordinasi federatif. Setiap lembaga, kementerian, regulator, pemerintah daerah, dan penyelenggara infrastruktur mempertahankan kewenangan serta tanggung jawabnya. Mereka mengikuti standar nasional, berbagi informasi yang relevan, menjalankan latihan, mengembangkan kapasitas, dan melaporkan insiden berdasarkan ambang yang telah ditetapkan.

Model federatif menjaga kedekatan antara pengambil keputusan dan sistem yang dilindungi. Operator energi tetap memahami sistem energinya. Bank tetap bertanggung jawab atas sistem keuangannya. Pemerintah daerah tetap mengelola layanan publiknya. BSSN bertugas memastikan bahwa kemampuan-kemampuan tersebut dapat bekerja sebagai satu ekosistem nasional.

Dalam kondisi krisis, koordinasi biasa dapat menjadi terlalu lambat. Negara memerlukan satu rantai komando sementara untuk menetapkan prioritas nasional, mengalokasikan sumber daya, mengarahkan bantuan teknis, menjaga kesinambungan pelayanan publik, dan mengelola komunikasi nasional.

Namun, komando krisis tidak boleh muncul hanya karena terjadi serangan besar atau pemberitaan yang ramai. Aktivasi harus berdasarkan indikator objektif, misalnya:

- Gangguan melibatkan beberapa sektor kritikal.
- Dampak meluas ke beberapa wilayah.
- Terdapat ancaman terhadap keselamatan manusia.
- Layanan pemerintahan atau ekonomi nasional mengalami gangguan serius.
- Kapasitas sektor yang terdampak tidak lagi mencukupi.
- Terdapat risiko penyebaran cepat ke infrastruktur lain.
- Terdapat indikasi kuat keterlibatan aktor dengan kemampuan strategis.

Komando krisis harus mempunyai ruang lingkup dan batas waktu. Kewenangan tambahan hanya berlaku selama kondisi yang membenarkannya masih ada. Setiap keputusan yang berdampak besar harus dicatat, mempunyai pemilik keputusan, dapat ditinjau, dan sebisa mungkin dapat dipulihkan.

Prinsip yang digunakan dalam pengelolaan AI juga relevan untuk komando negara: **kewenangan hanya boleh diberikan sebesar kemampuan organisasi untuk mengawasi, menjelaskan, menghentikan, dan memulihkan tindakannya**. Kecepatan tanpa akuntabilitas menghasilkan kesewenang-wenangan. Akuntabilitas tanpa kecepatan menghasilkan kelumpuhan. Tata kelola yang matang harus memiliki keduanya.

Komando krisis juga tidak otomatis memindahkan seluruh kewenangan hukum kepada satu lembaga. Regulator tetap mengatur sektor, Polri tetap menangani perkara pidana, BIN tetap menjalankan fungsi intelijen, dan TNI tetap bekerja dalam kerangka pertahanan. Yang disatukan adalah **arah, prioritas, gambaran situasi, serta orkestrasi respons nasional**.

1.6 National Cyber Situation Room

Indonesia memerlukan sebuah **National Cyber Situation Room** atau Pusat Situasi Siber Nasional. Ini bukan sekadar ruang besar dengan banyak layar, dan bukan pula proyek pengadaan teknologi baru. Ia adalah kemampuan negara untuk mengubah data yang tersebar menjadi pemahaman bersama dan keputusan yang terkoordinasi.

Pusat situasi tersebut perlu menjawab tujuh pertanyaan utama:

- Apa yang sedang terjadi?
- Sektor dan layanan apa yang terdampak?
- Seberapa besar risiko terhadap masyarakat dan negara?
- Apakah serangan masih berkembang?
- Siapa yang bertanggung jawab menangani setiap bagian?
- Keputusan apa yang harus diambil sekarang?
- Bagaimana layanan kritikal dipulihkan dan risiko berikutnya dicegah?

Informasi yang masuk tidak harus berupa semua log mentah dari setiap organisasi. Pendekatan pemusatan total menciptakan biaya besar, risiko privasi, kerentanan baru, dan godaan penyalahgunaan data. Arsitektur yang lebih tepat adalah **federasi informasi**: data rinci tetap berada pada pemiliknya, sedangkan pusat menerima informasi minimum yang diperlukan untuk membangun gambaran nasional.

Informasi minimum dapat mencakup tingkat insiden, sektor terdampak, layanan yang terganggu, indikator teknis terpilih, perkiraan dampak, status pemulihan, kebutuhan bantuan, dan risiko penyebaran. Untuk keperluan analisis lanjutan, akses terhadap data tambahan dilakukan berdasarkan kebutuhan, kewenangan, klasifikasi, dan jejak audit.

Pusat situasi juga harus menghubungkan konteks teknis dengan konteks kebijakan. Satu juta serangan otomatis yang gagal mungkin kurang penting dibanding satu akses tidak sah ke sistem pengendali pembangkit. Jumlah peringatan bukan ukuran utama. Yang harus dinilai adalah dampak terhadap manusia, layanan, ekonomi, pemerintahan, pertahanan, dan kepercayaan publik.

Karena itu, *dashboard* nasional tidak boleh berhenti pada jumlah serangan. Ia perlu menunjukkan:

- Fungsi nasional yang terancam.
- Aset atau layanan kritikal yang terdampak.
- Perkembangan dampak lintas sektor.
- Kemampuan respons yang tersedia.
- Keputusan yang tertunda.
- Estimasi waktu pemulihan.
- Risiko sisa setelah tindakan dilakukan.

Pusat situasi harus beroperasi terus-menerus, tetapi aktivasi pengambilan keputusan nasional disesuaikan dengan tingkat kondisi. Dalam keadaan normal, pusat berfungsi untuk pemantauan, analisis tren, latihan, dan kesiapan. Dalam kondisi eskalasi, pusat memperkuat koordinasi. Dalam kondisi tegang atau darurat, pusat menjadi simpul keputusan yang menghubungkan aspek teknis, intelijen, penegakan hukum, pertahanan, komunikasi publik, dan kepemimpinan politik.

> **Tujuan pusat situasi bukan mengetahui semua hal, tetapi memastikan negara mengetahui hal yang paling penting sebelum terlambat.**

1.7 Pengawasan, Audit, dan Pertanggungjawaban

Kewenangan siber dapat menyentuh data pribadi, rahasia perusahaan, komunikasi, infrastruktur kritikal, keamanan nasional, dan kebebasan warga. Oleh sebab itu, semakin besar kewenangan yang diberikan, semakin kuat pula mekanisme pengawasannya.

Keamanan Ketahanan Siber harus mencegah dua ekstrem. Ekstrem pertama adalah negara tidak mampu bertindak karena setiap keputusan terhambat birokrasi. Ekstrem kedua adalah negara dapat melakukan pemantauan dan intervensi tanpa batas, tanpa jejak, dan tanpa mekanisme koreksi.

Setiap tindakan luar biasa dalam kondisi krisis setidaknya harus memenuhi prinsip berikut.

Dasar kewenangan yang jelas. Tidak boleh ada tindakan hanya berdasarkan tafsir yang sangat luas atau perintah lisan tanpa dokumentasi.

Tujuan yang spesifik. Data dan akses yang diperoleh untuk menangani insiden tidak boleh digunakan secara bebas untuk tujuan lain.

Necessity. Tindakan harus benar-benar diperlukan untuk menghadapi ancaman.

Proporsionalitas. Tingkat intervensi harus sebanding dengan risiko yang dihadapi.

Batas waktu. Kewenangan luar biasa harus berakhir ketika kondisi yang membenarkannya berakhir.

Jejak audit. Harus diketahui siapa meminta, menyetujui, menjalankan, mengubah, dan menghentikan tindakan.

Kemampuan koreksi. Keputusan yang salah harus dapat dihentikan, dibatalkan, atau dipulihkan sejauh mungkin.

Pertanggungjawaban. Hasil tindakan harus dilaporkan kepada Presiden dan, sesuai kewenangan konstitusional, diawasi oleh DPR serta mekanisme pengawasan lain.

Pengawasan dapat dilakukan berlapis. Pengawasan internal memastikan kepatuhan operasional. Pengawasan eksekutif memastikan kesesuaian dengan kebijakan Presiden. Pengawasan legislatif memastikan akuntabilitas politik dan anggaran. Pengawasan yudisial diperlukan untuk tindakan tertentu yang sangat intrusif. Audit independen diperlukan untuk menilai efektivitas, kepatuhan, dan dampak terhadap hak.

Laporan kepada publik tidak harus membuka detail teknis atau informasi rahasia. Namun, masyarakat berhak mengetahui setidaknya jenis krisis, dampak, tindakan utama, penggunaan kewenangan khusus, hasil pemulihan, dan perbaikan yang dilakukan. Transparansi yang terukur membangun kepercayaan sekaligus mendorong disiplin kelembagaan.

Peraturan Presiden Nomor 47 Tahun 2023 telah memberikan fondasi strategi nasional dan manajemen krisis siber. Keamanan Ketahanan Siber perlu memastikan bahwa penguatan kewenangan di atas fondasi tersebut diikuti penguatan kontrol demokratis dan hukum. Perpres Nomor 47 Tahun 2023

> **Negara yang kuat bukan negara yang mempunyai kewenangan tanpa batas. Negara yang kuat adalah negara yang mampu bertindak cepat, tepat, dan tetap dapat mempertanggungjawabkan tindakannya.**

1.8 Keputusan Strategis Bab 1

Keamanan Ketahanan Siber perlu menetapkan arsitektur kelembagaan yang jelas pada tingkat undang-undang, tetapi tidak mengunci rincian organisasi yang mungkin berubah mengikuti perkembangan teknologi dan pemerintahan.

Norma pokok yang seharusnya berada dalam batang tubuh undang-undang meliputi:

Pertama, prinsip satu arah strategis nasional. Presiden memegang tanggung jawab politik tertinggi dalam keadaan krisis siber nasional.

Kedua, penetapan BSSN sebagai koordinator teknis nasional. Koordinasi ini mencakup *situational awareness*, standar, peringatan dini, jejaring CSIRT, bantuan teknis, dan orkestrasi respons lintas sektor.

Ketiga, pemisahan fungsi. Kebijakan, operasi teknis, intelijen, penegakan hukum, pertahanan, regulasi ekosistem, dan pembinaan pemerintah daerah harus dibedakan secara tegas.

Keempat, keberlanjutan tanggung jawab sektoral. Menteri, kepala badan, regulator, pemerintah daerah, dan penyelenggara tetap bertanggung jawab atas ketahanan sistem serta layanan yang berada dalam kewenangannya.

Kelima, mekanisme peralihan dari koordinasi normal menuju komando krisis. Peralihan harus berbasis indikator, pejabat yang berwenang, ruang lingkup, dan batas waktu.

Keenam, pembentukan kemampuan Pusat Situasi Siber Nasional. Pusat ini mengintegrasikan gambaran risiko dan keputusan, bukan memusatkan seluruh data secara membabi buta.

Ketujuh, kewajiban interoperabilitas dan pertukaran informasi. Lembaga dan sektor harus dapat bertukar informasi melalui format, klasifikasi, protokol, dan perlindungan yang disepakati.

Kedelapan, pengawasan serta pertanggungjawaban. Setiap kewenangan luar biasa harus mempunyai dasar, tujuan, durasi, jejak audit, mekanisme koreksi, dan pelaporan.

Detail teknis, struktur organisasi, format pertukaran informasi, standar operasional, serta komposisi pusat situasi dapat diatur melalui peraturan pelaksanaan. Namun, **siapa berwenang melakukan apa, dalam kondisi apa, untuk tujuan apa, sampai kapan, dan diawasi oleh siapa harus ditentukan oleh undang-undang.**

Keputusan paling penting bukan memilih lembaga mana yang paling berkuasa. Keputusan paling penting adalah membangun sistem yang membuat semua lembaga mampu bekerja sebagai satu negara.

> **Satu komando nasional bukan pemusatan seluruh kekuasaan. Ia adalah kesatuan tujuan, kesatuan gambaran situasi, kesatuan prioritas, dan kesatuan pertanggungjawaban.**

RANGKUMAN BAB 1

Bagian	Masalah utama	Arah kebijakan	Keputusan yang diperlukan
1.1 Fragmentasi kewenangan	Mandat tersebar dan koordinasi lintas sektor belum selalu jelas	Federasi kemampuan dengan kesatuan arah nasional	Tetapkan pemilik risiko, koordinator teknis, dan mekanisme eskalasi
1.2 Pemisahan fungsi	Teknologi yang sama dapat digunakan untuk fungsi hukum yang berbeda	Pisahkan kebijakan, operasi teknis, intelijen, penegakan hukum, dan pertahanan	Setiap fungsi memiliki mandat, prosedur, dan pertanggungjawaban sendiri
1.3 Peran BSSN	Negara membutuhkan satu simpul koordinasi teknis	BSSN menjadi koordinator teknis, bukan pemegang seluruh kekuasaan siber	Beri mandat untuk standar, peringatan dini, jejaring CSIRT, dan orkestrasi teknis
1.4 Peran lembaga lain	Potensi tumpang tindih atau kekosongan tanggung jawab	Pertahankan kompetensi serta mandat sektoral	Tegaskan peran BIN, Polri, TNI, Komdigi, Kemendagri, dan regulator
1.5 Model komando	Koordinasi normal dapat terlalu lambat ketika terjadi krisis	Bedakan koordinasi federatif dan komando krisis sementara	Tentukan indikator aktivasi, pemimpin, ruang lingkup, dan batas waktu
1.6 Pusat situasi nasional	Banyak data belum menghasilkan gambaran risiko nasional	Bangun federasi informasi dan pemahaman bersama	Bentuk National Cyber Situation Room berbasis informasi minimum yang diperlukan
1.7 Pengawasan	Kewenangan siber dapat menyentuh data, privasi, dan kebebasan warga	Terapkan pengawasan berlapis dan due process	Wajibkan dasar hukum, tujuan, proporsionalitas, batas waktu, audit, dan pelaporan
1.8 Keputusan strategis	Risiko menciptakan lembaga superbody atau koordinasi tanpa daya	Tetapkan norma pokok dalam undang-undang dan rincian adaptif dalam peraturan pelaksanaan	Bangun satu arah, satu situasi, satu prioritas, dan satu pertanggungjawaban nasional

REFERENSI BAB 1

Badan Pemeriksa Keuangan Republik Indonesia. Peraturan Presiden Nomor 47 Tahun 2023 tentang Strategi Keamanan Siber Nasional dan Manajemen Krisis Siber. https://peraturan.bpk.go.id/Details/255542/perpres-no-47-tahun-2023

European Commission. NIS2 Directive: Securing Network and Information Systems. https://digital-strategy.ec.europa.eu/en/policies/nis2-directive

National Institute of Standards and Technology. The NIST Cybersecurity Framework 2.0. https://www.nist.gov/cyberframework

Purbo, Onno W. AI dalam Cyber Security: Dari Teori Hingga Praktik Pertahanan Digital. 2025.

Purbo, Onno W. Strategic Blueprint: AI Integration in the Corporate SOC—A CISO's Roadmap for Cognitive Cyber Defense, Digital Sovereignty, and Business Resilience. 2026.

BAB 2 - INFRASTRUKTUR INFORMASI KRITIKAL: LINDUNGI FUNGSI, BUKAN SEKADAR INSTITUSI

Indonesia tidak dapat melindungi seluruh sistem digital dengan tingkat pengamanan yang sama. Sumber daya negara terbatas, jumlah sistem terus bertambah, dan teknologi berubah lebih cepat daripada regulasi. Negara harus menentukan sistem mana yang paling menentukan keselamatan manusia, kesinambungan pelayanan publik, stabilitas ekonomi, pertahanan, dan kemampuan pemerintahan untuk tetap berfungsi.

Di sinilah konsep Infrastruktur Informasi Kritikal atau IIK menjadi penting. Namun, terdapat persoalan terminologi yang harus terlebih dahulu diselesaikan. Regulasi Keamanan Ketahanan Siber menggunakan istilah **Infrastruktur Informasi Kritikal**, sedangkan Peraturan Presiden Nomor 82 Tahun 2022 menggunakan istilah **Infrastruktur Informasi Vital atau IIV**. Perpres tersebut mendefinisikan IIV sebagai sistem elektronik yang menggunakan teknologi informasi dan/atau teknologi operasional, baik berdiri sendiri maupun saling bergantung dengan sistem elektronik lain dalam menunjang sektor strategis, yang gangguan, kerusakan, atau kehancurannya menimbulkan dampak serius terhadap kepentingan umum, pelayanan publik, pertahanan dan keamanan, atau perekonomian nasional.

Secara substansi, kedua istilah tersebut mengarah pada persoalan yang sama: **sistem digital yang kegagalannya dapat mengganggu fungsi penting negara dan masyarakat**. Keamanan Ketahanan Siber sebaiknya tidak membiarkan dua istilah hidup dengan definisi, objek, dan konsekuensi hukum yang berbeda. Jika istilah IIK dipilih, hubungan hukumnya dengan IIV dalam Perpres Nomor 82 Tahun 2022 harus ditegaskan melalui ketentuan harmonisasi atau peralihan.

Persoalan yang lebih mendasar bukan sekadar memilih kata “kritikal” atau “vital”. Negara harus menjawab: apa yang benar-benar harus dilindungi, bagaimana mengukurnya, siapa yang menetapkan, bagaimana kewajibannya dibedakan, dan kapan status tersebut harus ditinjau kembali.

> **IIK tidak boleh menjadi daftar kehormatan bagi institusi besar. IIK adalah daftar tanggung jawab terhadap fungsi yang tidak boleh gagal.**

2.1 Apa yang Benar-Benar Kritikal bagi Negara

Kesalahan yang sering terjadi adalah menyamakan institusi besar dengan infrastruktur kritikal. Padahal, ukuran organisasi, jumlah pegawai, nilai aset, kepemilikan negara, atau popularitas layanan tidak otomatis menentukan kekritisan.

Sebuah institusi besar dapat mengoperasikan banyak sistem, tetapi hanya beberapa fungsi yang benar-benar kritikal. Sebaliknya, perusahaan kecil dapat mengelola satu komponen yang menjadi titik ketergantungan ratusan organisasi. Dengan demikian, objek penetapan IIK seharusnya bukan seluruh institusi secara otomatis, melainkan **fungsi, layanan, proses, sistem, data, teknologi operasional, dan dependensi yang menopang fungsi tersebut**.

Sebagai contoh, yang harus dilindungi bukan semata-mata “bank”, melainkan fungsi pembayaran, penyelesaian transaksi, penyimpanan nilai, autentikasi, dan akses masyarakat terhadap dana. Yang kritikal bukan sekadar “rumah sakit”, melainkan fungsi keselamatan pasien, layanan gawat darurat, rekam medis yang dibutuhkan untuk tindakan, laboratorium, farmasi, dan sistem pendukung alat kesehatan. Yang kritikal bukan hanya “perusahaan listrik”, melainkan kemampuan pembangkitan, pengaturan beban, transmisi, distribusi, pemulihan jaringan, serta komunikasi operasionalnya.

Pendekatan berbasis fungsi menghasilkan empat keuntungan.

> **Pertama**, negara dapat memusatkan sumber daya pada bagian yang benar-benar menentukan keberlangsungan layanan.
>
> **Kedua**, penyelenggara tidak dibebani kewajiban maksimum untuk semua sistem tanpa membedakan tingkat resikonya.
>
> **Ketiga**, negara dapat melihat dependensi lintas organisasi. Satu fungsi dapat bergantung pada telekomunikasi, pusat data, identitas digital, listrik, perangkat lunak, cloud, dan penyedia layanan lain.
>
> **Keempat**, klasifikasi dapat mengikuti perubahan teknologi. Nama institusi dapat tetap sama, tetapi fungsi, arsitektur, dan ketergantungannya dapat berubah dengan cepat.

Pendekatan berbasis fungsi juga menghindarkan negara dari bias kepemilikan. Infrastruktur yang dikelola pemerintah tidak selalu lebih kritikal daripada infrastruktur swasta. Dalam ekonomi digital, banyak fungsi publik dan strategis diselenggarakan atau didukung oleh badan usaha, perusahaan teknologi, operator telekomunikasi, penyedia cloud, perusahaan pusat data, dan pengembang perangkat lunak.

> **Yang menentukan kekritisan bukan siapa pemiliknya, melainkan apa yang terjadi kepada negara dan masyarakat apabila fungsi tersebut berhenti.**

Karena itu, setiap penetapan IIK harus dimulai dengan pertanyaan berikut:

- Fungsi apa yang disediakan?
- Siapa yang bergantung pada fungsi tersebut?
- Berapa lama fungsi dapat berhenti sebelum terjadi dampak serius?
- Apakah terdapat penyedia atau sistem pengganti?
- Apakah pemulihan dapat dilakukan secara mandiri?
- Apakah kegagalan akan menyebar ke sektor lain?
- Apakah fungsi tersebut dibutuhkan untuk menangani krisis lain?

Jawaban atas pertanyaan tersebut lebih penting daripada nama besar penyelenggaranya.

2.2 Kriteria Dampak Sistemik

Peraturan Presiden Nomor 82 Tahun 2022 telah menggunakan konsep dampak serius terhadap kepentingan umum, pelayanan publik, pertahanan dan keamanan, serta perekonomian nasional. Keamanan Ketahanan Siber perlu mempertahankan fondasi tersebut, tetapi mengembangkan indikator yang lebih objektif agar istilah “serius” tidak ditafsirkan secara sewenang-wenang.

Setidaknya terdapat delapan dimensi yang perlu digunakan untuk menilai dampak sistemik.

Pertama, dampak terhadap keselamatan manusia. Penilaian harus mempertimbangkan kemungkinan korban jiwa, cedera, kegagalan pelayanan kesehatan, kecelakaan, kerusakan lingkungan, atau gangguan terhadap kebutuhan dasar.

Kedua, dampak terhadap pelayanan publik. Negara harus menilai jumlah layanan yang terganggu, jumlah penduduk terdampak, sifat layanan, kelompok rentan yang bergantung padanya, dan kemungkinan penggunaan saluran alternatif.

Ketiga, dampak ekonomi dan keuangan. Penilaian mencakup kerugian langsung, gangguan transaksi, hilangnya produksi, terganggunya distribusi, risiko terhadap stabilitas keuangan, dan dampak terhadap kepercayaan pasar.

Keempat, dampak geografis. Gangguan dapat bersifat lokal, regional, nasional, atau lintas negara. Namun, luas wilayah tidak boleh menjadi satu-satunya ukuran. Gangguan lokal pada simpul utama dapat memicu dampak nasional.

Kelima, durasi gangguan dan kemampuan pemulihan. Sistem yang dapat dipulihkan dalam beberapa menit mempunyai profil risiko berbeda dari sistem yang membutuhkan waktu berminggu-minggu. Penilaian harus memperhitungkan *maximum tolerable downtime*, kapasitas cadangan, dan waktu pemulihan realistis.

Keenam, ketergantungan antar sektor. Sistem menjadi semakin kritikal ketika banyak layanan lain bergantung padanya. Telekomunikasi bergantung pada energi; layanan keuangan bergantung pada telekomunikasi dan identitas; rumah sakit bergantung pada listrik, jaringan, data, dan rantai pasokan farmasi.

Ketujuh, dampak terhadap pertahanan, keamanan, dan kesinambungan pemerintahan. Sistem yang menopang pengambilan keputusan negara, komunikasi pemerintahan, pertahanan, penegakan hukum, atau manajemen bencana memerlukan penilaian khusus.

Kedelapan, dampak terhadap kepercayaan publik. Gangguan yang merusak kepercayaan terhadap identitas digital, pemilu, data penduduk, sistem pembayaran, atau informasi resmi negara dapat menimbulkan dampak yang jauh lebih panjang daripada waktu gangguannya.

Kriteria tersebut perlu diterjemahkan menjadi metodologi penilaian yang terukur. Namun, undang-undang tidak perlu mengunci angka yang akan cepat usang. Keamanan Ketahanan Siber cukup menetapkan dimensi, prinsip, proses, hak, dan kewajiban dasarnya. Ambang numerik dapat ditetapkan serta diperbarui melalui peraturan pelaksanaan berdasarkan kajian risiko.

Penilaian juga tidak boleh hanya mengukur probabilitas serangan. Infrastruktur yang sangat jarang gagal tetap dapat dikategorikan kritikal apabila dampak kegagalannya sangat besar. Dengan kata lain:

> **Risiko IIK bukan hanya persoalan seberapa mungkin sistem diserang, tetapi seberapa berat akibatnya ketika sistem benar-benar gagal.**

Pendekatan ini sejalan dengan NIST Cybersecurity Framework 2.0 yang menempatkan pengelolaan risiko dalam konteks misi, pemangku kepentingan, aset, ancaman, kerentanan, dan dampak. Kerangka tersebut ditujukan untuk membantu organisasi pemerintah maupun industri mengurangi risiko siber, tetapi bukan undang-undang yang dapat disalin secara mentah ke Indonesia. NIST Cybersecurity Framework 2.0

2.3 Ketergantungan dan Dampak Kaskade

Infrastruktur digital modern tidak berdiri sendiri. Sebuah sistem dapat terlihat kuat ketika diperiksa secara individual, tetapi sebenarnya rapuh karena bergantung pada banyak komponen yang berada di luar kendalinya.

Sebuah layanan kesehatan dapat mempunyai server dan aplikasi yang baik, tetapi tetap berhenti ketika listrik, konektivitas, DNS, autentikasi, cloud, atau penyedia perangkat lunaknya gagal. Sistem pembayaran dapat memiliki pusat data cadangan, tetapi kedua pusat data tersebut mungkin menggunakan operator telekomunikasi, vendor perangkat, layanan identitas, atau rantai pasokan yang sama.

Ketahanan tidak cukup dinilai dari redundansi yang terlihat. Negara harus memeriksa apakah sistem cadangan mempunyai **kegagalan bersama atau *common-mode failure***. Dua pusat data bukan redundansi nyata apabila keduanya tergantung pada pemasok, jaringan, perangkat lunak, wilayah risiko, atau mekanisme autentikasi yang sama.

Dampak kaskade terjadi ketika kegagalan pada satu simpul memicu gangguan pada fungsi lain. Kegagalan listrik memutus telekomunikasi; gangguan telekomunikasi menghambat transaksi dan koordinasi; terganggunya pembayaran memengaruhi distribusi logistik; gangguan logistik kemudian berdampak pada pangan, kesehatan, dan ketertiban sosial.

Karena itu, pemetaan IIK perlu melihat sedikitnya empat jenis dependensi.

> **Dependensi fisik**, seperti listrik, bahan bakar, bangunan, pendinginan, jalur kabel, dan lokasi pusat data.
>
> **Dependensi digital**, seperti cloud, DNS, identitas, API, perangkat lunak, sertifikat digital, repository, dan layanan keamanan.
>
> **Dependensi operasional**, seperti tenaga ahli, vendor pemeliharaan, prosedur manual, akses jarak jauh, dan suku cadang.
>
> **Dependensi kelembagaan**, seperti perizinan, koordinasi, pengambilan keputusan, kontrak, dan kewenangan ketika terjadi krisis.

Sektor kecil atau perusahaan kecil dapat menjadi kritikal apabila menjadi pemasok tunggal atau menguasai satu titik yang sulit digantikan. Hal ini disebut sebagai *single point of failure*. Besarnya perusahaan tidak relevan jika kegagalannya dapat menghentikan banyak fungsi lain.

Keamanan Ketahanan Siber harus memerintahkan penyelenggara IIK untuk mengidentifikasi pemasok dan dependensi kritikal hingga tingkat yang material. Namun, kewajiban ini harus berorientasi pada risiko, bukan pada pengumpulan daftar vendor tanpa tujuan. Pemetaan harus menghasilkan keputusan, antara lain:

- Dependensi mana yang harus dikurangi?
- Pemasok mana yang membutuhkan pengawasan lebih kuat?
- Komponen mana yang memerlukan alternatif?
- Data dan layanan mana yang harus dapat dipindahkan?
- Bagaimana operasi dilanjutkan apabila pemasok utama gagal?
- Siapa yang harus diberi prioritas pemulihan dalam krisis nasional?

Dalam buku *Framework Peringkat Keamanan Siber dan Kepatuhan Data Pribadi untuk Dunia Perbankan Indonesia*, risiko konsentrasi vendor dan risiko pihak ketiga ditempatkan sebagai bagian dari ketahanan operasional. Prinsip tersebut dapat diperluas ke tingkat negara: **peta IIK tidak lengkap tanpa peta dependensi dan konsentrasi pemasoknya.**

Negara juga perlu berhati-hati terhadap konsentrasi pada teknologi asing. Kedaulatan tidak berarti semua teknologi harus dibuat di dalam negeri. Namun, untuk setiap dependensi kritikal, Indonesia harus mempunyai kemampuan memahami risikonya, mengaudit sesuai kebutuhan, menyiapkan alternatif, memindahkan data, mengganti pemasok, dan mempertahankan fungsi ketika layanan eksternal terganggu.

> **Tidak ada kedaulatan jika layanan nasional berhenti hanya karena satu vendor, satu lisensi, satu cloud, atau satu negara pemasok berubah kebijakan.**

2.4 Tingkatan Kekritisan Nasional

Tidak semua IIK mempunyai tingkat kekritisan yang sama. Oleh sebab itu, penetapan biner—kritikal atau tidak kritikal—terlalu sederhana. Keamanan Ketahanan Siber perlu membuka ruang bagi klasifikasi berjenjang agar kewajiban, pengawasan, investasi, dan sanksi dapat diterapkan secara proporsional.

Sebagai konsep kebijakan, Indonesia dapat menggunakan empat tingkat kekritisan.

Tingkat I – Strategis Nasional

Mencakup fungsi yang kegagalannya dapat mengancam keselamatan manusia dalam skala besar, kesinambungan pemerintahan, pertahanan dan keamanan, stabilitas keuangan nasional, atau beberapa sektor kritikal sekaligus.

Penyelenggara pada tingkat ini menerima kewajiban paling kuat, termasuk tata kelola pimpinan, pemetaan dependensi mendalam, pengujian ketahanan, pusat kendali cadangan, pelaporan cepat, audit berkala, dan rencana pemulihan lintas sektor.

Tingkat II – Kritikal Sektoral

Mencakup fungsi yang kegagalannya menimbulkan dampak serius pada satu sektor, wilayah besar, atau populasi yang signifikan, tetapi masih dapat ditangani melalui kapasitas sektor dengan bantuan nasional terbatas.

Kewajibannya tetap tinggi, tetapi disesuaikan dengan karakter dan risiko sektor.

Tingkat III – Esensial Regional atau Rantai Pasokan

Mencakup layanan yang sangat penting bagi wilayah tertentu atau menjadi pemasok kritikal bagi penyelenggara Tingkat I dan II. Organisasinya dapat berukuran kecil, tetapi posisinya dalam rantai dependensi membuatnya signifikan.

Pendekatan terhadap tingkat ini seharusnya menyeimbangkan kewajiban dan bantuan. Negara tidak boleh hanya memerintah, tetapi juga menyediakan standar sederhana, dukungan teknis, pengujian bersama, dan akses informasi ancaman.

Tingkat IV – Infrastruktur Penting dengan Kewajiban Dasar

Mencakup sistem yang penting bagi layanan dan ekonomi, tetapi kegagalannya belum menghasilkan dampak sistemik. Penyelenggara tetap wajib menjalankan keamanan dasar, manajemen risiko, pelaporan tertentu, dan rencana pemulihan, tanpa dibebani kontrol tingkat strategis nasional.

Klasifikasi ini merupakan usulan konseptual, bukan kutipan dari klasifikasi yang saat ini berlaku. Nama dan jumlah tingkat dapat disesuaikan dalam proses legislasi. Yang terpenting adalah prinsipnya: **kewajiban meningkat sejalan dengan besarnya dampak dan kedalaman dependensi.**

Pendekatan Uni Eropa dalam NIS2 membedakan entitas esensial dan entitas penting serta menerapkan ruang lingkup yang mempertimbangkan sektor dan ukuran organisasi, dengan pengecualian tertentu berdasarkan sifat kritikalnya. NIS2 juga menghubungkan klasifikasi dengan manajemen risiko, pelaporan insiden, pengawasan, dan pertanggungjawaban pimpinan. Indonesia tidak harus menyalin kategori tersebut, tetapi dapat mengambil pelajaran mengenai diferensiasi kewajiban. European Commission – NIS2

Klasifikasi berjenjang juga membantu negara menentukan prioritas anggaran. Infrastruktur Tingkat I harus memperoleh perhatian tertinggi dalam latihan nasional, dukungan pemulihan, penelitian, pengembangan talenta, dan pembangunan teknologi domestik. Tanpa prioritas, sumber daya akan tersebar tipis dan tidak cukup kuat untuk melindungi fungsi yang paling menentukan.

2.5 Penetapan, Evaluasi, dan Pengakhiran Status IIK

Status IIK membawa konsekuensi hukum, biaya, tanggung jawab pimpinan, kewajiban pelaporan, audit, dan pengawasan. Oleh karena itu, penetapannya tidak boleh dilakukan secara tertutup, tanpa indikator, atau tanpa kesempatan bagi penyelenggara untuk memberikan data dan keberatan.

Proses penetapan perlu dilakukan melalui beberapa tahap.

> **Pertama,** kementerian atau regulator sektoral mengidentifikasi fungsi esensial di dalam sektornya.
>
> **Kedua,** penyelenggara melakukan penilaian mandiri menggunakan metodologi nasional.
>
> **Ketiga,** regulator memvalidasi fungsi, dampak, dependensi, waktu pemulihan, alternatif, serta tingkat kekritisannya.
>
> **Keempat,** BSSN melakukan harmonisasi lintas sektor untuk menemukan dependensi bersama, konsentrasi risiko, dan potensi dampak kaskade.
>
> **Kelima,** status dan tingkat kekritisan ditetapkan oleh pejabat atau lembaga yang berwenang berdasarkan prosedur yang dinyatakan dalam undang-undang dan peraturan pelaksanaan.
>
> **Keenam,** penyelenggara memperoleh penjelasan mengenai alasan penetapan, ruang lingkup sistem yang termasuk, kewajiban yang berlaku, jadwal pemenuhan, serta mekanisme keberatan.

Penetapan harus menghasilkan batas objek yang jelas. Tidak tepat apabila seluruh organisasi langsung dianggap IIK hanya karena satu fungsi di dalamnya kritikal. Penyelenggara perlu mengetahui sistem, layanan, proses, lokasi, data, atau dependensi mana yang masuk ruang lingkup pengawasan.

Status IIK juga tidak boleh berlaku tanpa evaluasi. Teknologi berubah, layanan dihentikan, penyedia baru muncul, dependensi berpindah, merger terjadi, dan pola penggunaan masyarakat berkembang. Sistem yang dahulu kritikal dapat kehilangan perannya. Sebaliknya, layanan yang awalnya kecil dapat tumbuh menjadi simpul nasional.

Evaluasi dapat dilakukan secara berkala dan sewaktu-waktu apabila terjadi perubahan material, seperti:

- Perubahan arsitektur atau kepemilikan.
- Migrasi ke penyedia cloud atau platform baru.
- Peningkatan tajam jumlah pengguna.
- Perubahan fungsi pelayanan publik.
- Akuisisi atau konsolidasi pasar.
- Munculnya ketergantungan lintas sektor.
- Insiden besar yang memperlihatkan dampak baru.
- Tersedianya penyedia alternatif atau dihentikannya suatu layanan.

Keamanan Ketahanan Siber juga perlu menyediakan mekanisme pengakhiran atau penurunan status. Status IIK bukan gelar permanen. Jika fungsi telah dihentikan, dipindahkan, digantikan, atau tidak lagi memenuhi ambang kekritisan, statusnya harus dapat ditinjau dan dicabut.

> **Status yang dapat ditetapkan tetapi tidak dapat dipersoalkan atau diakhiri akan berubah dari instrumen perlindungan menjadi sumber ketidakpastian hukum.**

2.6 Informasi IIK yang Terbuka dan yang Harus Dirahasiakan

Kebijakan IIK berhadapan dengan dua kepentingan yang sama-sama sah. Publik membutuhkan transparansi mengenai kriteria, sektor, kewajiban, pengawasan, dan akuntabilitas. Namun, keterbukaan berlebihan mengenai kelemahan teknik, arsitektur, dependensi, dan titik kegagalan dapat memberikan peta serangan kepada pihak yang berniat buruk.

Karena itu, keterbukaan harus dibagi menjadi beberapa lapisan.

Informasi yang seharusnya terbuka meliputi dasar hukum, definisi, kriteria penetapan, sektor yang tercakup, jenis kewajiban, mekanisme keberatan, regulator yang berwenang, statistik agregat, serta laporan kinerja perlindungan nasional.

Keterbukaan ini diperlukan agar regulasi dapat dipahami, diawasi, dan dipatuhi. Penyelenggara harus dapat memperkirakan apakah suatu fungsi berpotensi ditetapkan sebagai IIK dan kewajiban apa yang akan timbul.

Informasi yang aksesnya perlu dibatasi meliputi daftar rinci aset, arsitektur jaringan, konfigurasi keamanan, kelemahan yang belum diperbaiki, kredensial, jalur pemulihan, dependensi tunggal, lokasi cadangan, hasil pengujian penetrasi, serta indikator teknis sensitif.

Informasi yang dapat dibagikan secara terkendali meliputi indikator ancaman, pola serangan, status kerentanan, dependensi lintas sektor, dan informasi respons yang dibutuhkan oleh lembaga atau mitra tertentu.

Klasifikasi informasi harus ditentukan berdasarkan dampak apabila informasi tersebut dibuka, bukan berdasarkan keinginan institusi untuk menghindari kritik. Kegagalan tata kelola, keterlambatan pemulihan, dan kelalaian tidak boleh disembunyikan hanya dengan memberikan label rahasia.

Sebaliknya, keterbukaan juga tidak boleh memaksa penyelenggara mengumumkan detail yang mempermudah serangan lanjutan. Bentuk laporan publik dapat menggunakan agregasi, anonimisasi, rentang nilai, atau penundaan terbatas sampai risiko teknis terkendali.

Pengelolaan informasi IIK perlu menerapkan prinsip:

- Hak akses minimum.
- Tujuan penggunaan yang jelas.
- Pencatatan setiap akses.
- Batas waktu penyimpanan.
- Perlindungan selama pengiriman dan penyimpanan.
- Larangan penggunaan sekunder tanpa dasar hukum.
- Pemusnahan atau pengembalian data setelah tidak diperlukan.
- Pertanggungjawaban atas penyalahgunaan.

Transparansi dibutuhkan untuk menjaga demokrasi; kerahasiaan dibutuhkan untuk menjaga pertahanan. Negara harus mampu melakukan keduanya tanpa menggunakan salah satunya sebagai alasan untuk menghancurkan yang lain.

2.7 Perlindungan terhadap Pelaku Kecil dan Rantai Ketergantungan

Proporsionalitas menjadi persoalan utama ketika organisasi kecil masuk ke dalam rantai pasokan IIK. UMKM, pengembang perangkat lunak lokal, penyedia layanan daerah, startup, laboratorium, integrator, dan vendor khusus dapat menjadi bagian penting dari layanan nasional. Namun, kemampuan finansial, SDM, dan tata kelola mereka tidak sebanding dengan operator nasional.

Ada dua kesalahan yang harus dihindari.

> **Kesalahan pertama** adalah mengecualikan semua pelaku kecil. Pendekatan ini berbahaya karena ***attacker*** sering mencari titik terlemah dalam rantai pasokan. Perusahaan kecil dapat mempunyai akses istimewa, menyimpan kredensial, mengelola pembaruan, atau menyediakan komponen yang digunakan banyak penyelenggara.
>
> **Kesalahan kedua** adalah membebankan kewajiban setara operator nasional kepada seluruh pelaku kecil. Beban tersebut dapat mematikan inovasi domestik, memperkuat dominasi vendor besar, dan mendorong organisasi kecil keluar dari pasar.

Solusinya adalah **proporsionalitas berbasis peran dan risiko**. Pelaku kecil tetap harus memenuhi keamanan dasar, tetapi persyaratannya disesuaikan dengan akses, jenis layanan, sensitivitas data, kemampuan mempengaruhi sistem, serta dampak kegagalannya.

Penyedia kecil yang tidak memiliki akses ke sistem kritikal mungkin cukup memenuhi standar dasar. Sebaliknya, penyedia kecil yang memegang kredensial administratif, menyediakan pembaruan perangkat lunak, mengelola identitas, atau menjadi pemasok tunggal harus memenuhi persyaratan lebih tinggi.

Namun, peningkatan kewajiban perlu disertai dukungan negara dan penyelenggara utama. Dukungan tersebut dapat berupa:

Standar minimum yang sederhana dan mudah diterapkan.

- Model kontrak keamanan yang adil.
- Layanan penilaian serta pengujian bersama.
- Akses kepada peringatan ancaman.
- Pendampingan peningkatan kematangan.
- Pelatihan dan pengembangan tenaga.
- Masa transisi yang realistis.
- Insentif pengadaan untuk produk domestik yang aman.
- Pembiayaan atau subsidi bagi peningkatan keamanan pemasok kritikal.

Penyelenggara IIK besar juga tidak boleh memindahkan seluruh risiko kepada pemasok kecil melalui kontrak. Organisasi utama tetap bertanggung jawab menilai, memantau, membantu, dan mengendalikan risiko rantai pasoknya.

Perkembangan kebijakan Uni Eropa pada 2026 juga memperlihatkan perhatian terhadap kejelasan hukum dan penyederhanaan beban kepatuhan bagi perusahaan, termasuk usaha mikro dan kecil, tanpa menghapus tujuan keamanan. Pelajarannya bagi Indonesia adalah bahwa **regulasi yang baik tidak hanya menentukan siapa yang wajib patuh, tetapi juga memastikan kepatuhan tersebut realistis dan meningkatkan keamanan nyata**.

Kebijakan pengadaan pemerintah dapat menjadi pengungkit penting. Produk lokal tidak cukup dipilih hanya karena murah atau berlabel dalam negeri. Negara perlu membantu industri domestik meningkatkan keamanan, dokumentasi, kemampuan pembaruan, interoperabilitas, dan kesinambungan dukungan.

Kemandirian teknologi tidak lahir dari proteksi pasar tanpa peningkatan mutu. Kemandirian lahir ketika produk lokal memperoleh kesempatan, dukungan, standar yang jelas, dan tekanan sehat untuk terus membaik.

> **Pelaku kecil jangan dibiarkan menjadi titik lemah, tetapi jangan pula dihukum karena belum mempunyai kapasitas sebesar perusahaan global. Negara harus membangun kapasitasnya.**

2.8 Keputusan Strategis Bab 2

Keamanan Ketahanan Siber perlu membangun sistem perlindungan IIK yang objektif, dinamis, proporsional, dan berorientasi pada kesinambungan fungsi negara.

Keputusan pertama adalah **menyelaraskan istilah IIK dalam Keamanan Ketahanan Siber dengan istilah IIV dalam Peraturan Presiden Nomor 82 Tahun 2022**. Harmonisasi harus mencakup definisi, ruang lingkup, penyelenggara, sektor, kewajiban, mekanisme penetapan, dan peraturan pelaksanaan yang sudah ada.

Keputusan kedua adalah menetapkan bahwa objek perlindungan bukan hanya institusi, melainkan **fungsi esensial beserta sistem, proses, data, manusia, teknologi operasional, pemasok, dan dependensi yang menopangnya**.

Keputusan ketiga adalah **menetapkan dimensi dampak** dalam batang tubuh undang-undang. Dimensi tersebut setidaknya mencakup keselamatan manusia, pelayanan publik, ekonomi, wilayah, durasi, dependensi antar sektor, pertahanan dan keamanan, kesinambungan pemerintahan, serta kepercayaan publik.

Keputusan keempat adalah menggunakan **klasifikasi kekritisan secara berjenjang**. Tingkat kekritisan menentukan kedalaman kewajiban, bentuk pengawasan, prioritas bantuan, frekuensi evaluasi, dan konsekuensi ketidakpatuhan.

Keputusan kelima adalah membentuk **proses penetapan yang transparan** dan dapat dipersoalkan. Penyelenggara harus mengetahui alasan, ruang lingkup, tingkat, kewajiban, masa transisi, serta mekanisme keberatannya.

Keputusan keenam adalah **mewajibkan evaluasi berkala** dan evaluasi setelah perubahan material. Status IIK harus dapat dinaikkan, diturunkan, diperluas, dipersempit, atau diakhiri.

Keputusan ketujuh adalah **mengatur klasifikasi informasi IIK**. Kriteria, kewajiban, dan akuntabilitas harus terbuka, sedangkan detail teknis yang meningkatkan risiko serangan harus dilindungi.

Keputusan kedelapan adalah **menerapkan kewajiban secara proporsional** kepada pelaku kecil dan pemasok kritikal. Kewajiban harus disertai dukungan, peningkatan kapasitas, masa transisi, standar sederhana, dan insentif untuk membangun industri keamanan domestik.

Detail angka, ambang, metodologi penilaian, format pelaporan, dan standar teknis dapat ditempatkan dalam peraturan pelaksanaan agar mudah diperbarui. Namun, **definisi, dimensi dampak, dasar klasifikasi, hak penyelenggara, prinsip proporsionalitas, kewajiban pokok, dan mekanisme pengawasan harus ditetapkan dalam undang-undang.**

Indonesia tidak membutuhkan daftar IIK yang panjang tetapi tidak dipahami. Indonesia membutuhkan peta fungsi nasional yang menunjukkan apa yang tidak boleh berhenti, apa yang menjadi ketergantungan bersama, siapa yang bertanggung jawab, dan bagaimana negara memulihkannya.

> **Lindungi fungsi yang menentukan hidup rakyat dan keberlangsungan negara. Nama institusi dapat berubah; fungsi esensial harus tetap berjalan.**

RANGKUMAN BAB 2

Bagian	Masalah utama	Arah kebijakan	Keputusan yang diperlukan
2.1 Fungsi kritikal	Kekritisan sering dikaitkan dengan ukuran atau nama institusi	Lindungi fungsi, layanan, proses, dan sistem yang tidak boleh gagal	Tetapkan IIK berdasarkan akibat kegagalan, bukan status pemilik
2.2 Dampak sistemik	Istilah “dampak serius” berisiko ditafsirkan terlalu luas	Gunakan dimensi dampak yang objektif dan dapat diukur	Nilai keselamatan, pelayanan, ekonomi, wilayah, durasi, pertahanan, dan kepercayaan
2.3 Dependensi dan dampak kaskade	Sistem terlihat kuat tetapi bergantung pada titik kegagalan bersama	Petakan dependensi fisik, digital, operasional, dan kelembagaan	Identifikasi pemasok tunggal, konsentrasi teknologi, alternatif, dan rencana keluar
2.4 Tingkat kekritisan	Klasifikasi biner menghasilkan kewajiban yang terlalu berat atau terlalu ringan	Terapkan klasifikasi kekritisan berjenjang	Sesuaikan kewajiban, pengawasan, bantuan, dan sanksi dengan risiko
2.5 Siklus status IIK	Status dapat menimbulkan biaya dan ketidakpastian hukum	Gunakan proses penetapan yang transparan dan dinamis	Sediakan validasi, alasan penetapan, evaluasi, keberatan, dan pengakhiran status
2.6 Keterbukaan informasi	Keterbukaan berlebihan meningkatkan risiko, tetapi kerahasiaan berlebihan menutup akuntabilitas	Pisahkan informasi publik, terbatas, dan rahasia	Buka kriteria serta akuntabilitas; lindungi kelemahan dan arsitektur sensitif
2.7 Pelaku kecil	Pengecualian menciptakan titik lemah, sedangkan kewajiban seragam mematikan inovasi	Terapkan proporsionalitas berbasis peran dan risiko	Berikan standar sederhana, dukungan teknis, insentif, dan masa transisi
2.8 Keputusan strategis	Istilah, kriteria, dan kewajiban berpotensi terfragmentasi	Bangun satu kerangka IIK yang harmonis dan adaptif	Selaraskan IIK dengan IIV serta tempatkan norma pokok dalam undang-undang

REFERENSI UTAMA BAB 2

Badan Pemeriksa Keuangan Republik Indonesia. Peraturan Presiden Nomor 82 Tahun 2022 tentang Perlindungan Infrastruktur Informasi Vital. https://peraturan.bpk.go.id/Details/211029/perpres-no-82-tahun-2022

European Commission. NIS2 Directive: Securing Network and Information Systems. https://digital-strategy.ec.europa.eu/en/policies/nis2-directive

National Institute of Standards and Technology. The NIST Cybersecurity Framework 2.0. https://www.nist.gov/cyberframework

Purbo, Onno W. *Framework Peringkat Keamanan Siber & Kepatuhan Data Pribadi untuk Dunia Perbankan Indonesia*. 2025.

Purbo, Onno W. *Strategic Blueprint: AI Integration in the Corporate SOC—A CISO's Roadmap for Cognitive Cyber Defense, Digital Sovereignty, and Business Resilience*. 2026.

BAB 3 - NORMAL, ESKALASI, TEGANG, DARURAT: TANGGA KRISIS YANG DAPAT DIUKUR

Serangan siber jarang bergerak dari keadaan aman langsung menjadi bencana nasional. Biasanya terdapat tanda-tanda awal: peningkatan pemindaian, eksploitasi kerentanan yang sama pada banyak organisasi, gangguan pada pemasok digital, penyebaran malware, penurunan kualitas layanan, atau munculnya pola serangan terkoordinasi lintas sektor.

Masalahnya, tanda-tanda tersebut sering tersebar pada banyak institusi. Setiap lembaga melihat sebagian kecil dari situasi, sementara tidak ada pihak yang mempunyai gambaran utuh. Ketika pemerintah akhirnya menyimpulkan bahwa negara sedang menghadapi krisis, dampaknya mungkin sudah meluas.

Di sisi lain, negara juga tidak boleh terlalu mudah menetapkan keadaan darurat. Status krisis dapat membuka kewenangan tambahan, meningkatkan akses terhadap informasi, mengubah prioritas anggaran, mempengaruhi layanan publik, dan membatasi keputusan operasional penyelenggara. Tanpa indikator, batas waktu, dan pengawasan, status darurat dapat menjadi jalan pintas untuk memperluas kekuasaan.

Peraturan Presiden Nomor 47 Tahun 2023 telah memberikan landasan bagi Strategi Keamanan Siber Nasional dan Manajemen Krisis Siber. Namun, Regulasi Keamanan Ketahanan Siber secara tepat mengangkat kebutuhan akan *escalation ladder* yang lebih terperinci. Usulan empat kondisi—Normal, Eskalasi, Tegang, dan Darurat—harus dipahami sebagai **desain kebijakan yang perlu dinormakan secara hati-hati**, bukan sebagai status hukum yang otomatis telah berlaku.

Empat tingkat tersebut bukan sekadar empat warna pada sebuah *dashboard*. Setiap tingkat harus menjawab:

- Apa indikatornya?
- Siapa yang menetapkan?
- Siapa yang memimpin?
- Kewenangan apa yang aktif?
- Sumber daya apa yang dapat dikerahkan?
- Siapa yang harus diberi tahu?
- Berapa lama status berlaku?
- Apa syarat untuk menurunkan atau mengakhirinya?

  Status tanpa indikator adalah opini. Status tanpa batas waktu adalah kekuasaan tanpa kendali. Status tanpa rencana pemulihan adalah pengakuan bahwa negara tidak siap.

3.1 Mengapa Model Biner Tidak Memadai

Model biner membagi keadaan menjadi dua: **insiden** dan **krisis.** Model ini terlalu kasar untuk menghadapi ancaman siber modern.

Tidak setiap insiden memerlukan intervensi nasional. Sebuah akun pegawai yang berhasil diambil alih, gangguan sementara pada situs, atau infeksi malware pada satu perangkat dapat ditangani oleh organisasi yang terdampak. Namun, insiden kecil juga dapat menjadi bagian dari operasi yang lebih luas. Jika insiden serupa terjadi pada banyak kementerian, bank, rumah sakit, atau operator energi, negara perlu meningkatkan kesiapan sebelum dampaknya berubah menjadi krisis.

Tanpa tingkat antara, pemerintah menghadapi dua pilihan buruk. Pilihan pertama adalah tidak berbuat lebih banyak karena situasi belum secara resmi disebut krisis. Pilihan kedua adalah langsung menetapkan krisis dengan konsekuensi kewenangan dan komunikasi yang terlalu besar.

Model berjenjang memungkinkan negara menaikkan perhatian, koordinasi, sumber daya, dan kewenangan secara bertahap. Negara tidak perlu menunggu layanan publik lumpuh untuk meningkatkan kesiapan. Pada saat yang sama, negara tidak perlu menggunakan kewenangan darurat hanya untuk menangani peningkatan ancaman yang masih dapat dikendalikan.

Sebelum membangun empat tingkat kondisi, Keamanan Ketahanan Siber perlu membedakan beberapa istilah dasar.

> **Peristiwa siber** adalah kejadian yang dapat diamati pada sistem, jaringan, aplikasi, data, atau layanan. Sebagian besar peristiwa tidak berbahaya.
>
> **Ancaman siber** adalah keadaan, aktor, kemampuan, atau tindakan yang berpotensi menimbulkan kerugian.
>
> **Insiden siber** adalah kejadian yang telah mengganggu atau mengancam kerahasiaan, integritas, ketersediaan, keaslian, atau keberlangsungan sistem dan layanan.
>
> **Insiden besar** adalah insiden yang menimbulkan dampak material dan memerlukan koordinasi di luar kapasitas penanganan rutin organisasi.
>
> **Krisis siber nasional** adalah keadaan ketika dampak aktual atau potensi dampak dari satu atau beberapa insiden mengancam fungsi penting negara, keselamatan publik, stabilitas ekonomi, pertahanan dan keamanan, atau kesinambungan pemerintahan, sehingga memerlukan keputusan dan koordinasi tingkat nasional.

Pembedaan tersebut penting karena sebuah serangan teknis belum tentu menjadi krisis nasional. Sebaliknya, krisis nasional dapat terbentuk dari akumulasi berbagai insiden yang secara individual terlihat kecil.

NIST SP 800-61 Revision 3, yang diterbitkan pada April 2025, menempatkan respons insiden sebagai bagian dari manajemen risiko siber yang berlangsung terus-menerus. NIST juga menegaskan bahwa triase, prioritas, eskalasi, dan keputusan pemulihan perlu didasarkan pada faktor evaluasi risiko, bukan urutan kedatangan laporan. Kerangka tersebut bukan hukum Indonesia, tetapi memberi pelajaran bahwa **respons insiden tidak boleh dimulai hanya setelah krisis diumumkan**. NIST SP 800-61 Revision 3

Model berjenjang juga menghindari pendekatan yang terlalu berpusat pada atribusi. Pada tahap awal, negara mungkin belum mengetahui siapa penyerangnya. Namun, ketidakpastian atribusi tidak boleh menghambat perlindungan dan pemulihan.

> **Negara harus dapat bertindak berdasarkan dampak dan resiko, tanpa menunggu kepastian siapa pelakunya. Atribusi penting untuk diplomasi, pertahanan, dan penegakan hukum; pemulihan layanan tidak boleh menunggunya.**

3.2 Kondisi Normal

Kondisi Normal bukan keadaan tanpa serangan. Dalam dunia digital, pemindaian, percobaan akses, malware, penipuan, dan eksploitasi terjadi setiap hari. Kondisi Normal berarti ancaman serta insiden masih dapat ditangani melalui struktur, kapasitas, dan kewenangan rutin.

Justru pada kondisi Normal, pekerjaan terpenting harus dilakukan. Negara harus membangun kesiapan sebelum krisis, bukan menyusun struktur ketika sistem sudah lumpuh.

Agenda pada Kondisi Normal mencakup:

Pemutakhiran inventaris fungsi dan aset kritikal.

- Pemetaan dependensi lintas sektor.
- Penilaian risiko dan kerentanan.
- Pemantauan ancaman serta peringatan dini.
- Penguatan CSIRT kementerian, sektor, pemerintah daerah, dan penyelenggara.
- Latihan teknis dan latihan pengambilan keputusan.
- Pengujian rencana kesinambungan serta pemulihan.
- Penyiapan jalur komunikasi alternatif.
- Pertukaran informasi ancaman secara rutin.
- Evaluasi pemasok dan konsentrasi teknologi.
- Penyiapan daftar ahli serta sumber daya yang dapat dikerahkan.
- Penyusunan pesan publik dan mekanisme komunikasi krisis.

Kondisi Normal harus mempunyai pemimpin yang jelas. Setiap penyelenggara bertanggung jawab atas sistemnya. Regulator bertanggung jawab atas kesiapan sektornya. BSSN mengoordinasikan kesiapan teknis nasional, standar, peringatan dini, serta jejaring CSIRT. Pengambil keputusan tingkat nasional menerima gambaran risiko strategis secara berkala.

Ukuran keberhasilan pada Kondisi Normal bukan jumlah rapat, dokumen, perangkat, atau sertifikat. Ukurannya adalah:

- Apakah fungsi kritikal telah dipetakan?
- Apakah dependensi diketahui?
- Apakah kontak pengambil keputusan mutakhir?
- Apakah jalur komunikasi cadangan tersedia?
- Apakah sistem dapat dipulihkan dari cadangan yang telah diuji?
- Apakah sektor dapat bekerja bersama?
- Apakah pimpinan memahami keputusan yang harus dibuat saat krisis?
- Apakah negara dapat tetap beroperasi ketika satu vendor atau jaringan utama gagal?

Latihan harus menguji kegagalan keputusan, bukan hanya kegagalan mesin. Banyak latihan siber berhenti pada tim teknis, padahal krisis nyata membutuhkan keputusan mengenai penghentian layanan, prioritas pemulihan, komunikasi kepada publik, koordinasi dengan penegak hukum, dukungan pertahanan, dan hubungan internasional.

Dalam kondisi Normal, negara juga harus menentukan *baseline* nasional. Tanpa gambaran normal, anomali sulit diukur. Pemerintah perlu mengetahui pola layanan normal, kapasitas normal, tingkat insiden rutin, waktu pemulihan wajar, serta dependensi utama. Data tersebut membentuk dasar untuk mengenali perubahan menuju Kondisi Eskalasi.

> **Kondisi Normal bukan waktu untuk merasa aman. Kondisi Normal adalah waktu untuk membangun kemampuan agar negara tidak panik ketika ancaman meningkat.**

3.3 Kondisi Eskalasi

Kondisi Eskalasi diaktifkan ketika ancaman meningkat melampaui pola normal, tetapi belum menimbulkan gangguan nasional yang serius. Fokus utamanya adalah **meningkatkan kewaspadaan, memperluas koordinasi, memverifikasi situasi, dan mencegah ancaman berkembang menjadi krisis**.

Indikator Kondisi Eskalasi dapat meliputi:

- Peningkatan signifikan aktivitas serangan terhadap satu atau beberapa sektor.
- Eksploitasi aktif terhadap kerentanan yang terdapat pada banyak organisasi.
- Kampanye phishing, malware, atau pengambilalihan akun yang terkoordinasi.
- Insiden serupa pada beberapa penyelenggara.
- Gangguan pada pemasok teknologi yang digunakan banyak institusi.
- Peringatan kredibel dari mitra nasional atau internasional.
- Indikasi kompromi pada sistem dengan hak akses tinggi.
- Penurunan kapasitas layanan yang belum mencapai dampak nasional.
- Ancaman terhadap proses strategis seperti pemilu, penyaluran bantuan, pelayanan kesehatan, atau transaksi nasional.

Pada tahap ini, tidak diperlukan pengambilalihan komando nasional. Sektor dan penyelenggara tetap memimpin penanganan sistemnya. Namun, BSSN sebagai koordinator teknis perlu meningkatkan frekuensi pelaporan, menghubungkan informasi lintas sektor, mengeluarkan peringatan, dan memastikan tindakan pencegahan diterapkan.

Kondisi Eskalasi dapat menghasilkan beberapa tindakan tambahan:

- Pengaktifan pemantauan yang lebih intensif.
- Peningkatan frekuensi situation report.
- Validasi kontak dan kesiapan tim.
- Penerapan mitigasi terhadap kerentanan tertentu.
- Pembatasan sementara akses berisiko tinggi.
- Pemeriksaan dependensi dan vendor terkait.
- Peningkatan kapasitas pusat operasi.
- Pemberitahuan terbatas kepada pimpinan sektor.
- Persiapan komunikasi publik apabila dampak meluas.

Kondisi Eskalasi harus mempunyai ruang lingkup. Peningkatan ancaman pada sektor kesehatan tidak otomatis menaikkan status seluruh negara. Status dapat berlaku secara sektoral, geografis, fungsional, atau nasional, bergantung pada bukti dan risiko.

Status ini juga harus dinamis. Jika indikator menurun dan ancaman terkendali, keadaan dapat kembali ke Normal. Jika dampak berkembang atau kapasitas sektor mulai terlampaui, status dapat dinaikkan menjadi Tegang.

Kondisi Eskalasi pada dasarnya adalah kesempatan terakhir untuk mencegah krisis dengan biaya dan kewenangan yang relatif rendah.

> **Negara yang matang tidak dinilai dari kemampuannya mengumumkan keadaan darurat, tetapi dari kemampuannya menghentikan ancaman sebelum keadaan darurat diperlukan.**

3.4 Kondisi Tegang

Kondisi Tegang ditetapkan ketika ancaman atau gangguan telah menyentuh beberapa fungsi kritikal, melintasi sektor atau wilayah, atau menunjukkan potensi kuat menimbulkan dampak nasional. Kapasitas penanganan rutin masih berjalan, tetapi mulai berada di bawah tekanan.

Pada tingkat ini, pemerintah harus berpindah dari koordinasi peningkatan kewaspadaan menuju **koordinasi krisis nasional yang aktif**. Artinya, gambaran situasi dikonsolidasikan, prioritas nasional mulai ditetapkan, sumber daya lintas lembaga dikerahkan, dan keputusan strategis tidak lagi diserahkan hanya kepada masing-masing organisasi.

Indikator Kondisi Tegang dapat meliputi:

- Gangguan material pada lebih dari satu penyelenggara IIK.
- Penyebaran cepat ke beberapa sektor atau daerah.
- Gangguan terhadap rantai pasokan digital nasional.
- Peningkatan risiko terhadap keselamatan manusia.
- Kegagalan pemulihan dalam target waktu yang ditetapkan.
- Penggunaan kapasitas cadangan mendekati batas aman.
- Indikasi kompromi terhadap sistem pemerintahan atau fungsi strategis.
- Serangan yang berpotensi mengganggu kepercayaan terhadap layanan nasional.

Ancaman yang memerlukan bantuan teknis, intelijen, penegakan hukum, dan komunikasi publik secara bersama.

Pada Kondisi Tegang, Pusat Situasi Siber Nasional harus beroperasi dengan intensitas penuh. Laporan situasi perlu disusun pada interval yang ditetapkan. Pimpinan sektor, BSSN, aparat penegak hukum, intelijen, pertahanan, pemerintah daerah, dan penyelenggara terkait harus bekerja berdasarkan gambaran situasi serta prioritas yang sama.

Namun, peningkatan koordinasi tidak boleh diartikan sebagai pemusatan semua keputusan teknis. Operator listrik tetap paling memahami stabilitas jaringannya. Bank sentral dan regulator keuangan tetap memahami risiko sistemik sektor keuangan. Rumah sakit tetap harus mempertahankan otoritas klinis dan keselamatan pasien.

Prinsipnya adalah **pusat menetapkan tujuan dan prioritas nasional; sektor menentukan tindakan teknis paling aman dalam ruang kewenangannya**.

Kondisi Tegang juga membutuhkan disiplin komunikasi. Negara harus menunjuk juru bicara atau mekanisme komunikasi terpadu agar kementerian dan lembaga tidak mengeluarkan informasi yang saling bertentangan. Komunikasi harus menjelaskan apa yang diketahui, apa yang belum diketahui, layanan apa yang terdampak, tindakan apa yang sedang dilakukan, dan apa yang perlu dilakukan masyarakat.

Ketidakpastian harus diakui. Pemerintah tidak perlu mengisi kekosongan informasi dengan spekulasi. Pernyataan atribusi terhadap pelaku atau negara lain harus dipisahkan dari komunikasi pemulihan dan hanya dilakukan melalui proses yang sah.

Status Tegang tidak boleh dipertahankan hanya untuk berjaga-jaga tanpa evaluasi. Setiap periode tertentu, pimpinan krisis harus memutuskan apakah status dikembalikan ke Eskalasi, dipertahankan dengan alasan yang terdokumentasi, atau dinaikkan menjadi Darurat.

> **Kondisi Tegang adalah saat negara mengkonsolidasikan seluruh kemampuan sebelum gangguan berubah menjadi ancaman terhadap keberlangsungan negara.**

3.5 Kondisi Darurat

Kondisi Darurat adalah tingkat tertinggi dan harus digunakan secara sangat terbatas. Kondisi ini hanya layak ditetapkan ketika insiden siber telah menimbulkan atau sangat mungkin menimbulkan ancaman serius terhadap:

- Keselamatan publik dalam skala besar.
- Kesinambungan pemerintahan.
- Pertahanan dan keamanan negara.
- Stabilitas sistem keuangan atau ekonomi nasional.
- Ketersediaan energi, komunikasi, kesehatan, transportasi, pangan, air, atau layanan esensial lain.
- Integritas proses strategis negara.
- Kemampuan negara untuk mengendalikan dan memulihkan fungsi kritikal.

Penting untuk dibedakan bahwa **Kondisi Darurat dalam manajemen krisis siber tidak otomatis identik dengan keadaan bahaya atau keadaan darurat konstitusional**. Keamanan Ketahanan Siber harus menyatakan hubungan tersebut secara tegas. Status operasional siber tidak boleh secara otomatis menangguhkan hak, mengubah hukum acara, atau memberikan kewenangan tanpa batas.

Apabila suatu keadaan memang memenuhi syarat untuk penggunaan rezim kedaruratan lain, penetapannya harus mengikuti dasar hukum, prosedur, pejabat, dan pengawasan yang berlaku bagi rezim tersebut. Keamanan Ketahanan Siber tidak boleh menjadi jalan belakang untuk menciptakan keadaan darurat konstitusional melalui terminologi teknis.

Dalam Kondisi Darurat, Presiden seharusnya memegang keputusan politik tertinggi. Operasi teknis nasional dikoordinasikan BSSN; kementerian dan regulator menjaga kesinambungan sektornya; BIN mendukung penilaian strategis; Polri menjalankan penegakan hukum; TNI menjalankan fungsi pertahanan sesuai dasar dan mandat hukum; pemerintah daerah melaksanakan langkah perlindungan serta pelayanan kepada masyarakat.

Tindakan darurat dapat mencakup:

- Penetapan prioritas pemulihan nasional.
- Pengerahan sumber daya lintas kementerian dan lembaga.
- Pengaktifan pusat komando krisis nasional.
- Penggunaan jalur komunikasi cadangan.
- Pembatasan sementara fungsi tertentu untuk mencegah kerusakan lebih luas.
- Koordinasi bantuan teknis nasional dan internasional.
- Pengamanan rantai pasokan serta fasilitas pendukung.
- Percepatan pengadaan atau mobilisasi sumber daya dengan pengawasan khusus.
- Komunikasi publik nasional secara terkoordinasi.

Seluruh tindakan harus memenuhi prinsip **legalitas, kebutuhan, proporsionalitas, keterbatasan waktu, tujuan yang jelas, dan kemampuan audit**. Tindakan yang menyentuh data pribadi, komunikasi, hak warga, atau sistem milik pihak lain harus memperoleh pengawasan lebih kuat.

Keputusan otomatis yang berpotensi mematikan layanan kritikal harus dibatasi. Sistem AI dapat membantu analisis, korelasi, dan rekomendasi, tetapi keputusan berisiko tinggi harus tetap berada di bawah manusia yang mempunyai kewenangan dan tanggung jawab.

Dari referensi *Strategic Blueprint: AI Integration in the Corporate SOC* dapat ditarik prinsip yang sangat relevan: **kewenangan hanya boleh diberikan sebesar kemampuan organisasi untuk mengawasi, menjelaskan, menghentikan, dan memulihkan tindakannya**.

Kondisi Darurat bukan ukuran kekuatan negara. Ia adalah instrumen terakhir untuk menyelamatkan fungsi nasional. Tujuan pertama sejak status ditetapkan harus selalu sama: membatasi dampak, memulihkan fungsi kritikal, dan kembali ke tata kelola normal sesegera mungkin.

3.6 Indikator, Ambang Batas, dan Pejabat Penetap

Empat tingkat kondisi hanya berguna jika setiap tingkat mempunyai indikator terukur. Namun, satu angka tidak cukup untuk menentukan krisis. Penilaian harus menggunakan kombinasi indikator kuantitatif dan kualitatif.

Setidaknya terdapat sembilan dimensi penilaian.

Pertama, skala dampak. Berapa banyak pengguna, organisasi, layanan, transaksi, atau aset yang terdampak?

Kedua, kekritisan fungsi. Apakah insiden menyentuh layanan biasa, layanan esensial, atau fungsi strategis nasional?

Ketiga, cakupan sektor. Apakah insiden terbatas pada satu organisasi, satu sektor, atau telah menjalar ke beberapa sektor?

Keempat, cakupan geografis. Apakah dampak terjadi secara lokal, regional, nasional, atau lintas batas?

Kelima, durasi dan tren. Apakah gangguan bersifat singkat, terus memburuk, atau melampaui target waktu pemulihan?

Keenam, kapasitas penanganan. Apakah penyelenggara dan sektor masih mampu menangani situasi dengan sumber daya rutin?

Ketujuh, keselamatan serta stabilitas. Apakah terdapat risiko terhadap jiwa, proses fisik, lingkungan, ekonomi, keuangan, pertahanan, atau ketertiban?

Kedelapan, karakter ancaman. Apakah terdapat eksploitasi aktif, kampanye terkoordinasi, kemampuan canggih, atau indikasi keterlibatan aktor strategis?

Kesembilan, tingkat keyakinan informasi. Seberapa kuat kualitas bukti yang menjadi dasar keputusan?

Atribusi tidak seharusnya menjadi syarat utama peningkatan status. Negara dapat menaikkan kesiapan berdasarkan dampak, kemampuan serangan, dan risiko penyebaran meskipun identitas pelaku belum diketahui.

Pejabat penetap harus dibedakan menurut tingkatnya.

> **Pada Kondisi Normal**, tidak diperlukan keputusan khusus karena merupakan keadaan dasar.
>
> **Kondisi Eskalasi** dapat ditetapkan secara teknis oleh Kepala BSSN pada lingkup nasional atau oleh otoritas sektor sesuai kewenangannya, berdasarkan indikator yang telah ditetapkan. Penetapan segera dilaporkan kepada pimpinan pemerintahan yang relevan.
>
> **Kondisi Tegang** sebaiknya ditetapkan oleh Presiden atau pejabat setingkat menteri koordinator yang ditunjuk secara tegas oleh Presiden, berdasarkan penilaian BSSN dan rekomendasi lintas lembaga. Jika kewenangan didelegasikan, delegasi harus terbatas dan terdokumentasi.
>
> **Kondisi Darurat nasional** seharusnya ditetapkan oleh Presiden karena konsekuensinya dapat melintasi sektor, mempengaruhi pelayanan publik, menggunakan sumber daya nasional, serta menyentuh hak dan kewajiban banyak pihak.

Untuk keadaan yang bergerak sangat cepat, Regulasi dapat memungkinkan aktivasi sementara oleh pejabat tertentu dalam jangka sangat pendek. Aktivasi tersebut harus memperoleh konfirmasi Presiden dalam batas waktu yang ketat. Jika tidak dikonfirmasi, status dan kewenangan tambahannya berakhir secara otomatis.

Setiap keputusan harus dituangkan secara tertulis dan setidaknya memuat:

- Dasar hukum.
- Ringkasan fakta dan indikator.
- Tingkat serta ruang lingkup status.
- Wilayah, sektor, atau fungsi yang tercakup.
- Pemimpin dan struktur koordinasi.
- Kewenangan tambahan yang diaktifkan.
- Kewajiban pelaporan.
- Masa berlaku.
- Jadwal evaluasi.
- Syarat penurunan atau pengakhiran status.

> **Pejabat penetap tidak boleh hanya berwenang menaikkan status. Ia juga wajib meninjau, menurunkan, dan mengakhiri status ketika dasar penetapannya tidak lagi terpenuhi.**

3.7 Batas Waktu, *Sunset Clause*, dan Pengakhiran Status

Status krisis cenderung lebih mudah ditetapkan daripada diakhiri. Setelah struktur, kewenangan, anggaran, dan akses tambahan diaktifkan, selalu ada alasan untuk mempertahankannya “demi berjaga-jaga”. Karena itu, Keamanan Ketahanan Siber harus memasukkan *sunset clause*.

Sunset clause berarti status dan kewenangan khusus berakhir secara otomatis setelah jangka waktu tertentu, kecuali diperpanjang melalui evaluasi dan keputusan baru yang sah. Perpanjangan tidak boleh hanya menyalin alasan lama. Pemerintah harus menunjukkan bahwa indikator masih terpenuhi, tindakan masih diperlukan, dan manfaatnya lebih besar daripada risikonya.

Jangka waktu sebaiknya berbeda menurut tingkat dan dampak. Kondisi Eskalasi dapat dievaluasi secara rutin oleh koordinator teknis. Kondisi Tegang memerlukan evaluasi lebih sering oleh pimpinan lintas lembaga. Kondisi Darurat harus mempunyai pengawasan paling ketat, evaluasi berkala, dan pelaporan kepada Presiden serta DPR sesuai fungsi konstitusionalnya.

Angka durasi yang tepat perlu ditentukan melalui pembahasan hukum dan simulasi kebijakan. Undang-undang sebaiknya menetapkan prinsip serta batas maksimum, sedangkan rincian interval operasional dapat ditempatkan dalam peraturan pelaksanaan.

Pengakhiran status tidak berarti seluruh pekerjaan selesai. Setelah situasi terkendali, negara memasuki fase pemulihan dan pembelajaran. Fase ini mencakup:

- Pemulihan fungsi menuju tingkat layanan yang dapat diterima.
- Validasi integritas sistem serta data.
- Pengembalian kewenangan kepada struktur normal.
- Penghentian akses dan tindakan sementara.
- Rekonsiliasi keputusan dan penggunaan sumber daya.
- Pemberitahuan kepada pihak terdampak.
- Audit teknis, hukum, anggaran, dan tata kelola.
- Analisis akar penyebab.
- Evaluasi kinerja pimpinan serta koordinasi.
- Perbaikan standar, arsitektur, dan kebijakan.
- Publikasi laporan yang aman bagi keamanan nasional.

NIST SP 800-61 Revision 3 menekankan bahwa pembelajaran dan perbaikan harus berlangsung sepanjang siklus manajemen risiko, bukan hanya menunggu akhir pemulihan. Pelajaran dari insiden harus segera diteruskan ketika sudah cukup valid agar organisasi lain dapat melindungi diri.

Setiap status juga membutuhkan kriteria keluar. Misalnya:

- Penyebaran ancaman telah dihentikan.
- Fungsi kritikal telah pulih pada tingkat minimum yang aman.
- Kapasitas cadangan kembali tersedia.
- Risiko terhadap keselamatan telah terkendali.
- Koordinasi luar biasa tidak lagi diperlukan.
- Penyelenggara dan regulator sektor telah mampu melanjutkan penanganan.
- Kewenangan khusus tidak lagi memenuhi prinsip kebutuhan dan proporsionalitas.

Penurunan status dapat dilakukan bertahap dari Darurat ke Tegang, dari Tegang ke Eskalasi, dan kemudian kembali ke Normal. Namun, jika indikator telah pulih secara nyata, proses tidak perlu diperlambat hanya demi formalitas.

> **Setiap pintu masuk menuju kewenangan darurat harus dibangun bersama pintu keluarnya.**

3.8 Keputusan Strategis Bab 3

Keamanan Ketahanan Siber perlu menetapkan protokol eskalasi nasional yang mempunyai kekuatan hukum, tetapi cukup lentur untuk mengikuti perkembangan ancaman.

> Keputusan pertama adalah menetapkan empat tingkat kondisi: **Normal, Eskalasi, Tegang, dan Darurat**. Nama tingkat dapat dipertajam melalui pembahasan hukum, tetapi setiap tingkat harus mempunyai makna dan konsekuensi berbeda.
>
> Keputusan kedua adalah **membedakan peristiwa**, ancaman, insiden, insiden besar, dan krisis nasional. Tanpa definisi yang jelas, setiap gangguan dapat dibesar-besarkan atau setiap krisis dapat diperkecil.
>
> Keputusan ketiga adalah **menggunakan penilaian multidimensi**. Status tidak ditentukan hanya dari jumlah serangan, nilai kerugian, atribusi pelaku, atau viralitas pemberitaan.
>
> Keputusan keempat adalah **menetapkan pejabat yang berwenang** pada setiap tingkat. BSSN dapat memimpin peningkatan kesiapan teknis, sedangkan status yang membawa konsekuensi politik dan kewenangan nasional harus ditetapkan oleh Presiden atau pejabat yang memperoleh delegasi terbatas dan eksplisit.
>
> Keputusan kelima adalah **membatasi kewenangan sesuai tingkat.** Kenaikan status harus menambah koordinasi serta sumber daya secara proporsional, bukan otomatis membuka semua kewenangan.
>
> Keputusan keenam adalah **membedakan darurat siber operasional** dari keadaan darurat konstitusional. Status teknis tidak boleh digunakan untuk menghindari prosedur hukum yang berlaku.
>
> Keputusan ketujuh adalah **mewajibkan *sunset clause*,** evaluasi berkala, alasan tertulis, jejak audit, pengawasan, serta kriteria penurunan dan pengakhiran.
>
> Keputusan kedelapan adalah **mewajibkan pembelajaran pasca krisis.** Setiap krisis harus menghasilkan perbaikan standar, arsitektur, kapasitas, regulasi, latihan, serta mekanisme koordinasi.

Detail indikator numerik, format laporan, interval *situation report*, komposisi pusat krisis, dan prosedur operasional dapat ditetapkan melalui peraturan pelaksanaan. Namun, **tingkat kondisi, dasar aktivasi, jenis kewenangan, pejabat penetap, batas waktu, mekanisme pengawasan, dan hubungan dengan hak warga harus berada dalam undang-undang.**

Indonesia tidak membutuhkan status darurat yang mudah diumumkan. Indonesia membutuhkan negara yang mampu melihat ancaman lebih awal, meningkatkan kesiapan secara bertahap, mengambil keputusan tepat waktu, membatasi kekuasaan, memulihkan layanan, dan kembali ke keadaan normal.

> **Tujuan tangga krisis bukan membawa negara menuju Darurat. Tujuannya adalah menghentikan ancaman pada tingkat serendah mungkin.**

RANGKUMAN BAB 3

Bagian	Fokus utama	Indikator atau tindakan kunci	Kepemimpinan dan keputusan
3.1 Kelemahan model biner	Jarak antara insiden rutin dan krisis nasional terlalu lebar	Bedakan peristiwa, ancaman, insiden, insiden besar, dan krisis	Gunakan tangga respons berbasis risiko
3.2 Normal	Kesiapan dan pencegahan	Inventaris, pemetaan dependensi, latihan, pengujian pemulihan, dan pertukaran informasi	Penyelenggara dan regulator memimpin; BSSN mengoordinasikan kesiapan teknis
3.3 Eskalasi	Mencegah ancaman berkembang menjadi krisis	Peningkatan serangan, eksploitasi aktif, kampanye terkoordinasi, atau insiden lintas organisasi	Kepala BSSN atau otoritas sektor menaikkan kesiapan sesuai ruang lingkup
3.4 Tegang	Konsolidasi respons lintas sektor	Beberapa fungsi kritikal terganggu, penyebaran cepat, atau kapasitas rutin mulai terlampaui	Presiden atau pejabat yang mendapat delegasi terbatas mengaktifkan koordinasi krisis
3.5 Darurat	Menyelamatkan fungsi nasional	Ancaman serius terhadap keselamatan, pemerintahan, ekonomi, pertahanan, atau layanan esensial	Presiden memegang keputusan politik tertinggi; komando teknis dan sektoral tetap dibedakan
3.6 Indikator dan ambang	Objektivitas keputusan	Dampak, fungsi, sektor, wilayah, durasi, kapasitas, keselamatan, ancaman, dan kualitas bukti	Setiap penetapan wajib tertulis, terbatas, dan dapat diaudit
3.7 Batas waktu	Mencegah status tanpa akhir	Sunset clause, evaluasi, kriteria keluar, pemulihan, audit, dan pembelajaran	Status berakhir otomatis jika tidak diperpanjang secara sah
3.8 Keputusan strategis	Membentuk tangga krisis yang sah dan terukur	Setiap tingkat memiliki indikator, kewenangan, pemimpin, durasi, komunikasi, dan syarat keluar	**Norma pokok ditempatkan dalam undang-undang; rincian teknis dalam peraturan pelaksanaan**

REFERENSI UTAMA BAB 3

Badan Pemeriksa Keuangan Republik Indonesia. Peraturan Presiden Nomor 47 Tahun 2023 tentang Strategi Keamanan Siber Nasional dan Manajemen Krisis Siber. https://peraturan.bpk.go.id/Details/255542/perpres-no-47-tahun-2023

National Institute of Standards and Technology. *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. NIST SP 800-61 Revision 3, April 2025. https://csrc.nist.gov/pubs/sp/800/61/r3/final

Purbo, Onno W. *Strategic Blueprint: AI Integration in the Corporate SOC—A CISO's Roadmap for Cognitive Cyber Defense, Digital Sovereignty, and Business Resilience*. 2026.

Purbo, Onno W. *Strategi R&D IT Mandiri untuk Kedaulatan Teknologi Republik*. 2025.

BAB 4 - REGULASI BERBASIS RISIKO: AMAN TANPA MEMATIKAN INOVASI

Tujuan bab: membentuk kewajiban keamanan yang tegas, proporsional, dapat dilaksanakan, dan tidak mengubah regulasi menjadi hambatan masuk bagi inovator domestik.

Keamanan siber tidak lahir dari banyaknya formulir kepatuhan. Keamanan lahir ketika risiko dikenali, keputusan dapat dipertanggungjawabkan, kerentanan segera diperbaiki, dan layanan mampu pulih setelah serangan.

Indonesia membutuhkan regulasi yang membedakan antara perusahaan rintisan dengan seribu pengguna dan penyelenggara layanan nasional yang menopang puluhan juta warga. Keduanya tetap wajib aman, tetapi **tingkat kewajiban, kedalaman pembuktian, frekuensi audit, dan berat sanksinya tidak boleh disamakan**.

Prinsip yang perlu digunakan sederhana: **risiko yang sama harus menerima kewajiban yang setara; risiko yang lebih tinggi harus menerima pengawasan yang lebih kuat; risiko yang rendah harus memperoleh jalur kepatuhan yang lebih sederhana**.

Pendekatan ini bukan pelonggaran keamanan. Sebaliknya, inilah cara agar tenaga pengawas, anggaran negara, dan kemampuan industri yang terbatas diarahkan kepada risiko yang benar-benar dapat melumpuhkan pelayanan publik, merugikan masyarakat, dan mengancam kedaulatan negara.

4.1 DARI KEWAJIBAN SERAGAM MENUJU KEWAJIBAN PROPORSIONAL

Regulasi seragam terlihat tegas di atas kertas, tetapi sering tidak efektif dalam pelaksanaan. Jika kewajiban yang sama diberlakukan kepada bank nasional, rumah sakit daerah, pengembang aplikasi kecil, penyedia komputasi awan, dan toko daring keluarga, hasilnya bukan keamanan yang merata. Pelaku besar dapat menjadikan kepatuhan sebagai kegiatan administratif, sementara pelaku kecil menghabiskan sumber daya untuk memenuhi dokumen tanpa benar-benar mengurangi risiko.

> **Kesetaraan tidak berarti semua organisasi menerima beban yang sama. Kesetaraan berarti organisasi dengan risiko yang sebanding diperlakukan secara sebanding.**

Keamanan Ketahanan Siber perlu memerintahkan penggunaan klasifikasi risiko berdasarkan sekurang-kurangnya enam unsur:

1. Kekritisan fungsi atau layanan yang diselenggarakan.
2. Besarnya dampak apabila layanan terganggu.
3. Jenis dan sensitivitas data yang diproses.
4. Jumlah pengguna atau masyarakat yang terdampak.
5. Ketergantungan sektor lain terhadap layanan tersebut.
6. Kemampuan organisasi mengendalikan risiko dan memulihkan layanan.

Ukuran organisasi tetap relevan, tetapi tidak boleh menjadi satu-satunya ukuran. Perusahaan kecil dapat menjadi pemasok tunggal komponen, pengelola identitas digital, pengembang perangkat lunak penting, atau pintu masuk ke jaringan lembaga besar. Dalam keadaan tersebut, skala ekonominya kecil, tetapi risiko sistemiknya tinggi.

Sebaliknya, tidak setiap perusahaan besar otomatis harus menerima kewajiban paling berat. Penilaian harus melihat fungsi, paparan, dependensi, dan akibat kegagalan. Pendekatan ini sejalan dengan *risk-based governance* dalam referensi Onno W. Purbo mengenai kepatuhan perlindungan data: sumber daya yang terbatas harus dipusatkan pada aset dan proses yang paling kritis, bukan dibagikan secara mekanis kepada semua objek.

Model yang disarankan adalah kewajiban berjenjang:

- **Tingkat dasar** berlaku bagi semua penyelenggara dan penyedia produk digital.
- **Tingkat menengah** berlaku bagi organisasi dengan pengguna, data, atau ketergantungan operasional yang signifikan.
- **Tingkat tinggi** berlaku bagi penyelenggara Infrastruktur Informasi Kritikal, pemasok strategis, dan produk yang kegagalannya dapat menimbulkan dampak sistemik.
- **Tingkat khusus** berlaku pada keadaan tertentu, misalnya teknologi yang digunakan dalam pertahanan, identitas nasional, kendali industri, kesehatan berisiko tinggi, atau fungsi pemerintahan yang tidak boleh berhenti.

Uni Eropa melalui NIS2 juga menggunakan cakupan sektoral dan tingkat kepentingan entitas untuk menerapkan manajemen risiko, pelaporan insiden, pengawasan, serta akuntabilitas pimpinan. Pengalaman tersebut menunjukkan bahwa memperluas regulasi harus diikuti kejelasan ruang lingkup dan penyederhanaan kepatuhan, khususnya bagi perusahaan mikro dan kecil. European Commission—NIS2 Directive

Keamanan Ketahanan Siber harus mengatur parameter dan akibat hukum setiap tingkat risiko dalam batang tubuh undang-undang. Rumus penilaian, indikator teknis, dan metode evaluasinya dapat diperbarui melalui peraturan pelaksanaan. Dengan demikian, kepastian hukum tidak dikorbankan, tetapi regulasi tetap dapat mengikuti perubahan teknologi.

4.2 BASELINE KEAMANAN NASIONAL

Proporsionalitas tidak boleh menjadi alasan untuk meniadakan kewajiban dasar. Setiap organisasi yang menghadirkan produk atau layanan digital kepada masyarakat harus memenuhi *baseline* keamanan nasional.

Baseline tersebut sebaiknya dirumuskan sebagai hasil yang wajib dicapai, bukan perintah membeli perangkat, merek, atau layanan tertentu. Regulasi harus menentukan “apa yang harus terlindungi”, sedangkan organisasi diberi ruang menentukan “bagaimana cara melindunginya” sesuai skala, teknologi, dan profil risikonya.

Fondasi minimum keamanan nasional perlu mencakup:

1. Tata kelola dan penanggung jawab risiko siber yang jelas.
2. Inventarisasi aset, sistem, layanan, data, dan ketergantungan utama.
3. Pengendalian identitas serta hak akses berdasarkan kebutuhan.
4. Konfigurasi aman dan pengurangan layanan yang tidak diperlukan.
5. Pengelolaan kerentanan, pembaruan, dan perbaikan keamanan.
6. Pencadangan serta kemampuan pemulihan yang teruji.
7. Pencatatan aktivitas, pemantauan, dan penyimpanan bukti yang proporsional.
8. Rencana penanganan insiden, komunikasi krisis, dan kesinambungan layanan.

NIST Cybersecurity Framework 2.0 menempatkan tata kelola bersama fungsi identifikasi, perlindungan, deteksi, respons, dan pemulihan sebagai hasil inti pengelolaan risiko. Kerangka tersebut dapat digunakan oleh pemerintah maupun industri tanpa mengunci organisasi kepada satu produk atau teknologi tertentu. NIST Cybersecurity Framework 2.0

Dalam konteks Indonesia, *baseline* Keamanan Ketahanan Siber harus diharmonisasikan dengan kewajiban yang telah ada dalam UU Pelindungan Data Pribadi, UU Informasi dan Transaksi Elektronik, Peraturan Pemerintah Nomor 71 Tahun 2019, serta regulasi sektoral. UU PDP telah mengatur kewajiban pengendali dan prosesor dalam seluruh rangkaian pemrosesan data pribadi. Keamanan Ketahanan Siber tidak seharusnya menciptakan istilah, saluran, atau bukti kepatuhan baru yang bertentangan dengan kerangka tersebut. UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi PP Nomor 71 Tahun 2019

Organisasi berisiko rendah dapat membuktikan kepatuhan melalui penilaian mandiri yang terstruktur. Organisasi berisiko menengah dapat diwajibkan menyerahkan pernyataan kepatuhan dan bukti pengujian berkala. Organisasi berisiko tinggi harus tunduk pada audit independen, pengujian ketahanan, pelaporan kepada pimpinan, dan pengawasan regulator.

> **Yang harus dinilai bukan banyaknya sertifikat, melainkan kemampuan organisasi mencegah, mendeteksi, merespons, dan memulihkan diri.**

4.3 SECURE BY DESIGN DAN SECURE BY DEFAULT

Selama ini biaya ketidakamanan terlalu sering dipindahkan kepada pengguna. Produk dijual dengan konfigurasi lemah, layanan yang tidak diperlukan aktif secara otomatis, pembaruan sulit dilakukan, dan kerentanan baru diperbaiki setelah terjadi korban. Model seperti ini memberi keuntungan kepada produsen, tetapi masyarakat dan negara menanggung kerugiannya.

Prinsip *secure by design* berarti keamanan dipertimbangkan sejak perumusan kebutuhan, perancangan arsitektur, pemilihan komponen, pengembangan, pengujian, distribusi, pengoperasian, sampai penghentian produk.

Prinsip *secure by default* berarti pengguna memperoleh konfigurasi yang paling aman secara wajar sejak awal, tanpa harus membeli fitur tambahan atau memiliki pengetahuan teknis khusus.

Konsekuensi kebijakannya jelas:

- Fitur yang tidak diperlukan seharusnya tidak aktif secara otomatis.
- Hak akses awal harus dibatasi berdasarkan prinsip kebutuhan minimum.
- Produk tidak boleh bergantung pada kata sandi bawaan yang sama untuk seluruh pengguna.
- Pengumpulan data harus dibatasi pada data yang benar-benar diperlukan.
- Pembaruan keamanan harus dapat diterapkan secara aman dan dapat diverifikasi.
- Perubahan penting pada konfigurasi, model risiko, dan mekanisme pemrosesan data harus diberitahukan secara layak kepada pengguna.
- Fitur keamanan mendasar tidak boleh diperlakukan sebagai fasilitas premium.

NIST Secure Software Development Framework menegaskan bahwa praktik pengembangan aman perlu diintegrasikan ke dalam setiap model siklus pengembangan perangkat lunak. Tujuannya adalah mengurangi kerentanan pada produk yang dirilis, membatasi dampak kerentanan yang belum ditemukan, dan mengatasi akar penyebab agar kesalahan yang sama tidak terus berulang. Kerangka itu juga menyediakan bahasa bersama yang dapat digunakan pembeli dalam proses pengadaan. NIST SP 800-218—Secure Software Development Framework

Keamanan Ketahanan Siber tidak perlu menetapkan satu metode pengembangan yang kaku. Undang-undang cukup menetapkan kewajiban hasil, antara lain penilaian risiko produk, pengendalian perubahan, pengujian yang sesuai tingkat risiko, dokumentasi keamanan, dan kemampuan memperbaiki kerentanan.

Produk yang berulang kali gagal karena kelalaian desain tidak boleh diperlakukan sama dengan produk yang telah dibangun secara bertanggung jawab tetapi menghadapi ancaman yang benar-benar baru. Perbedaan ini penting agar penegakan hukum menghukum kelalaian, bukan menghukum inovasi.

4.4 TANGGUNG JAWAB SEPANJANG SIKLUS HIDUP PRODUK

Produk digital tidak berhenti menjadi tanggung jawab penyedia setelah transaksi selesai. Perangkat yang masih digunakan masyarakat dapat menjadi pintu masuk serangan bertahun-tahun setelah dijual. Karena itu, tanggung jawab penyedia harus berlangsung sepanjang masa dukungan yang dijanjikan.

Sebelum produk dipasarkan, penyedia perlu menyampaikan secara jelas:

- Jangka waktu dukungan keamanan.
- Jenis pembaruan yang akan diberikan.
- Kanal penerimaan laporan kerentanan.
- Komponen atau layanan penting yang menjadi dependensi produk.
- Persyaratan operasional agar produk tetap aman.
- Prosedur ketika produk memasuki akhir masa dukungan.

Selama masa dukungan, penyedia wajib menerima laporan kerentanan, melakukan penilaian, menyediakan perbaikan berdasarkan tingkat keparahan, serta memberi informasi yang memadai kepada pengguna. Pembaruan keamanan mendasar dalam masa dukungan seharusnya tidak dikenakan biaya tambahan yang membuat pengguna memilih tetap rentan.

Negara juga perlu melindungi peneliti keamanan yang melaporkan kerentanan dengan itikad baik, mengikuti batas pengujian yang wajar, tidak memeras penyedia, dan tidak menyalahgunakan data yang ditemukan. Tanpa saluran pengungkapan kerentanan yang aman, peneliti justru terdorong diam, sementara kelemahan tetap dapat dimanfaatkan pihak yang berniat jahat.

Ketika dukungan berakhir, penyedia wajib memberikan pemberitahuan yang cukup, menjelaskan risiko, menyediakan jalur migrasi, dan memungkinkan pengguna mengambil data dalam format yang dapat digunakan. Untuk produk berisiko tinggi, penghentian dukungan secara mendadak harus dilarang kecuali terdapat keadaan yang benar-benar tidak dapat dihindari dan tersedia rencana mitigasi.

Cyber Resilience Act Uni Eropa memberikan contoh pendekatan yang menempatkan kewajiban keamanan pada seluruh rantai nilai produk digital, dari perencanaan, desain, pengembangan, sampai pemeliharaan dan penanganan kerentanan sepanjang siklus hidup. Kewajiban utamanya mulai berlaku pada 11 Desember 2027, sementara kewajiban pelaporan mulai berlaku pada 11 September 2026. Contoh ini perlu dipelajari sebagai arah kebijakan, bukan disalin tanpa penyesuaian terhadap kapasitas Indonesia. European Commission—Cyber Resilience Act

> **Tidak boleh ada produk kritikal tanpa masa dukungan yang dinyatakan, tidak boleh ada kerentanan tanpa saluran pelaporan, dan tidak boleh ada akhir dukungan tanpa jalan keluar bagi pengguna.**

4.5 KEWAJIBAN PENYEDIA ASING

Pasar digital Indonesia tidak hanya dilayani perusahaan yang memiliki kantor, pusat data, atau badan hukum di Indonesia. Banyak produk dan layanan strategis dioperasikan dari luar negeri. Apabila kewajiban hanya dapat diterapkan kepada perusahaan domestik, regulasi akan menghasilkan ketidakadilan: inovator Indonesia menanggung biaya kepatuhan, sedangkan penyedia asing menikmati pasar tanpa tanggung jawab yang sebanding.

> **Akses kepada pasar Indonesia harus diikuti tanggung jawab terhadap risiko yang ditimbulkan di Indonesia.**

Keamanan Ketahanan Siber perlu menerapkan kewajiban berdasarkan keterhubungan nyata dengan Indonesia, misalnya ketika penyedia secara sengaja menawarkan layanan kepada pengguna Indonesia, memproses data dalam skala signifikan, memasok sistem kritikal, atau produknya dapat menimbulkan dampak serius terhadap masyarakat dan negara.

Penyedia asing dalam kategori risiko tertentu harus diwajibkan:

1. Menunjuk perwakilan atau titik kontak yang dapat dimintai pertanggungjawaban.
2. Menyediakan jalur komunikasi insiden yang aktif dan dapat diuji.
3. Menyampaikan bukti pemenuhan standar keamanan yang berlaku.
4. Menangani kerentanan dan menyediakan pembaruan selama masa dukungan.
5. Memenuhi perintah hukum yang sah melalui prosedur yang transparan.
6. Menjaga bukti teknis yang diperlukan untuk penyelidikan tanpa melakukan pengumpulan data secara berlebihan.
7. Menyediakan mekanisme pemulihan, portabilitas, dan penghentian layanan yang tertib.
8. Menghormati ketentuan pelindungan data serta regulasi sektoral Indonesia.

Perwakilan lokal tidak boleh menjadi kotak surat administratif semata. Perwakilan tersebut harus mempunyai akses kepada pengambil keputusan dan fungsi teknis penyedia. Namun Indonesia juga tidak perlu mewajibkan pendirian infrastruktur lokal untuk setiap layanan tanpa penilaian risiko. **Lokalisasi yang tidak selektif dapat menaikkan biaya tanpa otomatis meningkatkan keamanan.**

Penegakan dapat dilakukan melalui kombinasi pendaftaran berbasis risiko, persyaratan perizinan sektoral, ketentuan pengadaan pemerintah, perintah perbaikan, denda administratif, pembatasan produk, dan penghentian akses sebagai tindakan terakhir. Langkah tersebut harus dapat diuji, proporsional, dan menyediakan hak keberatan.

Tujuannya bukan mengusir teknologi asing. Tujuannya adalah memastikan bahwa **kedaulatan pasar Indonesia disertai kemampuan menuntut tanggung jawab**.

4.6 PERLINDUNGAN INOVASI, STARTUP, DAN UMKM

Startup dan UMKM bukan kelompok yang harus dibebaskan dari keamanan. Mereka adalah kelompok yang harus dibantu mencapai keamanan melalui jalur yang masuk akal.

Jika kepatuhan memerlukan konsultan mahal, audit berlapis, dan dokumen yang hanya dapat disusun perusahaan besar, regulasi akan berubah menjadi penghalang masuk. Perusahaan mapan memperoleh perlindungan dari kompetisi, sementara inovator domestik kehilangan ruang tumbuh.

Keamanan Ketahanan Siber perlu memerintahkan penyediaan jalur kepatuhan sederhana, antara lain profil *baseline* berdasarkan jenis usaha, templat penilaian risiko, standar kontrak minimum, layanan konsultasi bersama, pusat pengujian yang terjangkau, dan masa transisi yang terukur.

Negara dapat menggunakan insentif berupa:

- Bantuan peningkatan keamanan bagi pelaku domestik.
- Voucher pengujian atau sertifikasi.
- Insentif fiskal untuk penelitian dan pengembangan keamanan.
- Infrastruktur pengujian bersama.
- Pendampingan melalui perguruan tinggi, komunitas, dan asosiasi industri.
- Akses kepada perangkat terbuka dan standar yang dapat digunakan tanpa ketergantungan pada satu vendor.

Regulatory sandbox dapat digunakan untuk teknologi baru yang model risiko dan cara pengawasannya belum matang. Namun *sandbox* bukan zona bebas hukum. Di dalamnya tetap harus terdapat batas pengguna, durasi, pengawasan, perlindungan data, mekanisme penghentian, serta pertanggungjawaban apabila timbul kerugian.

Masa transisi juga harus dibedakan berdasarkan risiko. Organisasi berisiko rendah dapat menerima waktu lebih panjang dan pendampingan. Operator berisiko tinggi harus memenuhi kewajiban inti lebih cepat. Pelaku kecil yang menjadi pemasok kritikal tidak boleh diabaikan, tetapi negara dan operator utama perlu ikut membiayai peningkatan keamanannya.

Referensi Onno W. Purbo mengenai pendekatan sumber terbuka menekankan bahwa kontrol harus sesuai dengan skala organisasi: institusi kecil mungkin tidak memerlukan sistem yang sangat mahal, tetapi tetap membutuhkan akses yang terkendali, pencadangan yang terlindungi, dan kemampuan pemulihan. Prinsipnya adalah **bukti pengendalian risiko, bukan penyalinan templat kepatuhan**.

Kemandirian teknologi nasional tidak akan muncul hanya dengan mewajibkan penggunaan produk lokal. Kemandirian lahir ketika inovator Indonesia memperoleh akses kepada pengetahuan, standar, infrastruktur pengujian, pasar pemerintah, dan kesempatan memperbaiki produknya.

4.7 PENGADAAN PEMERINTAH SEBAGAI PENGUNGKIT KEAMANAN

Pemerintah adalah salah satu pembeli teknologi terbesar di Indonesia. Karena itu, pengadaan pemerintah dapat mengubah perilaku pasar lebih cepat daripada imbauan. Ketika pemerintah hanya mengejar harga terendah dan fitur terbanyak, pasar akan memasok produk murah dengan keamanan, dokumentasi, dan dukungan minimum.

> **Belanja negara harus membeli kendali, keberlanjutan, dan kemampuan berpindah—bukan sekadar lisensi.**

Persyaratan pengadaan teknologi pemerintah perlu mencakup:

1. Masa dukungan keamanan dan target waktu perbaikan.
2. Mekanisme penerimaan serta penanganan laporan kerentanan.
3. Hak audit yang proporsional terhadap risiko.
4. Pemberitahuan insiden dan dukungan investigasi.
5. Portabilitas data dalam format yang terdokumentasi.
6. Interoperabilitas dan antarmuka yang tidak dikunci secara sepihak.
7. Dokumentasi arsitektur, konfigurasi, dependensi, serta perubahan penting.
8. Transfer pengetahuan dan penguatan tenaga teknis Indonesia.
9. Rencana kesinambungan layanan apabila penyedia gagal atau berhenti beroperasi.
10. Strategi keluar yang dapat diuji sebelum kontrak berakhir.

Untuk produk dengan tingkat risiko tertentu, pemerintah dapat meminta transparansi komponen perangkat lunak, termasuk *software bill of materials* yang proporsional. Transparansi ini bukan tuntutan agar seluruh kode sumber dibuka, melainkan kemampuan mengetahui komponen penting, asalnya, versi yang digunakan, dan respons yang harus dilakukan ketika suatu komponen ditemukan rentan.

Penilaian tender tidak boleh hanya menghitung harga awal. Pemerintah harus memperhitungkan *total cost of ownership*, biaya migrasi, biaya pemulihan insiden, ketergantungan lisensi, kebutuhan peningkatan kapasitas, dan risiko penghentian dukungan.

Dalam referensi Onno W. Purbo mengenai strategi teknologi keamanan, *vendor lock-in* dikenali melalui format tertutup, biaya ekspor tinggi, antarmuka yang tidak portabel, aturan deteksi yang hanya dapat digunakan pada satu produk, perubahan layanan yang dikendalikan sepihak, serta kemampuan tenaga kerja yang terbatas pada satu vendor. Resiko terbesarnya adalah **hilangnya kemampuan bangsa menentukan arah teknologinya sendiri**.

Pilihan sumber terbuka dapat memperkuat auditabilitas, kemampuan modifikasi, dan kedaulatan operasi, tetapi tidak otomatis bebas risiko. Proyek sumber terbuka yang bergantung kepada satu pengembang, tidak dipelihara, atau tidak mempunyai dokumentasi juga dapat menjadi ketergantungan. Karena itu, negara perlu menilai keberlanjutan komunitas, kualitas pemeliharaan, kemampuan SDM nasional, dan hak nyata untuk mengoperasikan teknologi tersebut.

Kebijakan yang sehat bukan “semua harus produk asing” atau “semua harus sumber terbuka”. Kebijakan yang sehat adalah: **negara harus mampu mengaudit, mengoperasikan, memulihkan, memindahkan, dan mengembangkan teknologi strategis tanpa izin sepihak dari pihak lain**.

4.8 KEPUTUSAN STRATEGIS BAB 4

Keamanan Ketahanan Siber harus membangun regulasi berdasarkan risiko, bukan berdasarkan ketakutan terhadap teknologi. Keamanan yang terlalu longgar meninggalkan masyarakat dalam bahaya. Keamanan yang terlalu kaku mematikan inovasi, memperkuat pemain besar, dan memperdalam ketergantungan Indonesia.

Delapan keputusan strategis perlu ditegaskan.

Pertama, **batang tubuh undang-undang harus menetapkan prinsip proporsionalitas, parameter klasifikasi risiko, kewajiban dasar, tanggung jawab produk, dan hak pihak yang diawasi**. Materi mendasar tersebut tidak boleh seluruhnya diserahkan kepada peraturan pelaksanaan.

Kedua, seluruh penyelenggara dan penyedia produk digital harus **memenuhi *baseline* keamana**n. Tidak ada pengecualian total berdasarkan ukuran perusahaan, tetapi cara pembuktian dan kedalaman pengawasannya harus berjenjang.

Ketiga, produk digital harus dibangun berdasarkan ***secure by design* dan *secure by default***. Keamanan dasar tidak boleh menjadi fitur tambahan yang hanya tersedia bagi pembeli beranggaran besar.

Keempat, penyedia harus bertanggung jawab sepanjang masa dukungan produk, termasuk pembaruan keamanan, penerimaan laporan kerentanan, pemberitahuan akhir dukungan, dan jalur migrasi.

Kelima, **penyedia asing** yang memperoleh manfaat dari pasar Indonesia harus tunduk pada tanggung jawab yang dapat ditegakkan. Pelaku domestik dan asing dengan risiko yang sama harus menghadapi kewajiban yang setara.

Keenam, **startup dan UMKM harus memperoleh jalur kepatuhan sederhana**, pendampingan, insentif, masa transisi, dan infrastruktur pengujian bersama. Dukungan tersebut tidak menghapus kewajiban dasar.

Ketujuh, **pengadaan pemerintah harus digunakan untuk mendorong keamanan**, interoperabilitas, portabilitas, transfer pengetahuan, dan kemandirian teknologi nasional.

Kedelapan, regulator harus **mengukur keberhasilan** berdasarkan penurunan kerentanan, kecepatan perbaikan, ketahanan layanan, dan kemampuan pemulihan—bukan jumlah dokumen yang dikumpulkan.

Regulasi harus keras terhadap risiko besar, ringan dalam prosedur bagi risiko rendah, tetapi tidak pernah membiarkan keamanan dasar menjadi pilihan.

RANGKUMAN BAB 4

Bagian	Persoalan Utama	Arah Kebijakan	Keputusan bagi Negara
4.1 Kewajiban proporsional	Kewajiban seragam membebani pelaku kecil dan mengaburkan risiko besar	Klasifikasi berdasarkan fungsi, dampak, data, pengguna, dependensi, dan kemampuan pemulihan	Terapkan kewajiban berjenjang dengan parameter utama di dalam undang-undang
4.2 Baseline nasional	Kepatuhan administratif belum tentu menghasilkan keamanan	Tetapkan hasil minimum: tata kelola, akses, pembaruan, pencadangan, pencatatan, respons, dan pemulihan	Berlakukan fondasi keamanan bagi semua dengan pembuktian sesuai tingkat risiko
4.3 Secure by design/default	Biaya ketidakamanan dialihkan kepada pengguna dan negara	Masukkan keamanan sejak desain dan gunakan konfigurasi awal yang aman	Jadikan keamanan dasar bagian produk, bukan fitur premium
4.4 Siklus hidup produk	Produk tetap digunakan setelah dukungan berakhir dan kerentanan tidak tertangani	Wajibkan masa dukungan, pembaruan, pelaporan kerentanan, pemberitahuan akhir dukungan, dan migrasi	Pertahankan tanggung jawab penyedia sepanjang masa dukungan
4.5 Penyedia asing	Penyedia asing dapat menikmati pasar tanpa tanggung jawab efektif	Gunakan keterhubungan nyata dengan Indonesia sebagai dasar kewajiban	Samakan kewajiban berdasarkan risiko dan sediakan instrumen penegakan lintas batas
4.6 Startup dan UMKM	Biaya kepatuhan dapat menjadi hambatan masuk	Sediakan standar sederhana, bantuan, insentif, sandbox, dan masa transisi	Bantu pelaku kecil memenuhi keamanan tanpa memberi pengecualian total
4.7 Pengadaan pemerintah	Harga murah dapat menciptakan ketergantungan dan biaya jangka panjang	Prioritaskan auditabilitas, interoperabilitas, portabilitas, dukungan, pengetahuan, dan strategi keluar	Gunakan belanja negara untuk membangun pasar teknologi yang aman dan berdaulat
4.8 Keputusan strategis	Regulasi dapat terlalu lemah atau terlalu kaku	Bedakan berat kewajiban, bukan keberadaan kewajiban dasar	**Risiko tinggi diawasi ketat; risiko rendah diberi prosedur sederhana; semua wajib aman**

REFERENSI UTAMA BAB 4

- Onno W. Purbo, *Panduan Praktis Kepatuhan UU PDP untuk Executive dan Pengambil Keputusan*, 2025.
- Onno W. Purbo dan A. Ikhwanudin, *Panduan Praktis Kepatuhan UU PDP dan Keamanan Data Institusi: Open Source Approach*, 2025.
- Onno W. Purbo, *Strategic Blueprint: AI Integration in the Corporate SOC*, 2026.
- Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi.
- Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik.
- NIST, *Cybersecurity Framework 2.0*.
- NIST SP 800-218, *Secure Software Development Framework Version 1.1*.
- European Union, *Directive on Measures for a High Common Level of Cybersecurity—NIS2*.
- European Union, *Cyber Resilience Act*.

BAB 5 - SATU INSIDEN, SATU LAPORAN, SATU GAMBARAN NASIONAL

Tujuan bab: menghilangkan duplikasi pelaporan dan membangun gambaran situasi nasional tanpa mengorbankan kerahasiaan, privasi, atau reputasi korban.

Serangan siber bergerak dalam hitungan detik, sedangkan birokrasi pelaporan sering bergerak dalam hitungan hari. Ketika sebuah organisasi diserang, tenaga teknisnya seharusnya berkonsentrasi menghentikan penyebaran, melindungi masyarakat, mempertahankan bukti, dan memulihkan layanan. Kenyataannya, organisasi dapat dipaksa mengirim laporan yang hampir sama kepada beberapa lembaga melalui format, tenggat, dan saluran yang berbeda.

Keadaan tersebut tidak otomatis menghasilkan keamanan. Duplikasi justru menghabiskan waktu kritis, mendorong organisasi menyusun laporan secara tergesa-gesa, dan meningkatkan risiko kebocoran informasi sensitif.

Indonesia memerlukan prinsip sederhana: **satu insiden dilaporkan satu kali melalui satu saluran nasional, kemudian informasi yang relevan diteruskan secara sah kepada setiap otoritas yang berwenang**.

Kesatuan saluran tidak berarti pemusatan seluruh kewenangan. BSSN, lembaga pelindungan data pribadi, regulator sektor, Polri, dan otoritas lainnya tetap menjalankan mandat masing-masing. Yang disatukan adalah pintu masuk, identitas insiden, format data inti, dan gambaran situasi nasional.

> **Negara tidak memerlukan lima laporan tentang satu kejadian. Negara memerlukan satu laporan yang dapat dipercaya, diperbarui, dilindungi, dan ditindaklanjuti bersama.**

5.1 MASALAH PELAPORAN YANG TERFRAGMENTASI

Satu insiden dapat mempunyai beberapa dimensi sekaligus. Serangan terhadap rumah sakit, misalnya, dapat mengganggu pelayanan kesehatan, membuka data pribadi pasien, melibatkan pemerasan, mempengaruhi Infrastruktur Informasi Kritikal, dan membutuhkan penyelidikan pidana.

Satu kejadian tersebut dapat bersentuhan dengan BSSN, lembaga pelindungan data pribadi, kementerian kesehatan, aparat penegak hukum, pemerintah daerah, serta kewajiban komunikasi kepada masyarakat. Setiap lembaga memiliki kepentingan yang sah, tetapi kepentingan tersebut tidak seharusnya menghasilkan permintaan berulang kepada korban.

Fragmentasi pelaporan menimbulkan sedikitnya tujuh masalah.

Pertama, **definisi insiden berbeda antara regulasi**. Gangguan operasional, kompromi keamanan, kegagalan pelindungan data pribadi, dan tindak pidana siber dapat menggunakan terminologi yang tidak sama.

Kedua, **titik awal perhitungan tenggat dapat berbeda**. Ada kewajiban yang dihitung sejak insiden terjadi, sejak terdeteksi, sejak diketahui, atau sejak dikonfirmasi.

Ketiga, **organisasi harus mengisi format yang berbeda** meskipun sumber informasinya sama.

Keempat, **informasi awal dapat menjadi tidak konsisten** karena masing-masing laporan disusun oleh unit organisasi yang berbeda.

Kelima, **terlalu banyak penerima memperbesar resiko tersebarnya data pribadi**, bukti investigasi, konfigurasi sistem, dan kelemahan keamanan.

Keenam, **organisasi dapat menunda laporan karena takut** bahwa laporan awal yang belum sempurna akan dianggap sebagai pengakuan kesalahan.

Ketujuh, **negara tetap gagal memperoleh gambaran nasional** karena data tersimpan dalam sistem kelembagaan yang tidak saling terhubung.

Fragmentasi pelaporan menghasilkan banyak dokumen, tetapi belum tentu menghasilkan pengetahuan nasional.

Keamanan Ketahanan Siber harus mengubah orientasi dari pelaporan berbasis lembaga menjadi pelaporan berbasis insiden. Setiap kejadian memperoleh satu identitas insiden nasional. Laporan berikutnya, permintaan tambahan, perkembangan investigasi, dan keputusan penutupan harus merujuk kepada identitas yang sama.

Bagi penyelenggara, prinsipnya adalah *report once*. Bagi pemerintah, prinsipnya adalah *use many times with lawful access*. Informasi tidak boleh diminta ulang apabila telah tersedia dan dapat diakses secara sah melalui sistem nasional.

Namun, saluran tunggal bukan berarti semua lembaga dapat melihat seluruh isi laporan. **Akses harus dibatasi berdasarkan kewenangan, tujuan, kebutuhan, dan sensitivitas informasi.** Regulator kesehatan mungkin memerlukan informasi kesinambungan layanan, lembaga PDP memerlukan informasi mengenai data pribadi, sedangkan aparat penegak hukum memerlukan bukti yang relevan dengan dugaan tindak pidana. Tidak semuanya membutuhkan salinan penuh data teknis.

5.2 DEFINISI INSIDEN YANG WAJIB DILAPORKAN

Tidak setiap *event* merupakan insiden. Tidak setiap *alert* merupakan bukti serangan. Tidak setiap insiden perlu dilaporkan kepada negara.

Referensi Onno W. Purbo tentang pembangunan *Security Operations Center* membedakan empat lapisan penting:

- *Event* adalah kejadian yang tercatat.
- *Alert* adalah sinyal yang dianggap penting oleh aturan deteksi atau sistem pemantauan.
- Insiden adalah kejadian keamanan yang telah divalidasi, memiliki dampak atau potensi dampak, dan membutuhkan respons.
- *Case* adalah wadah untuk mengelola bukti, analisis, tindakan, penanggung jawab, dan keputusan akhir.

Perbedaan tersebut penting secara hukum. Jika setiap *alert* wajib dilaporkan, regulator akan tenggelam dalam informasi yang tidak relevan. Penyelenggara juga terdorong mengirim laporan sebanyak mungkin untuk menghindari sanksi. Hasilnya adalah *over-reporting*: jumlah laporan naik, tetapi kemampuan negara melihat ancaman penting justru turun.

Sebaliknya, definisi yang terlalu sempit dapat membuat serangan terkoordinasi tidak terlihat sampai dampaknya meluas. Negara perlu menangkap insiden yang belum menimbulkan kerusakan besar tetapi mempunyai potensi material, khususnya jika menyasar fungsi kritikal, menggunakan teknik baru, atau terjadi secara serentak pada beberapa organisasi.

Keamanan Ketahanan Siber sebaiknya mendefinisikan insiden wajib lapor sebagai:

> **Kejadian yang mengganggu atau berpotensi secara material mengganggu kerahasiaan, keutuhan, ketersediaan, keaslian, atau ketahanan sistem elektronik, data, produk digital, atau layanan penting; serta memenuhi ambang batas yang ditentukan berdasarkan dampak dan risiko penyebarannya.**

Definisi tersebut harus membedakan:

1. Insiden operasional biasa yang dapat ditangani secara internal.
2. Insiden keamanan yang wajib dicatat tetapi belum wajib dilaporkan.
3. Insiden material yang wajib dilaporkan kepada saluran nasional.
4. Insiden kritikal yang membutuhkan pelaporan segera dan koordinasi lintas sektor.
5. Kegagalan pelindungan data pribadi yang menimbulkan kewajiban khusus berdasarkan UU PDP.
6. Dugaan tindak pidana yang memerlukan proses penegakan hukum.

Kerentanan yang belum dieksploitasi tidak selalu menjadi insiden. *Alert* palsu juga bukan insiden. Namun kerentanan kritis yang telah dieksploitasi secara aktif, terdapat pada banyak layanan publik, atau berpotensi menyebabkan dampak sistemik dapat membutuhkan pemberitahuan khusus kepada otoritas teknis meskipun kerugian belum terlihat.

> **Undang-undang harus mencegah dua ekstrem: semua kejadian dilaporkan dan hanya bencana besar yang dilaporkan.**

5.3 AMBANG BATAS MATERIALITAS

Materialitas merupakan jembatan antara kejadian teknis dan kepentingan negara. Pertanyaannya bukan sekadar “apakah sistem diserang?”, tetapi “apakah kejadian ini cukup penting sehingga negara perlu mengetahui dan bertindak?”

Penilaian materialitas tidak boleh hanya berdasarkan besarnya kerugian finansial. Sistem kesehatan dapat mengalami kerugian finansial kecil tetapi mengancam keselamatan pasien. Gangguan pada penyedia identitas digital dapat berlangsung singkat tetapi berdampak kepada banyak sektor. Kebocoran data dalam jumlah kecil dapat tetap material apabila melibatkan data biometrik, kesehatan, anak, pertahanan, atau pejabat strategis.

Materialitas perlu dinilai berdasarkan kombinasi indikator berikut:

1. **Gangguan layanan:** apakah fungsi penting berhenti, melambat, atau kehilangan integritas.
2. **Durasi:** berapa lama gangguan berlangsung dan berapa lama pemulihan diperkirakan.
3. **Data terdampak:** jenis, sensitivitas, volume, dan kemungkinan penyalahgunaan data.
4. **Jumlah pihak terdampak:** pengguna, organisasi, wilayah, atau kelompok rentan.
5. **Kerugian:** dampak ekonomi langsung maupun tidak langsung.
6. **Keselamatan manusia:** risiko terhadap jiwa, kesehatan, atau keamanan fisik.
7. **Cakupan sektor:** apakah insiden melintasi organisasi atau sektor.
8. **Dampak geografis:** lokal, regional, nasional, atau lintas negara.
9. **Dampak kaskade:** kemungkinan gangguan menyebar melalui rantai pasokan atau dependensi digital.
10. **Karakter ancaman:** indikasi eksploitasi aktif, serangan terkoordinasi, sabotase, spionase, atau pemerasan.
11. **Kemampuan pemulihan:** apakah organisasi mampu memulihkan layanan menggunakan sumber dayanya sendiri.
12. **Kepentingan nasional:** kemungkinan dampak terhadap pemerintahan, ekonomi, pertahanan, demokrasi, atau ketertiban umum.

Tidak semua indikator harus terpenuhi. Satu indikator dengan dampak ekstrem dapat cukup untuk menjadikan insiden material. Sebaliknya, beberapa indikator tingkat rendah dapat menjadi material apabila muncul bersamaan.

Keamanan Ketahanan Siber harus menetapkan kategori indikator dalam undang-undang. Nilai kuantitatif, bobot, matriks penilaian, dan ambang sektoral dapat ditetapkan melalui peraturan pelaksanaan setelah konsultasi dengan regulator serta pelaku sektor.

Pendekatan sektoral tetap diperlukan. Satu jam gangguan dapat ditoleransi oleh layanan tertentu, tetapi tidak oleh sistem kendali penerbangan, fasilitas kesehatan intensif, layanan darurat, atau jaringan pembayaran nasional.

NIS2 Uni Eropa menggunakan konsep insiden signifikan, yaitu insiden yang dapat menimbulkan gangguan operasional atau kerugian yang berat serta mempengaruhi pihak lain. Pendekatan tersebut menunjukkan pentingnya menghubungkan kewajiban pelaporan dengan dampak, bukan dengan setiap gangguan teknis. European Commission, NIS2 Directive

> **Ambang materialitas harus cukup jelas untuk memberi kepastian, tetapi cukup dinamis untuk menangkap pola ancaman baru.**

5.4 PELAPORAN BERTAHAP

Salah satu kesalahan kebijakan yang sering terjadi adalah menuntut laporan lengkap ketika organisasi baru mengetahui bahwa sesuatu yang tidak normal sedang berlangsung. Pada jam-jam pertama, penyebab, pelaku, cakupan, dan dampak insiden biasanya belum dapat dipastikan.

Jika laporan awal harus sempurna, organisasi akan memilih menunggu. Padahal negara membutuhkan peringatan dini agar dapat melihat apakah insiden yang sama sedang terjadi di tempat lain.

Solusinya adalah pelaporan bertahap atau *progressive reporting*. Kelengkapan laporan meningkat sejalan dengan kematangan investigasi.

Tahap pertama adalah **peringatan awal**. Untuk insiden kritikal atau berpotensi menyebar, laporan awal dapat diwajibkan paling lambat 24 jam sejak organisasi memiliki keyakinan yang wajar bahwa ambang pelaporan telah terpenuhi.

Laporan awal cukup memuat:

- identitas penyelenggara;
- waktu deteksi;
- fungsi atau layanan terdampak;
- dugaan kategori insiden;
- dampak yang telah diketahui;
- potensi penyebaran;
- tindakan awal yang telah dilakukan;
- kebutuhan bantuan;
- titik kontak yang dapat dihubungi.

Tahap kedua adalah **laporan perkembangan**, misalnya paling lambat 72 jam. Laporan ini memperbarui tingkat keparahan, ruang lingkup, indikator teknis yang aman untuk dibagikan, data atau pengguna terdampak, tindakan pengendalian, serta perkiraan pemulihan.

Tahap ketiga adalah **laporan akhir**, misalnya paling lambat 30 hari setelah insiden terkendali atau dalam jangka waktu lain yang ditetapkan berdasarkan kompleksitas. Laporan akhir memuat akar masalah, dampak terverifikasi, kronologi, tindakan pemulihan, kelemahan tata kelola, dan rencana perbaikan.

Jika investigasi belum selesai, organisasi dapat menyerahkan laporan antara disertai alasan dan jadwal penyelesaian. Regulasi tidak boleh mendorong organisasi mengarang kepastian yang belum tersedia.

Skema waktu tersebut merupakan usulan desain kebijakan, bukan pernyataan bahwa seluruh tenggat itu telah berlaku dalam hukum Indonesia. Tenggat akhirnya harus diharmonisasikan dengan UU PDP dan regulasi sektoral.

Setiap laporan harus membedakan secara tegas antara:

> **Fakta terverifikasi**: telah didukung bukti.
>
> **Indikasi awal**: masuk akal tetapi masih diselidiki.
>
> **Asumsi kerja**: digunakan untuk menentukan tindakan sementara.
>
> **Informasi yang belum diketahui**: belum tersedia pada saat pelaporan.

Model tersebut mencegah spekulasi berubah menjadi fakta hukum. Pembaruan yang dibuat dengan iktikad baik tidak boleh dianggap sebagai bukti bahwa laporan awal palsu. Yang harus dikenai sanksi adalah penyembunyian, manipulasi bukti, keterlambatan tanpa alasan yang sah, atau pemberian informasi yang diketahui tidak benar.

NIST SP 800-61 Rev. 3 menempatkan respons insiden sebagai bagian dari manajemen risiko, bukan kegiatan yang berdiri sendiri. Integrasi tersebut membantu organisasi mempersiapkan respons, mengurangi jumlah dan dampak insiden, serta meningkatkan efektivitas deteksi, respons, dan pemulihan. NIST SP 800-61 Rev. 3

> **Cepat tidak harus lengkap. Lengkap tidak harus diberikan pada jam pertama. Yang penting adalah cepat, jujur, dapat diperbarui, dan dapat ditindaklanjuti.**

5.5 SALURAN PELAPORAN NASIONAL TERPADU

Saluran pelaporan nasional terpadu bukan sekadar portal formulir. Ia harus menjadi infrastruktur koordinasi yang menghubungkan penyelenggara, BSSN, lembaga PDP, regulator sektor, CSIRT, aparat penegak hukum, dan pengambil keputusan nasional.

Sistem tersebut sekurang-kurangnya harus mempunyai kemampuan berikut:

1. Memberikan satu nomor identitas nasional untuk setiap insiden.
2. Menerima laporan awal, perkembangan, dan laporan akhir.
3. Menentukan otoritas yang berhak menerima bagian tertentu dari laporan.
4. Menghindari permintaan data yang sama secara berulang.
5. Mencatat siapa yang mengakses, mengubah, atau meneruskan informasi.
6. Menyediakan kanal komunikasi dua arah antara pelapor dan otoritas.
7. Mengirim peringatan kepada sektor lain tanpa membuka identitas korban.
8. Mendukung klasifikasi informasi dan pembatasan akses.
9. Menyimpan bukti penyerahan serta waktu penerimaan laporan.
10. Menghasilkan gambaran situasi nasional yang telah dianonimkan atau diagregasi.

BSSN dapat berperan sebagai pengelola teknis dan koordinator pertukaran informasi siber. Namun, BSSN tidak otomatis mengambil alih kewenangan lembaga PDP, regulator sektoral, maupun aparat penegak hukum. **Satu saluran harus memperjelas kewenangan, bukan menghapus batas kewenangan.**

Arsitektur sistem sebaiknya bersifat federatif. Data inti dan status insiden dapat dikelola secara nasional, sementara data mentah, log lengkap, rekam medis, rahasia dagang, konfigurasi sistem, dan bukti sensitif tetap berada pada pemilik atau repositori sektoral yang berwenang.

Otoritas memperoleh akses berdasarkan kebutuhan. Jika analisis lebih lanjut membutuhkan data rinci, permintaan harus memiliki dasar hukum, tujuan, ruang lingkup, penanggung jawab, batas waktu penyimpanan, serta jejak audit.

Prinsip yang harus dijaga adalah **berbagi indikator ancaman tanpa membagikan data pribadi secara berlebihan**. Misalnya, negara dapat menyebarkan pola serangan, kerentanan yang dieksploitasi, ciri perangkat berbahaya, atau tindakan mitigasi tanpa mengumumkan nama korban dan arsitektur internalnya.

Gambaran nasional harus menjawab pertanyaan strategis:

- Sektor mana yang sedang diserang?
- Apakah terdapat pola yang sama pada beberapa organisasi?
- Apakah insiden berpotensi menjadi krisis lintas sektor?
- Fungsi nasional apa yang berisiko berhenti?
- Bantuan apa yang dibutuhkan?
  Keputusan apa yang harus diambil pemerintah?

Dashboard nasional bukan papan perlombaan jumlah serangan. Jumlah *alert* tidak selalu menunjukkan tingkat bahaya. Gambaran nasional harus menampilkan tingkat dampak, sektor terdampak, kecepatan penyebaran, kapasitas pemulihan, dan kebutuhan intervensi.

> **Negara membutuhkan gambaran ancaman, bukan gudang data mentah yang tidak terkendali.**

5.6 HARMONISASI DENGAN UU PDP DAN REGULASI SEKTORAL

Insiden keamanan siber dan kegagalan pelindungan data pribadi saling berhubungan, tetapi bukan hal yang identik.

Serangan *denial-of-service* dapat menghentikan layanan tanpa membocorkan data pribadi. Sebaliknya, kesalahan pengiriman dokumen dapat membuka data pribadi tanpa melibatkan serangan siber. Sebuah serangan *ransomware* dapat menyebabkan keduanya: layanan berhenti dan data pribadi terekspos.

Karena itu, Keamanan Ketahanan Siber tidak boleh mencampurkan dua rezim tersebut. Yang dibutuhkan adalah **pembedaan secara hukum dan penyatuan secara proses**.

Pasal 46 UU Nomor 27 Tahun 2022 mewajibkan pengendali data pribadi menyampaikan pemberitahuan tertulis paling lambat 3 x 24 jam kepada subjek data pribadi dan lembaga apabila terjadi kegagalan pelindungan data pribadi. Pemberitahuan sekurang-kurangnya memuat data pribadi yang terungkap, waktu dan cara terungkapnya data, serta upaya penanganan dan pemulihan. [UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi]

Kewajiban tersebut mempunyai tujuan berbeda dari laporan teknis kepada otoritas keamanan siber.

> Pemberitahuan kepada subjek data bertujuan memungkinkan warga melindungi dirinya.
>
> Pelaporan kepada lembaga PDP bertujuan memastikan kewajiban pengendali dan hak subjek data dipenuhi.
>
> Pelaporan siber kepada BSSN atau CSIRT bertujuan membantu penanganan teknis, mendeteksi pola lintas organisasi, dan mencegah penyebaran.
>
> Pelaporan kepada regulator sektoral bertujuan menjaga kesinambungan serta keselamatan layanan.
>
> Pelaporan kepada aparat penegak hukum bertujuan memproses dugaan tindak pidana berdasarkan hukum acara.

Kelima tujuan tersebut tidak boleh dipaksa menggunakan satu isi laporan yang identik. Namun semuanya dapat dimulai dari satu formulir inti dan satu identitas insiden.

Sistem nasional dapat menyediakan modul yang menyesuaikan informasi dengan kewajiban hukum terkait. Apabila laporan menunjukkan adanya kegagalan pelindungan data pribadi, sistem memberi peringatan mengenai tenggat UU PDP dan meneruskan bagian yang relevan kepada lembaga PDP. Jika terdapat gangguan sektoral, bagian operasional diteruskan kepada regulator terkait. Jika pelapor memilih atau diwajibkan membuat laporan pidana, bukti diteruskan melalui prosedur hukum yang sesuai.

Pengiriman melalui saluran nasional harus secara hukum dianggap telah memenuhi kewajiban penyampaian kepada otoritas yang terhubung, panjang data minimum dan tenggatnya terpenuhi. Tanpa pengakuan hukum tersebut, “saluran tunggal” hanya menjadi satu kewajiban tambahan.

Keamanan Ketahanan Siber juga harus mengatur urutan apabila tenggat berbeda. Tenggat yang paling cepat dapat dipenuhi melalui laporan awal. Informasi tambahan disampaikan melalui pembaruan tanpa membuka perkara baru.

Satu sistem, beberapa tujuan hukum, tanpa pelaporan ganda.

5.7 SAFE HARBOR DAN PERLINDUNGAN PELAPOR

Organisasi sering takut melaporkan insiden karena khawatir kehilangan reputasi, langsung dianggap lalai, dijatuhi sanksi, atau digugat sebelum investigasi selesai. Ketakutan ini menciptakan insentif yang salah: organisasi yang terbuka menghadapi risiko lebih besar daripada organisasi yang menyembunyikan kejadian.

Keamanan Ketahanan Siber perlu menyediakan *safe harbor* terbatas bagi penyelenggara yang:

1. Lapor tepat waktu atau mempunyai alasan sah atas keterlambatan.
2. Bertindak dengan itikad baik.
3. Menyampaikan fakta yang diketahui tanpa manipulasi.
4. Memperbarui laporan ketika memperoleh informasi baru.
5. Mempertahankan bukti yang relevan.
6. Bekerja sama dalam pembatasan dampak dan pemulihan.
7. Melaksanakan langkah perbaikan yang diperintahkan secara sah.

Safe harbor bukan kekebalan dari tanggung jawab. Pelaporan tidak menghapus kesalahan apabila organisasi terbukti sengaja mengabaikan kewajiban keamanan, melakukan kelalaian berat, menutup-nutupi insiden, menghancurkan bukti, atau memberikan informasi palsu.

Perlindungan yang tepat adalah:

> **Laporan awal tidak dianggap sebagai pengakuan tanggung jawab hukum.**
>
> **Perubahan informasi selama investigasi tidak otomatis dianggap sebagai laporan palsu.**
>
> **Informasi rahasia dalam laporan tidak diumumkan tanpa dasar hukum dan penilaian kepentingan publik.**
>
> **Identitas korban tidak digunakan untuk mempermalukan organisasi.**
>
> **Kepatuhan pelaporan dan kerja sama menjadi faktor yang meringankan dalam penegakan administratif.**
>
> **Informasi yang dibagikan untuk pertahanan siber tidak boleh digunakan di luar tujuan yang sah tanpa prosedur yang dapat diuji.**

Perlindungan reputasi tidak boleh mengalahkan hak masyarakat. Apabila warga perlu mengambil tindakan untuk melindungi akun, identitas, keuangan, kesehatan, atau keselamatannya, pemberitahuan harus dilakukan secara jelas dan tepat waktu. Bahasa pemberitahuan harus menjelaskan apa yang terjadi, siapa yang mungkin terdampak, tindakan apa yang telah dilakukan, serta apa yang perlu dilakukan masyarakat.

Komunikasi publik tidak boleh bersifat spekulatif, tetapi juga tidak boleh menyamarkan risiko. Pernyataan “tidak ada bukti data bocor” berbeda dari “dipastikan tidak ada data bocor”. Negara dan organisasi harus menggunakan bahasa yang mencerminkan tingkat kepastian yang sebenarnya.

Referensi Onno W. Purbo mengenai *incident response* menekankan bahwa insiden harus di triage, didokumentasikan, ditangani, dan ditutup dengan pembelajaran. Bukti, kronologi, tingkat keyakinan, dampak, tindakan, dan rekomendasi harus dipisahkan dengan jelas. **Laporan yang baik membangun cerita berdasarkan bukti, bukan berdasarkan dugaan atau kebutuhan menjaga citra.**

Kepercayaan publik tidak dibangun dengan berpura-pura bahwa insiden tidak pernah terjadi. Kepercayaan dibangun ketika organisasi dapat mengatakan: kejadian terdeteksi, masyarakat dilindungi, layanan dipulihkan, penyebab ditemukan, dan kesalahan tidak diulangi.

5.8 KEPUTUSAN STRATEGIS BAB 5

Pelaporan insiden bukan tujuan akhir. Pelaporan adalah mekanisme untuk memobilisasi pertolongan, menghentikan penyebaran, memperingatkan pihak lain, melindungi masyarakat, dan memperbaiki ketahanan nasional.

Keamanan Ketahanan Siber perlu menetapkan sepuluh keputusan strategis.

Pertama, **Indonesia harus menggunakan prinsip satu insiden, satu identitas, dan satu pintu pelaporan nasional**.

Kedua, **undang-undang harus membedakan** *event*, *alert*, insiden, insiden material, kegagalan pelindungan data pribadi, dan dugaan tindak pidana.

Ketiga, **kewajiban laporan** harus didasarkan pada dampak material dan risiko penyebaran, bukan pada setiap gangguan teknis.

Keempat, **indikator materialitas** harus mencakup layanan, durasi, data, pengguna, kerugian, keselamatan, sektor, wilayah, dampak kaskade, karakter ancaman, dan kemampuan pemulihan.

Kelima, **laporan harus dilakukan bertahap**. Laporan awal memuat informasi minimum, laporan perkembangan memperbaiki gambaran, dan laporan akhir menghasilkan pembelajaran.

Keenam, **penyampaian melalui saluran nasional** harus diakui sebagai pemenuhan kewajiban kepada otoritas yang terhubung apabila isi minimum dan tenggat telah dipenuhi.

Ketujuh, **data laporan harus dipisahkan** berdasarkan klasifikasi, kebutuhan, dan kewenangan. Tidak semua lembaga boleh memperoleh seluruh data.

Kedelapan, **pelaporan keamanan siber** harus dibedakan tetapi diintegrasikan dengan pemberitahuan kegagalan pelindungan data pribadi serta kewajiban sektoral.

Kesembilan, pelapor yang bertindak tepat waktu, jujur, dan kooperatif harus **memperoleh *safe harbor* terbatas**. Perlindungan tersebut tidak berlaku bagi penyembunyian, manipulasi, kelalaian berat, atau penghancuran bukti.

Kesepuluh, **keberhasilan sistem pelaporan harus diukur** melalui kecepatan pertolongan, penurunan dampak, peringatan lintas sektor, keberhasilan pemulihan, dan perbaikan kebijakan—bukan hanya dari jumlah laporan yang diterima.

Negara yang tangguh bukan negara yang tidak pernah mengalami insiden. Negara yang tangguh adalah negara yang cepat mengetahui, cepat membantu, cepat belajar, dan tidak mengulangi kesalahan yang sama.

RANGKUMAN BAB 5

Bagian	Masalah Utama	Arah Kebijakan	Keputusan Strategis
5.1 Pelaporan terfragmentasi	Satu insiden dilaporkan berulang kepada banyak lembaga	Gunakan satu identitas dan satu pintu masuk nasional	Satu insiden, satu laporan inti, banyak tindak lanjut sesuai kewenangan
5.2 Definisi insiden	Event, alert, insiden, dan kebocoran data sering disamakan	Bedakan kejadian teknis berdasarkan validasi, dampak, dan kebutuhan respons	Hanya insiden material dan kritikal yang wajib dilaporkan kepada negara
5.3 Materialitas	Tidak tersedia ambang yang konsisten dan objektif	Nilai layanan, data, pengguna, keselamatan, kerugian, dependensi, wilayah, dan pemulihan	Letakkan indikator utama dalam undang-undang dan ukuran teknis dalam aturan pelaksanaan
5.4 Pelaporan bertahap	Laporan lengkap sulit dibuat pada jam pertama	Gunakan peringatan awal, laporan perkembangan, dan laporan akhir	Kecepatan laporan tidak boleh dipertukarkan dengan kepastian palsu
5.5 Saluran nasional	Banyak laporan tidak menghasilkan gambaran nasional	Bangun sistem federatif dengan akses berbasis kewenangan	Pusatkan gambaran situasi, bukan seluruh data mentah
5.6 Harmonisasi	Kewajiban siber, PDP, sektoral, dan pidana tumpang tindih	Gunakan formulir inti dan distribusi otomatis sesuai tujuan hukum	Pelaporan satu kali harus diakui sebagai pemenuhan kewajiban kepada otoritas terkait
5.7 Safe harbor	Ketakutan terhadap sanksi mendorong penyembunyian	Lindungi laporan yang tepat waktu, jujur, dan diperbarui dengan iktikad baik	Laporan bukan pengakuan salah; manipulasi dan penyembunyian tetap dikenai sanksi
5.8 Keputusan strategis	Pelaporan mudah berubah menjadi kegiatan administratif	Arahkan sistem kepada pertolongan, pembatasan dampak, dan pembelajaran	**Ukur keberhasilan dari keselamatan dan pemulihan, bukan jumlah formulir**

REFERENSI UTAMA BAB 5

- Onno W. Purbo, *Open Source SOC Mastery: Membangun Security Operations Center Modern dengan Tools Gratis*, 2026.
- Onno W. Purbo, *Audit Data Privacy untuk UU PDP Compliance*, 2025.
- Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi.
- Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik.
- NIST SP 800-61 Rev. 3, *Incident Response Recommendations and Considerations for Cybersecurity Risk Management*, 2025.
- NIST, *Cybersecurity Framework 2.0*, 2024.
- European Union, Directive (EU) 2022/2555, *Network and Information Security Directive 2*.

BAB 6 - MEMPERTAHANKAN RUANG INFORMASI TANPA MEMBUNUH DEMOKRASI

Tujuan bab: membedakan keamanan konten dari pengendalian pendapat dan mencegah Keamanan Ketahanan Siber menjadi alat sensor politik.

Demokrasi dapat diserang tanpa satu pun server dimatikan. Pemilu dapat dipengaruhi tanpa membobol sistem penghitungan suara. Kepercayaan kepada negara dapat dirusak tanpa merusak jaringan telekomunikasi. Serangan dilakukan dengan membanjiri ruang informasi, menyamarkan pelaku, menciptakan kesan dukungan palsu, memperbesar konflik, dan mengulang narasi secara terkoordinasi sampai masyarakat sulit membedakan percakapan yang organik dari operasi yang direkayasa.

Namun, upaya mempertahankan ruang informasi membawa risiko yang sama seriusnya. Definisi yang kabur dapat membuat kritik, oposisi, jurnalisme, satire, penelitian, atau perbedaan pendapat dicap sebagai ancaman siber. Kewenangan yang dibentuk untuk menghadapi manipulasi asing dapat bergeser menjadi alat untuk melindungi pemerintah dari kritik.

Karena itu, negara harus membedakan tiga hal: **pendapat yang tidak disukai, informasi yang keliru, dan operasi manipulasi yang terkoordinasi**. Ketiganya tidak boleh diperlakukan dengan cara yang sama.

> **Keamanan Ketahanan Siber harus melindungi autentisitas proses demokrasi, bukan menentukan pendapat mana yang boleh dipercaya masyarakat.**

6.1 RUANG SIBER MEMILIKI LAPISAN INFRASTRUKTUR, SISTEM, DATA, DAN INFORMASI

Keamanan siber sering dipahami hanya sebagai perlindungan jaringan, server, aplikasi, dan data. Pandangan tersebut benar, tetapi belum lengkap. Ruang siber merupakan ekosistem berlapis yang setiap lapisannya mempunyai risiko berbeda.

> Lapisan pertama adalah **infrastruktur fisik**, seperti kabel, pusat data, satelit, menara telekomunikasi, perangkat jaringan, dan pasokan energi.
>
> Lapisan kedua adalah **sistem dan aplikasi**, termasuk sistem operasi, layanan komputasi awan, aplikasi pemerintah, sistem pembayaran, media sosial, serta algoritma yang mengatur distribusi informasi.
>
> Lapisan ketiga adalah **data**, yaitu rekaman yang disimpan, diproses, dipindahkan, atau digunakan untuk menghasilkan keputusan.
>
> Lapisan keempat adalah **informasi dan interaksi sosial**, yaitu narasi, perdebatan, kampanye, berita, iklan, rekomendasi algoritmik, dan hubungan antarwarga.

Serangan terhadap tiga lapisan pertama relatif mudah dikenali. Sistem kehilangan ketersediaan, data berubah tanpa izin, akun diambil alih, atau jaringan mengalami gangguan. Pada lapisan informasi, sistem teknis dapat tetap berfungsi sesuai rancangan, tetapi hasil sosialnya dimanipulasi.

Seribu akun semu dapat mengulang narasi yang sama sehingga tampak sebagai suara masyarakat. Sistem rekomendasi dapat dieksploitasi untuk memperbesar konten provokatif. Identitas media dapat ditiru untuk memberi legitimasi palsu. Potongan video dapat dipindahkan dari konteks aslinya. Jaringan akun dapat menyerang seorang jurnalis secara serentak agar ia berhenti berbicara.

Dalam keadaan tersebut, tidak ada kerusakan pada server. Yang diserang adalah **integritas proses pembentukan persepsi publik**.

Negara perlu memahami bahwa keamanan informasi bukan berarti negara menjadi penentu kebenaran. Kebenaran ilmiah, tafsir sejarah, kritik kebijakan, pilihan politik, dan penilaian moral tidak dapat ditentukan melalui dashboard keamanan siber.

Peran negara adalah menjaga agar warga dapat berinteraksi dalam lingkungan yang tidak direkayasa melalui penipuan sistematis, intimidasi, penyamaran, dan amplifikasi tidak autentik. Jawaban utamanya bukan sensor, melainkan transparansi, autentisitas proses, literasi, pluralisme media, dan kemampuan masyarakat memeriksa sumber.

> **Yang harus dipertahankan adalah proses demokratisnya, bukan kenyamanan penguasanya.**

6.2 DEFINISI OPERASI PENGARUH TERKOORDINASI

Istilah operasi pengaruh terkoordinasi harus dirumuskan secara sempit dan terukur. Definisi yang hanya menggunakan kata “informasi menyesatkan”, “meresahkan”, “mempengaruhi masyarakat”, atau “mengganggu stabilitas” terlalu lentur untuk menjadi dasar pembatasan hak.

Hampir semua komunikasi politik bertujuan mempengaruhi masyarakat. Kampanye partai, iklan komersial, advokasi organisasi masyarakat, komunikasi pemerintah, kegiatan kehumasan, dan gerakan sosial sama-sama berusaha membentuk opini. Pengaruh dengan sendirinya bukan pelanggaran.

Operasi pengaruh terkoordinasi dapat dirumuskan sebagai:

> **Serangkaian tindakan yang dilakukan secara sengaja dan terkoordinasi oleh satu atau lebih aktor untuk memanipulasi proses distribusi, persepsi, atau partisipasi dalam ruang informasi melalui penyamaran identitas, penipuan mengenai asal-usul, amplifikasi tidak autentik, eksploitasi sistem platform, atau cara manipulatif lainnya, sehingga menimbulkan atau berpotensi menimbulkan dampak material terhadap kepentingan publik, proses demokrasi, keselamatan, atau keamanan nasional.**

Definisi tersebut mempunyai lima unsur yang harus dibuktikan.

> Pertama, terdapat **tindakan**, bukan hanya isi pendapat.
>
> Kedua, terdapat **koordinasi**, bukan sekadar banyak orang mempunyai pandangan yang sama.
>
> Ketiga, terdapat **ketidak otentikan atau manipulasi**, seperti penyamaran pengendali, hubungan berbayar yang tidak diungkap, identitas palsu, atau penggunaan sistem otomatis untuk menciptakan kesan dukungan organik.
>
> Keempat, terdapat **tujuan atau pola yang dapat dinilai**, bukan dugaan berdasarkan kedekatan politik.
>
> Kelima, terdapat **dampak material atau risiko material**, bukan sekedar rasa tidak nyaman pemerintah.

European External Action Service mendefinisikan *Foreign Information Manipulation and Interference* sebagai pola perilaku yang manipulatif, dilakukan secara sengaja dan terkoordinasi, serta mengancam atau berpotensi merugikan nilai, prosedur, dan proses politik. Pendekatan tersebut penting karena berfokus pada perilaku manipulatif, bahkan ketika setiap potongan kontennya belum tentu ilegal. European External Action Service, Information Integrity and FIMI

Dalam konteks Indonesia, operasi tersebut dapat melibatkan:

- jaringan akun yang dikendalikan secara terpusat;
- penyamaran hubungan antara akun dan pemberi perintah;
- pembelian amplifikasi yang tidak diungkapkan;
- penggunaan bot untuk memalsukan popularitas;
- peniruan identitas media, lembaga, atau tokoh;
- manipulasi tagar, tren, komentar, atau sistem rekomendasi;
- distribusi konten melalui jaringan halaman yang tampak independen;
- pendanaan atau pengarahan asing yang disembunyikan;
- intimidasi terkoordinasi untuk membungkam partisipasi publik;
- penggabungan operasi informasi dengan peretasan, kebocoran terpilih, pemalsuan, atau sabotase.

Pendanaan asing merupakan faktor penting, tetapi bukan satu-satunya unsur. Bantuan asing kepada media, penelitian, pendidikan, atau organisasi masyarakat yang sah dan transparan tidak boleh otomatis dianggap sebagai operasi pengaruh. Masalah muncul ketika sumber dana, kendali, tujuan, atau metode sengaja disembunyikan untuk menipu publik.

> **Koordinasi yang terbuka adalah kampanye. Koordinasi yang sengaja disamarkan untuk menciptakan persepsi palsu dapat menjadi operasi manipulasi.**

6.3 PERILAKU, BUKAN ISI PENDAPAT

Batas paling penting dalam Bab ini adalah pemisahan antara isi dan perilaku.

Sebuah pendapat dapat keras, emosional, memihak, tidak populer, keliru, atau menyakitkan tanpa menjadi serangan siber. Kritik terhadap Presiden, menteri, parlemen, TNI, Polri, BSSN, partai politik, maupun kebijakan negara tidak boleh dikategorikan sebagai ancaman hanya karena menyebar luas atau menurunkan kepercayaan publik.

Demikian pula, satire, parodi, karya seni, jurnalisme investigatif, perdebatan akademik, dan oposisi politik mempunyai fungsi penting dalam demokrasi. Negara yang hanya aman ketika tidak dikritik sebenarnya tidak aman; negara tersebut rapuh terhadap koreksi.

Penanganan operasi pengaruh harus memeriksa pertanyaan berikut:

- Apakah pelaku menyembunyikan hubungan koordinasi?
- Apakah identitas atau afiliasi sengaja dipalsukan?
- Apakah aktivitas otomatis digunakan untuk menciptakan kesan dukungan manusia yang tidak ada?
- Apakah terdapat transaksi atau pendanaan yang sengaja tidak diungkap?
- Apakah jaringan berusaha menipu sistem rekomendasi atau pengukuran popularitas?
- Apakah beberapa kanal yang tampak independen sebenarnya dikendalikan pihak yang sama?
- Apakah terdapat intimidasi, ancaman, penipuan, peretasan, atau tindakan lain yang sudah melanggar hukum?
- Apakah dampaknya cukup material untuk membenarkan intervensi?

Sebaliknya, hal-hal berikut tidak boleh menjadi bukti tunggal:

- kesamaan pendapat;
- penggunaan tagar yang sama;
- kritik yang disampaikan serentak;
- popularitas narasi;
- pilihan kata yang mirip;
- afiliasi politik;
- anonimitas;
- kesalahan faktual;
- ketidaksukaan pemerintah terhadap isi pesan.

> **Kesamaan narasi menunjukkan korelasi, bukan otomatis koordinasi. Kesamaan waktu menunjukkan pola, bukan otomatis komando. Kedekatan politik menunjukkan afiliasi, bukan otomatis kejahatan.**

Informasi yang salah perlu direspons secara berbeda berdasarkan bentuk dan dampaknya. Kesalahan biasa dapat dikoreksi melalui informasi tandingan. Informasi medis yang membahayakan dapat membutuhkan intervensi berbasis hukum kesehatan. Penipuan dapat diproses berdasarkan hukum pidana. Fitnah mempunyai mekanisme hukum tersendiri. Operasi asing membutuhkan respons diplomatik dan keamanan nasional.

Keamanan Ketahanan Siber tidak boleh menjadi undang-undang sapu jagat untuk semua persoalan konten. Norma keamanan siber harus dibatasi pada ketahanan sistem informasi, manipulasi perilaku terkoordinasi, risiko sistemik, dan keterhubungannya dengan ancaman siber.

6.4 BOT, BUZZER, DAN AKUN SEMU

Bot adalah teknologi otomatisasi. *Buzzer* adalah istilah sosial yang belum mempunyai definisi hukum yang konsisten. Akun semu dapat digunakan untuk penipuan, tetapi dapat pula digunakan untuk privasi, keselamatan, karya kreatif, penelitian, parodi, atau perlindungan dari persekusi.

Karena itu, **teknologi maupun identitas samaran tidak boleh dinyatakan ilegal secara otomatis**.

Bot dapat digunakan untuk memberikan peringatan gempa, informasi cuaca, pengumuman transportasi, layanan pelanggan, distribusi berita, atau respons keadaan darurat. Otomatisasi menjadi bermasalah ketika digunakan untuk menipu pengguna, menyamarkan skala operasi, memalsukan dukungan, atau mengganggu sistem platform.

Demikian pula, penggunaan nama samaran mempunyai nilai demokratis. Pelapor pelanggaran, korban kekerasan, kelompok minoritas, aktivis, dan warga yang menghadapi ancaman dapat membutuhkan anonimitas. Kewajiban penggunaan identitas asli untuk semua akun dapat membahayakan mereka dan memperluas pengumpulan data pribadi.

Yang perlu diatur adalah transparansi fungsi dan perilaku. Akun otomatis yang berinteraksi dengan publik dalam skala tertentu dapat diwajibkan menyatakan bahwa ia dioperasikan secara otomatis. Kampanye berbayar perlu mengungkap pihak yang membayar. Akun yang mengatasnamakan lembaga atau tokoh harus dibedakan dari akun resmi. Platform harus bertindak terhadap peniruan identitas yang menipu.

Untuk menilai jaringan bot atau *buzzer*, tidak boleh digunakan satu indikator tunggal. Frekuensi unggahan yang tinggi, teks yang serupa, atau aktivitas pada malam hari hanya merupakan petunjuk. Analisis harus memeriksa kombinasi:

1. Keserempakan waktu yang tidak wajar.
2. Penggunaan teks, tautan, media, atau pola kesalahan yang identik.
3. Pola pembuatan serta aktivasi akun.
4. Struktur amplifikasi yang berulang.
5. Hubungan administratif atau infrastruktur jika tersedia secara sah.
6. Aliran pembayaran atau hubungan kontraktual.
7. Perintah atau koordinasi yang dapat dibuktikan.
8. Upaya menyembunyikan pengendali sebenarnya.
9. Dampak terhadap pengguna, proses demokrasi, atau keselamatan.
10. Penjelasan alternatif yang masuk akal.

Referensi Onno W. Purbo mengenai OSINT menegaskan bahwa bot tidak dapat ditentukan melalui satu ciri. Akun manusia dapat menggunakan otomatisasi, sedangkan bot dapat meniru pola manusia. Demikian pula, sebuah *cluster* jaringan dapat terbentuk karena kesamaan bahasa, minat, lokasi, popularitas, peristiwa, atau algoritma platform—bukan selalu karena koordinasi.

> **Grafik jaringan yang indah tidak membuktikan adanya komando. Skor kecerdasan buatan tidak boleh berubah menjadi vonis.**

Sistem analitik nasional dapat membantu mendeteksi pola, tetapi manusia yang berwenang tetap harus memeriksa konteks, sumber, keterbatasan data, kemungkinan kesalahan, dan dampak terhadap hak.

6.5 ATRIBUSI DAN STANDAR PEMBUKTIAN

Mendeteksi pola berbeda dari menentukan pelaku. Menemukan seratus akun yang bertindak serupa belum membuktikan siapa pengendalinya. Menemukan alamat IP belum membuktikan identitas manusia. Menemukan infrastruktur di negara tertentu belum membuktikan bahwa pemerintah negara tersebut bertanggung jawab.

Atribusi operasi pengaruh setidaknya mempunyai empat tingkat.

> Tingkat pertama adalah **atribusi perilaku**: apakah aktivitas menunjukkan pola terkoordinasi dan tidak autentik.
>
> Tingkat kedua adalah **atribusi teknis**: apakah terdapat hubungan perangkat, infrastruktur, akun administratif, domain, jaringan, atau artefak digital.
>
> Tingkat ketiga adalah **atribusi organisasi dan finansial**: apakah terdapat hubungan pengelolaan, kontrak, pembayaran, kepemilikan, atau pemberian perintah.
>
> Tingkat keempat adalah **atribusi politik atau negara**: apakah operasi dapat secara bertanggung jawab dikaitkan kepada lembaga pemerintah, organisasi politik, perusahaan, atau negara asing tertentu.

Semakin serius tuduhan dan konsekuensinya, semakin tinggi standar pembuktiannya. Penurunan distribusi konten mungkin dapat dilakukan berdasarkan risiko platform dengan mekanisme banding. Penutupan jaringan akun memerlukan bukti koordinasi yang lebih kuat. Sanksi administratif memerlukan prosedur pemeriksaan. Pemidanaan harus mengikuti hukum acara dan standar pembuktian pidana. Tuduhan kepada negara asing memerlukan penilaian lintas intelijen, diplomasi, hukum, dan kebijakan nasional.

Bukti dapat berasal dari beberapa kelompok:

- **Bukti perilaku:** waktu, pola unggahan, pengulangan, struktur amplifikasi, dan pembagian peran.
- **Bukti teknis:** akun administratif, metadata yang diperoleh secara sah, infrastruktur, domain, perangkat, atau artefak digital.
- **Bukti finansial:** pembayaran, kontrak, sponsor, perantara, dan sumber pembiayaan.
- **Bukti organisasi:** komunikasi, pemberian tugas, struktur kendali, atau hubungan kelembagaan.
- **Bukti konten:** konsistensi narasi dan tujuan, tetapi bukan sebagai bukti tunggal.
- **Bukti intelijen:** informasi yang diperoleh lembaga berwenang dengan pengujian reliabilitas serta pembatasan penggunaan.
- **Bukti kontekstual:** waktu politik, target, korban, dan hubungan dengan operasi lain.

Analisis wajib memisahkan fakta, inferensi, hipotesis, dan hal yang belum diketahui. Setiap kesimpulan perlu mempunyai tingkat keyakinan serta penjelasan mengenai bukti yang mendukung dan yang bertentangan.

Prinsip dari referensi OSINT sangat relevan: **kesamaan jejak digital adalah petunjuk, bukan bukti bahwa dua akun dikendalikan orang yang sama**. Kesamaan IP juga hanya menunjukkan kemungkinan hubungan teknis. Satu alamat IP dapat digunakan banyak pelanggan, layanan komputasi awan, *content delivery network*, atau sistem *shared hosting*.

Kesalahan atribusi dapat menghancurkan reputasi, memicu konflik diplomatik, mengkriminalisasi warga, dan mengurangi kepercayaan kepada negara. Karena itu, publikasi atribusi harus melalui penelaahan independen, dokumentasi alasan, klasifikasi tingkat keyakinan, dan persetujuan pejabat yang bertanggung jawab.

> **Kemampuan negara untuk menuduh harus diimbangi kewajiban negara untuk membuktikan.**

6.6 PERAN PLATFORM DIGITAL

Platform bukan sekadar papan pengumuman. Platform menentukan siapa melihat apa, seberapa cepat konten menyebar, akun mana yang direkomendasikan, dan bagaimana popularitas diukur. Sistem rekomendasi, iklan, fitur tren, serta desain interaksi dapat memperbesar informasi jauh melampaui jangkauan organiknya.

Karena itu, kewajiban platform tidak cukup berhenti pada menerima permintaan penghapusan. Platform perlu membangun transparansi dan akuntabilitas pada tingkat sistem.

Kewajiban berbasis risiko bagi platform besar dapat mencakup:

1. Transparansi mengenai parameter utama sistem rekomendasi.
2. Pilihan bagi pengguna untuk memperoleh umpan nonpersonal atau kronologis.
3. Pelabelan akun otomatis dalam kategori tertentu.
4. Transparansi iklan politik dan isu kepentingan publik.
5. Repository iklan yang dapat diperiksa publik.
6. Pengungkapan pihak yang membayar, nilai, periode, target, dan jangkauan iklan.
7. Deteksi jaringan koordinasi tidak autentik berdasarkan proses yang terdokumentasi.
8. Penjelasan ketika konten dihapus, diturunkan distribusinya, atau akun dibatasi.
9. Mekanisme keberatan dan peninjauan oleh manusia.
10. Pelaporan berkala mengenai moderasi serta risiko sistemik.
11. Akses aman bagi peneliti independen yang memenuhi persyaratan.
12. Preservasi bukti untuk investigasi yang sah tanpa pengumpulan data berlebihan.

Uni Eropa melalui Digital Services Act mewajibkan transparansi alasan penghapusan atau pembatasan konten, menyediakan mekanisme banding, meningkatkan transparansi iklan, serta meminta platform yang sangat besar menilai risiko terhadap kebebasan berekspresi, pluralisme media, keamanan publik, dan proses pemilu. Pengguna platform besar juga memperoleh pilihan umpan yang tidak dipersonalisasi. European Commission, Digital Services Act

Indonesia dapat mempelajari prinsip tersebut tanpa menyalinnya secara mentah. Kewajiban harus disesuaikan dengan jumlah pengguna, kemampuan platform memengaruhi distribusi, serta risiko sistemiknya. Platform kecil tidak boleh menerima beban yang sama dengan platform global yang menjadi gerbang utama informasi nasional.

Namun, transparansi algoritma tidak harus berarti membuka seluruh kode sumber atau rahasia dagang. Yang diperlukan adalah keterbukaan mengenai tujuan optimasi, faktor utama rekomendasi, risiko yang telah ditemukan, perubahan material, hasil audit, dan pilihan kendali bagi pengguna.

Negara juga tidak boleh memerintahkan platform secara informal untuk menurunkan konten tanpa dasar dan jejak keputusan. Setiap permintaan pemerintah harus mempunyai dasar hukum, identitas pejabat, alasan, ruang lingkup, durasi, serta mekanisme evaluasi dan keberatan.

> **Jika pemerintah dapat menyembunyikan permintaan sensor dan platform dapat menyembunyikan logika amplifikasi, masyarakat berada di antara dua kekuasaan yang sama-sama tidak terlihat.**

6.7 SAFEGUARD KEBEBASAN BEREKSPRESI

Kebebasan berekspresi bukan gangguan terhadap keamanan nasional. Ia merupakan salah satu sumber ketahanan nasional karena memungkinkan kesalahan pemerintah ditemukan, korban berbicara, ilmuwan memperingatkan risiko, dan masyarakat mengoreksi informasi.

UUD Negara Republik Indonesia Tahun 1945 menjamin kebebasan menyatakan pikiran dan sikap serta hak untuk berkomunikasi, mencari, memperoleh, memiliki, menyimpan, mengolah, dan menyampaikan informasi. Indonesia juga telah mengesahkan Kovenan Internasional tentang Hak-Hak Sipil dan Politik melalui UU Nomor 12 Tahun 2005.

Hak tersebut bukan tanpa batas. Namun setiap pembatasan harus lulus pengujian yang ketat.

Pertama, **legalitas**. Pembatasan harus memiliki dasar hukum yang jelas, dapat diakses, dan dapat diperkirakan akibatnya. Istilah seperti “meresahkan”, “tidak sejalan”, “merugikan citra”, atau “mengganggu stabilitas” tidak cukup presisi.

Kedua, **tujuan yang sah**. Intervensi hanya boleh dilakukan untuk tujuan yang diakui hukum, seperti melindungi hak orang lain, keamanan nasional, ketertiban umum, kesehatan, atau keselamatan.

Ketiga, **kebutuhan**. Negara harus membuktikan adanya kebutuhan nyata, bukan sekadar kemungkinan abstrak.

Keempat, **proporsionalitas**. Tindakan harus seimbang dengan dampak dan menggunakan cara yang paling sedikit membatasi hak.

Kelima, **batas waktu**. Pembatasan, pengawasan, atau penurunan distribusi tidak boleh berlaku tanpa batas.

Keenam, **due process**. Pihak terdampak berhak mengetahui alasan, memperoleh bukti yang dapat dibuka, menyampaikan pembelaan, dan mengajukan keberatan.

Ketujuh, **pengawasan independen**. Tindakan berisiko tinggi perlu ditinjau oleh pengadilan atau mekanisme independen yang mempunyai kewenangan nyata.

Kedelapan, **transparansi**. Pemerintah dan platform harus menerbitkan statistik permintaan, tindakan, hasil keberatan, serta kesalahan penanganan tanpa membuka data pribadi.

Instrumen penanganan juga perlu disusun secara bertingkat. Negara sebaiknya mendahulukan tindakan yang paling sedikit membatasi:

1. Memberikan informasi resmi yang cepat dan dapat diverifikasi.
2. Mendukung pemeriksaan fakta independen.
3. Menyediakan konteks atau label mengenai sumber.
4. Mengungkap sponsor, otomatisasi, atau hubungan koordinasi.
5. Mengurangi insentif finansial bagi operasi manipulatif.
6. Mengurangi amplifikasi buatan.
7. Membatasi fitur tertentu untuk sementara.
8. Menangguhkan akun atau jaringan setelah pemeriksaan.
9. Menghapus konten apabila jelas melanggar hukum.
10. Menggunakan pidana hanya terhadap perbuatan yang memenuhi unsur tindak pidana dan sebagai *ultimum remedium*.

Hak atas anonimitas juga perlu dilindungi. Pembukaan identitas hanya boleh dilakukan berdasarkan kewenangan yang sah, kebutuhan nyata, ruang lingkup terbatas, dan prosedur yang dapat diuji. Pengawasan massal terhadap percakapan warga tidak dapat dibenarkan hanya karena negara ingin menemukan kemungkinan operasi pengaruh.

Model analitik yang digunakan pemerintah harus diaudit untuk mengukur *false positive*, bias bahasa, bias politik, kualitas data, dan kemungkinan manipulasi. Tidak boleh ada daftar hitam rahasia berdasarkan skor algoritmik tanpa pemeriksaan manusia dan hak koreksi.

> **Dalam demokrasi, pemerintah tidak boleh menjadi sekaligus pelapor, pemeriksa, hakim, dan pelaksana penghapusan pendapat.**

6.8 KEPUTUSAN STRATEGIS BAB 6

Keamanan Ketahanan Siber dapat mengatur ketahanan ruang informasi, tetapi ruang lingkupnya harus dibatasi secara tegas. Regulasi ini sebaiknya mengatur koordinasi pertahanan, transparansi sistem, pertukaran indikator, tanggung jawab platform, preservasi bukti, dan respons terhadap operasi manipulatif.

Keamanan Ketahanan Siber tidak boleh menjadi dasar umum untuk menentukan kebenaran suatu pendapat atau menghukum informasi hanya karena salah, kontroversial, atau merugikan citra pemerintah.

Terdapat sepuluh keputusan strategis yang perlu ditetapkan.

Pertama, **bedakan keamanan infrastruktur, sistem, data, dan ruang informasi**. Setiap lapisan memerlukan instrumen serta standar pembuktian berbeda.

Kedua, **definisikan operasi** pengaruh berdasarkan tindakan sengaja, koordinasi, penyamaran, manipulasi, dan dampak material. Hindari istilah abstrak yang mudah dipolitisasi.

Ketiga, **jadikan perilaku sebagai objek utama penilaian**. Isi pendapat hanya dapat menjadi unsur konteks, bukan bukti tunggal.

Keempat, bot, *buzzer*, akun anonim, akun parodi, dan penggunaan otomatisasi tidak boleh dilarang berdasarkan jenisnya. Yang dinilai adalah penipuan, penyamaran hubungan, manipulasi sistem, koordinasi tersembunyi, serta dampaknya.

Kelima, **gunakan standar atribusi bertingkat**. Temuan pola tidak otomatis membuktikan pelaku, organisasi pengendali, pemberi dana, atau negara asal.

Keenam, **bebankan tanggung jawab sistemik kepada platform besar**, termasuk transparansi iklan, sistem rekomendasi, koordinasi tidak autentik, keputusan moderasi, dan mekanisme banding.

Ketujuh, **setiap tindakan pemerintah** harus memenuhi legalitas, tujuan sah, kebutuhan, proporsionalitas, batas waktu, dokumentasi, dan *due process*.

Kedelapan, **gunakan respons bertingkat** dengan mengutamakan transparansi, koreksi, literasi, pengungkapan sponsor, dan pengurangan amplifikasi sebelum penghapusan atau pemidanaan.

Kesembilan, **bangun kapasitas nasional** untuk analisis jaringan, forensik digital, analisis finansial, preservasi bukti, audit algoritma, dan literasi informasi menggunakan teknologi yang dapat diaudit serta dikembangkan di Indonesia.

Kesepuluh, **libatkan** perguruan tinggi, media, masyarakat sipil, komunitas teknis, platform, dan lembaga independen dalam pengawasan. Pemerintah tidak boleh memonopoli definisi ancaman informasi.

Keamanan Ketahanan Siber boleh melindungi negara dari manipulasi. Keamanan Ketahanan Siber tidak boleh melindungi pemerintah dari kritik.

RANGKUMAN BAB 6

Bagian	Masalah Utama	Prinsip Pengamanan	Keputusan Strategis
6.1 Lapisan ruang siber	Demokrasi dapat diganggu tanpa merusak infrastruktur	Bedakan infrastruktur, sistem, data, dan informasi	Lindungi integritas proses informasi tanpa menjadikan negara penentu kebenaran
6.2 Definisi operasi pengaruh	Definisi kabur mudah digunakan untuk menekan kritik	Buktikan tindakan, koordinasi, manipulasi, penyamaran, dan dampak	Gunakan definisi sempit, objektif, dan berbasis perilaku
6.3 Perilaku, bukan isi	Pendapat tidak populer dapat dicap sebagai ancaman	Nilai cara penyebaran dan koordinasi, bukan keberpihakan pesan	**Kritik, satire, oposisi, dan kesalahan biasa bukan otomatis ancaman siber**
6.4 Bot, buzzer, dan akun semu	Teknologi dan anonimitas dapat digunakan secara sah maupun manipulatif	Gunakan kombinasi indikator dan pemeriksaan manusia	Jangan melarang alat atau identitas; tindak penipuan dan manipulasi
6.5 Atribusi	Korelasi teknis mudah disalah artikan sebagai bukti pelaku	Pisahkan atribusi perilaku, teknis, organisasi, finansial, dan politik	Semakin berat akibat hukum, semakin tinggi standar pembuktian
6.6 Platform digital	Algoritma platform dapat memperbesar manipulasi	Transparansi rekomendasi, iklan, moderasi, autentisitas, dan banding	Terapkan kewajiban proporsional berdasarkan skala serta risiko sistemik
6.7 Kebebasan berekspresi	Kewenangan keamanan dapat berubah menjadi sensor	Legalitas, tujuan sah, kebutuhan, proporsionalitas, batas waktu, dan due process	Dahulukan respons yang paling sedikit membatasi hak
6.8 Keputusan strategis	Perlindungan ruang informasi berisiko dipolitisasi	Pertahanan berbasis bukti, pengawasan independen, dan partisipasi publik	**Lawan manipulasi terkoordinasi tanpa membunuh demokrasi**

REFERENSI UTAMA BAB 6

- Onno W. Purbo, Open Source Intelligence (OSINT), 2026.
- Onno W. Purbo, CEH Mastery: AI-Assisted OSINT, 2026.
- Undang-Undang Dasar Negara Republik Indonesia Tahun 1945, khususnya Pasal 28E, Pasal 28F, dan Pasal 28J.
- Undang-Undang Nomor 12 Tahun 2005 tentang Pengesahan International Covenant on Civil and Political Rights.
- United Nations Human Rights Committee, General Comment No. 34: Article 19—Freedoms of Opinion and Expression, 2011.
- European External Action Service, Information Integrity and Countering Foreign Information Manipulation and Interference.
- European Union, Digital Services Act.
- United Nations, International Covenant on Civil and Political Rights.
- Onno W. Purbo, Pemikiran tentang Keamanan dan Ketahanan Siber Indonesia, 2026.

BAB 7 - AI DAN RANTAI PASOKAN: MEDAN BARU KEDAULATAN TEKNOLOGI

Tujuan bab: membangun strategi nasional agar Indonesia tidak hanya aman menggunakan teknologi, tetapi juga mampu memahami, mengaudit, memperbaiki, mengganti, dan mengembangkannya.

Kedaulatan teknologi tidak berarti Indonesia harus membuat sendiri setiap cip, server, aplikasi, atau model kecerdasan artifisial. Dalam ekonomi digital global, kemandirian absolut hampir tidak mungkin dan secara ekonomi belum tentu masuk akal. Namun ketergantungan yang tidak dikelola sama berbahayanya dengan ketertinggalan teknologi.

Negara kehilangan kedaulatan ketika data strategis tidak dapat dipindahkan, keputusan mesin tidak dapat dijelaskan, sistem tidak dapat diaudit, kerentanan tidak dapat diperbaiki tanpa izin vendor, dan layanan publik berhenti ketika kontrak atau koneksi internasional terputus.

Ukuran kedaulatan yang lebih realistis adalah **kemampuan nasional untuk memahami, mengendalikan, mengaudit, mengoperasikan, memperbaiki, memulihkan, mengganti, dan mengembangkan teknologi yang menopang fungsi negara**.

Kecerdasan artifisial memperbesar urgensi tersebut. AI tidak hanya merupakan aplikasi. AI dibangun di atas rantai panjang yang melibatkan data, model, perangkat komputasi, pustaka perangkat lunak, layanan komputasi awan, antarmuka pemrograman, jaringan, integrator, dan tenaga ahli. Satu komponen yang tidak terkendali dapat menjadi titik kegagalan seluruh sistem.

> **Kedaulatan tidak dimulai dari slogan “buatan Indonesia”. Kedaulatan dimulai dari pertanyaan: apabila penyedia berhenti melayani besok, apakah negara masih dapat bekerja?**

7.1 AI SEBAGAI PEDANG BERMATA DUA

AI memberi pertahanan siber kemampuan untuk membaca data dalam skala dan kecepatan yang sulit dicapai manusia. AI dapat membantu mengelompokkan *alert*, mencari hubungan antar kejadian, mengenali anomali, merangkum bukti, menyusun kronologi, menerjemahkan laporan ancaman, dan memprioritaskan pekerjaan analis.

Dalam pusat operasi keamanan, manfaat terbesar AI bukan menggantikan analis, melainkan mengurangi pekerjaan berulang agar manusia dapat berkonsentrasi pada konteks, dampak, dan keputusan. AI dapat mempercepat pencarian, tetapi manusia tetap menentukan apakah temuan tersebut benar dan tindakan apa yang layak dilakukan.

Pada sisi lain, kemampuan yang sama tersedia bagi penyerang. AI dapat membantu menghasilkan pesan *phishing* yang lebih meyakinkan, meniru gaya bahasa seseorang, membuat suara dan video sintetis, mengotomatisasi rekayasa sosial, menganalisis kode, mencari pola kelemahan, dan menghasilkan variasi serangan dalam jumlah besar.

AI juga menurunkan biaya masuk. Pelaku dengan kemampuan teknis terbatas dapat menggunakan AI untuk memperbaiki bahasa, menyesuaikan pesan kepada kelompok sasaran, atau mengotomatisasi bagian dari operasi. Namun AI bukan mesin ajaib yang secara otomatis berhasil membobol sistem. Hasilnya tetap bergantung pada akses, data, kualitas model, pengujian, dan kemampuan pelaku memanfaatkan keluaran tersebut.

Dalam pertahanan, AI membawa sedikitnya enam risiko utama.

Pertama, **halusinasi**, yaitu keluaran yang terlihat meyakinkan tetapi tidak didukung fakta atau bukti teknis.

Kedua, ***automation bias***, yaitu kecenderungan manusia menerima rekomendasi mesin tanpa pemeriksaan yang memadai.

Ketiga, ***false positive***, yaitu aktivitas sah dinilai sebagai ancaman.

Keempat, ***false negative***, yaitu serangan nyata tidak dikenali oleh model.

Kelima, **manipulasi model dan data** melalui *data poisoning*, *prompt injection*, masukan adversarial, pencurian model, atau kompromi konektor.

Keenam, **ketergantungan** kepada penyedia model, komputasi, dan antarmuka yang dapat berubah tanpa kendali pengguna.

Referensi Onno W. Purbo mengenai AI dalam keamanan siber menegaskan bahwa sistem otomatis penuh dapat salah mengambil tindakan, misalnya memblokir layanan penting karena *false positive*. Karena itu, tata kelola, keterjelasan keputusan, dan kolaborasi manusia-AI menjadi unsur utama pertahanan.

AI paling aman digunakan lebih dahulu pada fungsi yang dapat dibalik dan diverifikasi, seperti pencarian, pengelompokan, penerjemahan, penyusunan konteks, dan rekomendasi. Semakin besar dampak tindakan, semakin kuat pengawasan manusianya.

> **AI boleh mempercepat pengamatan. AI tidak boleh mempercepat kesalahan negara.**

7.2 HUMAN-IN-THE-LOOP UNTUK KEPUTUSAN BERISIKO TINGGI

Istilah *human-in-the-loop* sering disalahartikan sebagai sekadar menyediakan tombol persetujuan. Padahal pengawasan manusia hanya bermakna apabila orang yang mengawasi mempunyai kewenangan, waktu, kompetensi, informasi, serta kemampuan menolak rekomendasi AI.

Jika seorang operator harus menyetujui ratusan keputusan dalam beberapa menit, manusia hanya menjadi stempel. Jika sistem tidak menjelaskan dasar rekomendasinya, manusia tidak benar-benar dapat mengawasi. Jika penolakan terhadap AI selalu dianggap sebagai kesalahan operator, kewenangan manusia hanya formalitas.

Keamanan Ketahanan Siber perlu menetapkan bahwa keputusan tertentu tidak boleh dilaksanakan sepenuhnya secara otomatis, terutama keputusan yang berkaitan dengan:

1. Pembatasan hak atau akses warga.
2. Penetapan seseorang sebagai ancaman atau pelaku.
3. Pengawasan terhadap individu.
4. Pemutusan layanan publik atau infrastruktur kritikal.
5. Penghapusan data atau bukti.
6. Pengenaan sanksi administratif maupun pidana.
7. Operasi ofensif dan tindakan balasan siber.
8. Atribusi serangan kepada organisasi atau negara.
9. Perubahan konfigurasi kritis yang sulit dipulihkan.
10. Keputusan yang dapat menimbulkan korban atau eskalasi konflik.

Otomatisasi tetap dapat digunakan untuk tindakan berisiko rendah dan mudah dibalik. Sistem dapat mengelompokkan laporan, meningkatkan pemantauan, menandai anomali, atau menyiapkan rekomendasi. Dalam keadaan yang telah ditentukan secara sempit, otomatisasi dapat menjalankan tindakan sementara dengan batas waktu, misalnya mengisolasi proses tertentu sambil menunggu validasi manusia.

Untuk keputusan berisiko tinggi, harus tersedia:

- pejabat atau profesional yang bertanggung jawab;
- dasar keputusan yang dapat diperiksa;
- tingkat keyakinan model;
- bukti yang mendukung dan yang bertentangan;
- catatan persetujuan atau penolakan;
- mekanisme override;
- kemampuan rollback;
- *kill switch*;
- jalur keberatan bagi pihak terdampak;
- evaluasi setelah keputusan dijalankan.

Surat Edaran Menteri Komunikasi dan Informatika Nomor 9 Tahun 2023 tentang Etika Kecerdasan Artifisial menempatkan AI sebagai pendukung aktivitas manusia dan menyatakan bahwa AI tidak diselenggarakan sebagai penentu kebijakan atau pengambil keputusan yang menyangkut kemanusiaan. Edaran tersebut juga menekankan keamanan, transparansi, kredibilitas, akuntabilitas, pelindungan data pribadi, manajemen risiko, dan tanggung jawab pengembang. JDIH Komdigi, SE Menkominfo Nomor 9 Tahun 2023

Prinsip itu perlu diterjemahkan menjadi norma yang dapat ditegakkan untuk penggunaan AI berisiko tinggi. Norma tidak cukup berhenti pada “harus ada manusia”. Undang-undang harus memastikan bahwa manusia tersebut **benar-benar mampu memahami, menghentikan, mengubah, dan mempertanggungjawabkan keputusan**.

> **Tanggung jawab tidak dapat dialihkan kepada algoritma. Pada akhirnya, selalu harus ada manusia dan institusi yang dapat dimintai pertanggungjawaban.**

7.3 TATA KELOLA RISIKO AI

AI tidak dapat dikelola hanya sebagai perangkat lunak biasa. Perilakunya dipengaruhi oleh data, model, konteks penggunaan, pembaruan, interaksi pengguna, dan perubahan lingkungan. Sistem yang menunjukkan hasil baik pada saat pengadaan dapat mengalami penurunan kualitas ketika data berubah atau model diperbarui.

Tata kelola risiko AI harus mencakup seluruh siklus hidup: perumusan tujuan, pemilihan atau pelatihan model, pengujian, penerapan, pemantauan, pembaruan, penanganan insiden, sampai penghentian.

Setiap sistem AI berisiko tinggi perlu memiliki sedikitnya:

1. **Tujuan yang jelas:** masalah apa yang diselesaikan dan penggunaan apa yang dilarang.
2. **Pemilik sistem:** siapa yang bertanggung jawab terhadap manfaat, risiko, dan keputusan.
3. **Pemilik data:** siapa yang memastikan asal, dasar penggunaan, kualitas, dan perlindungan data.
4. **Klasifikasi risiko:** dampak terhadap manusia, layanan publik, keamanan, dan hak.
5. **Dokumentasi model:** versi, asal, arsitektur umum, batas kemampuan, dan asumsi penggunaan.
6. **Validasi sebelum penggunaan:** pengujian akurasi, keamanan, bias, ketahanan, dan kesesuaian konteks.
7. **Pemantauan berkelanjutan:** perubahan performa, *model drift*, pola kegagalan, dan penyalahgunaan.
8. **Jejak keputusan:** masukan, keluaran, versi model, tindakan manusia, dan perubahan konfigurasi.
9. **Manajemen insiden AI:** prosedur ketika model bocor, dimanipulasi, salah mengambil keputusan, atau gagal.
10. **Prosedur penghentian:** kriteria untuk menurunkan, mengisolasi, mengganti, atau mematikan sistem.

Data perlu dinilai berdasarkan legalitas, kualitas, keterwakilan, sensitivitas, dan relevansinya. Dataset besar belum tentu baik. Dataset yang banyak memuat pola lama dapat membuat model gagal mengenali ancaman baru. Dataset yang terlalu didominasi satu sektor, wilayah, sistem operasi, bahasa, atau kelompok pengguna dapat menghasilkan bias.

Kinerja tidak boleh dinilai hanya berdasarkan akurasi rata-rata. Untuk keamanan siber, regulator dan pengguna perlu melihat *false positive*, *false negative*, presisi, kemampuan mendeteksi kelas ancaman penting, waktu respons, konsistensi, serta dampak kesalahan.

Keterjelasan atau *explainability* juga harus proporsional terhadap risiko. Tidak setiap keluaran AI memerlukan penjelasan teknis yang sangat rinci. Namun keputusan berisiko tinggi harus memungkinkan pengguna dan auditor memahami faktor utama, batasan, tingkat keyakinan, serta alasan sistem menghasilkan rekomendasi tertentu.

NIST AI Risk Management Framework dirancang untuk membantu organisasi mengelola risiko AI terhadap individu, organisasi, dan masyarakat, serta memasukkan unsur keandalan

ke dalam desain, pengembangan, penggunaan, dan evaluasi sistem AI. Pada April 2026, NIST juga menerbitkan catatan konsep untuk profil AI terpercaya pada infrastruktur kritikal. NIST AI Risk Management Framework

Uni Eropa melalui AI Act menerapkan pendekatan berbasis risiko. Untuk penggunaan berisiko tinggi, kerangkanya mencakup penilaian risiko, kualitas dataset, pencatatan aktivitas, dokumentasi, informasi kepada pengguna, pengawasan manusia, ketahanan, keamanan siber, dan akurasi. Model serbaguna dengan risiko sistemik juga menerima kewajiban penilaian dan mitigasi tambahan. European Commission, AI Act

Indonesia tidak perlu menyalin model asing secara utuh. Namun prinsip dasarnya relevan: **semakin besar dampak AI terhadap manusia dan negara, semakin kuat kewajiban pengujian, dokumentasi, pengawasan, dan pertanggungjawabannya**.

7.4 KEAMANAN RANTAI PASOKAN DIGITAL

Tidak ada sistem digital modern yang benar-benar berdiri sendiri. Sebuah aplikasi dapat menggunakan chip yang dirancang di satu negara, diproduksi di negara lain, menjalankan *firmware* dari vendor berbeda, memakai sistem operasi sumber terbuka, puluhan ribu pustaka, layanan komputasi awan, API eksternal, dan model AI yang dilatih menggunakan data dari berbagai yurisdiksi.

Rantai pasokan digital sekurang-kurangnya mencakup:

- perangkat keras dan komponen elektronik;
- firmware serta perangkat lunak tertanam;
- sistem operasi dan perangkat lunak utama;
- pustaka, paket, modul, dan komponen sumber terbuka;
- layanan komputasi awan dan pusat data;
- API dan layanan pihak ketiga;
- repositori kode serta sistem pembangunan perangkat lunak;
- model AI, bobot model, dan komponen inferensi;
- dataset pelatihan, validasi, dan evaluasi;
- mekanisme pembaruan;
- integrator, konsultan, dan penyedia pemeliharaan;
- identitas, sertifikat, dan kunci kriptografi;
- tenaga ahli yang mempunyai akses khusus.

Kompromi tidak harus terjadi pada produk akhir. Penyerang dapat menyusup melalui pustaka, akun pengembang, sistem pembaruan, alat pembangunan, penyedia identitas, atau vendor pemeliharaan. Produk yang terlihat aman dapat menjadi berbahaya setelah menerima pembaruan yang telah dimanipulasi.

NIST SP 800-161 Rev. 1 menjelaskan risiko rantai pasokan sebagai risiko produk dan layanan yang dapat mengandung fungsi berbahaya, komponen palsu, atau kerentanan akibat praktik pengembangan serta produksi yang buruk. Risiko membesar ketika organisasi tidak mempunyai visibilitas mengenai bagaimana teknologi dikembangkan, diintegrasikan, dan diterapkan. NIST SP 800-161 Rev. 1

Keamanan Ketahanan Siber harus menempatkan keamanan rantai pasokan sebagai tanggung jawab bersama. Produsen bertanggung jawab atas desain dan komponen yang dipilih. Integrator bertanggung jawab atas konfigurasi serta penggabungan sistem. Operator bertanggung jawab atas penggunaan, akses, dan pemantauan. Pemerintah bertanggung jawab menetapkan standar, mengawasi produk berisiko tinggi, dan membangun kemampuan pengujian nasional.

Kewajiban harus dibedakan berdasarkan risiko. Tidak realistis meminta setiap UMKM mengaudit seluruh kode setiap pustaka. Namun operator infrastruktur kritikal harus mampu mengetahui komponen penting, pemasok utama, dependensi strategis, masa dukungan, jalur pembaruan, dan pilihan pengganti.

Penilaian vendor tidak boleh berhenti pada negara asal. Produk domestik dapat tidak aman, sementara produk asing dapat mempunyai rekam keamanan yang baik. Yang harus diuji adalah:

- transparansi kepemilikan dan kendali;
- proses pengembangan aman;
- asal dan integritas komponen;
- kemampuan memperbaiki kerentanan;
- masa dukungan;
- akses khusus yang dimiliki vendor;
- lokasi serta kendali terhadap data;
- keberlanjutan pemasok;
- risiko yurisdiksi;
- kemampuan audit;
- rencana pemulihan dan penggantian.

Label “lokal” tidak menggantikan audit. Label “global” tidak menjamin ketahanan.

7.5 TRANSPARANSI KOMPONEN DAN KERENTANAN

Organisasi tidak dapat melindungi apa yang tidak diketahuinya. Ketika sebuah kerentanan diumumkan, pertanyaan pertama adalah: apakah komponen tersebut digunakan dalam sistem kita? Tanpa inventaris komponen, organisasi hanya dapat menebak.

Untuk produk berisiko tinggi, penyedia perlu mempunyai dokumentasi yang sekurang-kurangnya memuat:

1. Identitas dan versi produk.
2. Daftar komponen penting.
3. Asal atau pemasok komponen.
4. Hubungan dependensi.
5. Masa dukungan.
6. Mekanisme pembaruan.
7. Riwayat perubahan penting.
8. Kerentanan yang diketahui dan status perbaikannya.
9. Kanal pelaporan kerentanan.
10. Kontak keamanan yang dapat dihubungi.
11. Prosedur akhir dukungan.
12. Jalur migrasi atau penggantian.

Software Bill of Materials atau SBOM dapat digunakan sebagai salah satu instrumen transparansi komponen. Namun SBOM bukan sertifikat keamanan. Daftar komponen yang panjang tidak berarti produk telah aman. SBOM baru bernilai jika datanya akurat, diperbarui, dapat diproses, dan dihubungkan dengan proses pengelolaan kerentanan.

Untuk sistem AI, transparansi rantai pasokan perlu diperluas menjadi inventaris model dan data. Dokumentasi perlu menjelaskan model dasar, versi, sumber model, lisensi, komponen eksternal, dataset utama atau kategori sumber data, metode evaluasi, batas penggunaan, serta perubahan setelah *fine-tuning*.

Tidak seluruh informasi harus diumumkan kepada publik. Keterbukaan yang berlebihan dapat membocorkan rahasia dagang, data pribadi, atau rincian kelemahan yang dapat dieksploitasi. Karena itu, diperlukan beberapa tingkat transparansi:

> **Transparansi publik** mencakup masa dukungan, fungsi, risiko umum, kebijakan pembaruan, dan kanal laporan kerentanan.
>
> **Transparansi kepada pengguna** mencakup komponen relevan, perubahan penting, batas penggunaan, konfigurasi aman, dan jalur migrasi.
>
> **Transparansi kepada auditor dan regulator** mencakup dokumentasi yang lebih rinci, hasil pengujian, dependensi, dan bukti pengendalian.
>
> **Transparansi terbatas untuk investigasi** mencakup data teknis sensitif dengan dasar hukum, akses terbatas, dan jejak audit.

NIST Secure Software Development Framework menekankan integrasi praktik keamanan ke dalam siklus pengembangan agar jumlah kerentanan berkurang, dampak kerentanan yang belum ditemukan dapat dibatasi, dan akar masalah dapat diperbaiki. Kerangka tersebut juga memberikan bahasa bersama yang dapat dipakai pembeli dalam proses pengadaan. NIST SP 800-218, Secure Software Development Framework

Transparansi juga harus diikuti tanggung jawab. Penyedia harus menerima laporan kerentanan, memberikan konfirmasi, menetapkan prioritas, memperbaiki masalah, dan memberi informasi kepada pengguna. Peneliti yang bekerja dengan iktikad baik perlu memperoleh perlindungan yang proporsional.

Inventaris tanpa pemeliharaan hanyalah daftar. Transparansi tanpa tindakan hanyalah publikasi risiko.

7.6 OPEN SOURCE, PROPRIETARY, DAN ARSITEKTUR HIBRIDA

Perdebatan teknologi sering terjebak pada dua posisi ekstrem. Posisi pertama menganggap teknologi sumber terbuka selalu aman dan berdaulat. Posisi kedua menganggap produk komersial selalu lebih profesional karena mempunyai vendor serta dukungan.

Keduanya terlalu sederhana.

Sumber terbuka memberi kesempatan untuk memeriksa kode, membangun kompetensi, melakukan modifikasi, dan menjalankan sistem secara mandiri. Namun kemampuan tersebut hanya menjadi nyata jika Indonesia mempunyai tenaga yang mampu membaca, menguji, memelihara, dan mengembangkan teknologi tersebut.

Perangkat lunak terbuka yang tidak dipahami tetap dapat menciptakan ketergantungan. Proyek dapat bergantung kepada satu pengembang, kehilangan pemelihara, mempunyai dokumentasi buruk, atau menggunakan rantai dependensi yang rapuh.

Teknologi *proprietary* dapat menyediakan dukungan, integrasi, skala, fitur, dan jaminan layanan yang sulit dibangun dalam waktu singkat. Namun resikonya mencakup format tertutup, biaya yang berubah, ketergantungan lisensi, API yang tidak portabel, akses audit terbatas, dan kesulitan memindahkan data atau aturan operasional.

Arsitektur hibrida sering menjadi pilihan paling realistis. Data dan fungsi paling sensitif dapat dikelola pada infrastruktur yang berada dalam kendali nasional, sedangkan layanan komersial digunakan untuk fungsi yang membutuhkan skala atau kecepatan. Model lokal dapat menjalankan pekerjaan rutin, sementara model eksternal digunakan secara selektif setelah data di sanitasi dan risiko dinilai.

Keputusan teknologi harus diuji melalui tujuh ukuran:

1. **Auditabilitas:** dapatkah perilaku dan keamanannya diperiksa?
2. **Kontrol:** siapa yang dapat mengubah, menghentikan, atau mengakses sistem?
3. **Portabilitas:** dapatkah data, konfigurasi, dan pengetahuan dipindahkan?
4. **Interoperabilitas:** dapatkah sistem bekerja dengan teknologi lain?
5. **Kompetensi:** apakah tenaga Indonesia mampu mengoperasikan dan memperbaikinya?
6. **Ketahanan:** apakah sistem tetap dapat berjalan ketika komponen atau pemasok gagal?
7. **Kemampuan keluar:** dapatkah organisasi mengganti penyedia tanpa kehilangan operasi?

Referensi Onno W. Purbo, *Strategic Blueprint: AI Integration in the Corporate SOC*, menegaskan bahwa keputusan antara sumber terbuka, *proprietary*, dan hibrida bukan keputusan ideologis. Teknologi terbaik adalah teknologi yang sesuai risiko, menjaga kendali data, dapat diaudit, mempunyai biaya siklus hidup yang rasional, dapat bertahan ketika penyedia gagal, dan tidak menghilangkan kompetensi internal.

Vendor lock-in dapat dikenali melalui format tertutup, biaya ekspor tinggi, API tidak portabel, aturan deteksi yang hanya dapat digunakan pada satu platform, perubahan model sepihak, serta kemampuan tenaga kerja yang terlalu bergantung kepada satu produk.

> **Kedaulatan tidak ditentukan oleh jenis lisensi. Kedaulatan ditentukan oleh siapa yang mempunyai pengetahuan, kontrol, dan jalan keluar.**

7.7 INFRASTRUKTUR AI NASIONAL

AI nasional tidak cukup dibangun dengan satu model bahasa atau satu pusat data besar. Indonesia membutuhkan ekosistem berlapis yang dapat melayani pemerintah, infrastruktur kritikal, perguruan tinggi, industri, dan inovator domestik.

Infrastruktur tersebut sekurang-kurangnya mencakup tujuh lapisan strategis.

Pertama, **kapasitas komputasi**. Indonesia membutuhkan akses terencana terhadap GPU, akselerator, penyimpanan, jaringan berkecepatan tinggi, listrik, dan pendinginan. Tidak semua kapasitas harus dimiliki pemerintah, tetapi negara harus mengetahui kapasitas yang tersedia, siapa yang mengendalikannya, dan bagaimana alokasinya dalam krisis.

Kedua, **komputasi awan dan pusat data**. Layanan strategis perlu mempunyai pilihan penempatan, replikasi, operasi lokal, pemulihan, dan perpindahan antar pemasok. Kedaulatan tidak cukup dicapai hanya dengan lokasi fisik pusat data; kendali administratif, kunci kriptografi, perangkat lunak pengelola, serta tenaga operasi juga menentukan.

Ketiga, **model nasional dan model sektoral**. Indonesia membutuhkan model yang memahami Bahasa Indonesia, bahasa daerah, hukum, pelayanan publik, budaya, keamanan, kesehatan, pendidikan, dan kebutuhan industri. Model nasional tidak harus selalu menjadi model terbesar. Model yang lebih kecil, efisien, dapat dijalankan lokal, dan teruji untuk tugas tertentu sering lebih berdaulat serta lebih berguna.

Keempat, **dataset nasional yang sah dan berkualitas**. Dataset harus mempunyai asal yang jelas, dasar pemrosesan yang sah, dokumentasi, kontrol akses, ukuran kualitas, perlindungan data pribadi, dan mekanisme koreksi. Data pemerintah tidak boleh dibuka secara sembarangan, tetapi juga tidak boleh terkurung dalam silo yang membuat pengembangan nasional berhenti.

Kelima, **identitas digital dan kriptografi**. AI yang memperoleh akses kepada sistem negara harus menggunakan identitas, otorisasi, tanda tangan, pencatatan, dan manajemen kunci yang dapat dipercaya. Indonesia perlu menguasai operasi infrastruktur kunci serta mempersiapkan migrasi kriptografi ketika standar dan ancaman berubah.

Keenam, **pusat evaluasi dan keamanan AI**. Negara memerlukan kemampuan independen untuk menguji model terhadap bias, kebocoran data, *prompt injection*, manipulasi, penyalahgunaan, ketahanan, dan kesesuaian penggunaan. Pusat ini harus melibatkan BSSN, Komdigi, BRIN, perguruan tinggi, regulator sektor, industri, dan masyarakat ilmiah tanpa menciptakan monopoli penilaian.

Ketujuh, **SDM dan ekosistem pengembangan**. Infrastruktur tanpa manusia hanya menghasilkan ketergantungan baru. Pengadaan harus disertai transfer pengetahuan, akses dokumentasi, program riset, pengembangan talenta, dan kesempatan bagi perusahaan Indonesia membangun komponen.

Model pembiayaan dapat menggabungkan investasi negara, konsorsium BUMN, perguruan tinggi, industri, dan penyedia swasta. Pemerintah tidak harus mengoperasikan semuanya, tetapi harus menetapkan arsitektur nasional, standar interoperabilitas, prioritas penggunaan, dan jaminan kesinambungan.

Infrastruktur AI nasional harus memiliki jalur operasi pada beberapa keadaan:

- keadaan normal dengan kombinasi sumber daya lokal dan global;
- gangguan konektivitas internasional;
- penghentian layanan salah satu penyedia;
- pembatasan ekspor komponen;
- serangan terhadap rantai pasokan;
- lonjakan kebutuhan komputasi dalam krisis;
- kegagalan pusat data atau wilayah operasi.

Sovereign AI bukan sekadar model yang berbicara Bahasa Indonesia. Sovereign AI adalah ekosistem yang tetap dapat bekerja, diaudit, dipulihkan, dan dikembangkan oleh bangsa Indonesia.

7.8 KEPUTUSAN STRATEGIS BAB 7

AI dan rantai pasokan harus diperlakukan sebagai persoalan keamanan, ekonomi, industri, pendidikan, dan geopolitik sekaligus. Kebijakan yang hanya berorientasi pada pengadaan akan membuat Indonesia menjadi pengguna. Kebijakan yang membangun penguasaan pengetahuan akan menjadikan Indonesia pemain.

Keamanan Ketahanan Siber perlu menetapkan sepuluh keputusan strategis.

Pertama, **penggunaan AI harus diklasifikasikan berdasarkan risiko dan dampaknya**, bukan berdasarkan popularitas teknologi atau besarnya model.

Kedua, **AI boleh mempercepat analisis dan rekomendasi**, tetapi keputusan yang menyentuh hak warga, sanksi, pemutusan layanan kritikal, atribusi, dan operasi ofensif harus berada di bawah tanggung jawab manusia.

Ketiga, setiap **AI berisiko tinggi harus mempunyai tujuan**, pemilik, dokumentasi, validasi, pemantauan, jejak keputusan, mekanisme *override*, serta prosedur penghentian.

Keempat, **keamanan rantai pasokan** harus mencakup perangkat keras, *firmware*, perangkat lunak, pustaka, komputasi awan, API, model, data, pembaruan, integrator, identitas, dan tenaga pemeliharaan.

Kelima, **produk berisiko tinggi** harus mempunyai inventaris komponen, masa dukungan, riwayat perubahan, mekanisme pembaruan, kanal pelaporan kerentanan, dan rencana akhir dukungan.

Keenam, negara tidak boleh mewajibkan sumber terbuka atau *proprietary* secara membabi buta. Pemilihan harus didasarkan pada auditabilitas, kontrol, portabilitas, interoperabilitas, ketahanan, biaya siklus hidup, dan penguasaan kompetensi.

Ketujuh, **pemerintah harus membangun kapasitas** komputasi, pusat data, model, dataset, identitas, kriptografi, pusat evaluasi, dan SDM sebagai ekosistem AI nasional.

Kedelapan, **pengadaan teknologi strategis** harus mewajibkan transfer pengetahuan, dokumentasi, portabilitas data, standar terbuka, uji pemulihan, dan strategi penggantian pemasok.

Kesembilan, **ketergantungan harus dipetakan** sampai pemasok lapis kedua dan ketiga untuk sistem kritikal. Ketergantungan tersembunyi pada pustaka, layanan identitas, pembaruan, atau personel dapat lebih berbahaya daripada vendor utama.

Kesepuluh, setiap sistem strategis harus **mempunyai *sovereign exit strategy***. Strategi tersebut harus menjawab:

- bagaimana data diekspor;
- bagaimana format dikonversi;
- bagaimana model dipindahkan atau diganti;
- bagaimana sistem kembali ke operasi manual;
- bagaimana layanan dipulihkan;
- bagaimana akses vendor dicabut;
- bagaimana bukti dan log dipertahankan;
- bagaimana kompetensi tetap berada di Indonesia;
- bagaimana negara beroperasi apabila pemasok berhenti melayani.

Strategi keluar tidak boleh baru disusun ketika hubungan dengan vendor memburuk. Strategi keluar harus menjadi syarat sebelum kontrak ditandatangani dan diuji secara berkala selama sistem digunakan.

Jika data tidak dapat dipindahkan, negara bukan pemilik data. Jika sistem tidak dapat diaudit, negara bukan pengendali sistem. Jika layanan tidak dapat berjalan tanpa vendor, negara belum berdaulat secara teknologi.

RANGKUMAN BAB 7

Bagian	Risiko Strategis	Arah Kebijakan	Keputusan Negara
7.1 AI sebagai pedang bermata dua	AI memperkuat pertahanan sekaligus menurunkan biaya serangan	Gunakan AI untuk mempercepat analisis dengan batas penggunaan yang jelas	AI membantu manusia, bukan menggantikan akuntabilitas manusia
7.2 Human-in-the-loop	Persetujuan manusia dapat menjadi formalitas	Pastikan pengawas mempunyai kompetensi, informasi, waktu, dan kewenangan menolak	Larang otomatisasi penuh untuk keputusan yang menyentuh hak, sanksi, layanan kritikal, atribusi, dan operasi ofensif
7.3 Tata kelola risiko AI	Bias, halusinasi, manipulasi, dan model drift dapat merusak keputusan	Kelola tujuan, data, model, validasi, pemantauan, pencatatan, insiden, dan penghentian	Terapkan kewajiban berjenjang berdasarkan risiko dan dampak
7.4 Rantai pasokan digital	Kompromi dapat masuk melalui komponen, pembaruan, layanan, atau personel	Petakan seluruh dependensi dan tanggung jawab sepanjang rantai	Nilai pemasok berdasarkan transparansi, keamanan, keberlanjutan, dan kemampuan diganti
7.5 Transparansi komponen	Organisasi tidak mengetahui komponen yang harus diperbaiki	Gunakan inventaris komponen, SBOM, inventaris model, riwayat perubahan, dan masa dukungan	Transparansi harus berjenjang dan diikuti tindakan perbaikan
7.6 Sumber terbuka, tertutup, dan hibrida	Pilihan ideologis dapat menciptakan ketergantungan baru	Ukur auditabilitas, kontrol, portabilitas, interoperabilitas, kompetensi, dan ketahanan	Gunakan arsitektur yang menjaga kendali serta jalan keluar
7.7 Infrastruktur AI nasional	Ketergantungan pada komputasi, model, data, dan platform asing	Bangun ekosistem komputasi, pusat data, model, dataset, kriptografi, evaluasi, dan SDM	Pastikan layanan strategis tetap berjalan ketika koneksi atau pemasok terganggu
7.8 Keputusan strategis	Kontrak teknologi dapat menghilangkan kendali negara	Wajibkan sovereign exit strategy sejak awal pengadaan	**Data dapat dipindahkan, sistem dapat diganti, model dapat diaudit, dan layanan dapat dipulihkan**

REFERENSI UTAMA BAB 7

- Onno W. Purbo, *AI dalam Cyber Security*, 2025.
- Onno W. Purbo, *Strategic Blueprint: AI Integration in the Corporate SOC*, 2026.
- Onno W. Purbo, *Strategi R&D IT Mandiri untuk Kedaulatan Teknologi Republik*, 2025.
- Onno W. Purbo, *Buat AI Sendiri dengan Open Source*, 2026.
- Surat Edaran Menteri Komunikasi dan Informatika Nomor 9 Tahun 2023 tentang Etika Kecerdasan Artifisial.
- NIST, *Artificial Intelligence Risk Management Framework 1.0*, 2023.
- NIST SP 800-161 Rev. 1, *Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*, 2022.
- NIST SP 800-218, *Secure Software Development Framework Version 1.1*, 2022.
- European Union, Regulation (EU) 2024/1689, *Artificial Intelligence Act*.
- European Union, Regulation (EU) 2024/2847, *Cyber Resilience Act*.
- ISO/IEC 42001:2023, *Artificial Intelligence Management System*.

BAB 8 - MEMBANGUN MANUSIA, BUKAN SEKADAR MENERBITKAN SERTIFIKAT

Teknologi dapat dibeli, tetapi **kemampuan untuk memahami, mengendalikan, memperbaiki, dan mengembangkannya tidak dapat diimpor secara instan**. Kedaulatan siber pada akhirnya tidak ditentukan oleh banyaknya perangkat keamanan yang dimiliki negara, melainkan oleh mutu manusia yang mengambil keputusan di belakangnya.

Indonesia tidak cukup memiliki operator yang dapat menjalankan produk asing. Negara membutuhkan pembuat kebijakan yang memahami risiko teknologi, arsitek yang mampu merancang sistem, analis yang dapat membaca serangan, pemimpin yang tetap tenang ketika krisis terjadi, serta peneliti dan pengembang yang sanggup menciptakan teknologi sendiri.

Karena itu, strategi sumber daya manusia siber harus bergeser dari logika administratif menuju logika kemampuan nasional. **Sertifikat penting, tetapi sertifikat bukan tujuan akhir.** Ukuran keberhasilan yang sesungguhnya adalah apakah Indonesia mampu menjaga layanan kritikal, memulihkan insiden, mengaudit teknologi, mengurangi ketergantungan, dan membangun solusi yang dikuasai sendiri.

8.1 Kesenjangan Talenta sebagai Risiko Kedaulatan

Kesenjangan talenta siber bukan semata-mata persoalan ketenagakerjaan. Ia merupakan risiko strategis terhadap kesinambungan pemerintahan, keamanan ekonomi, pertahanan negara, dan kedaulatan teknologi.

Sebuah kementerian dapat membeli sistem pemantauan paling mahal. Namun, apabila tidak ada tenaga nasional yang memahami arsitektur, konfigurasi, data, asumsi keamanan, dan keterbatasannya, kementerian tersebut hanya menjadi pengguna. Ketika muncul gangguan, perubahan lisensi, penghentian dukungan, konflik geopolitik, atau kegagalan pemasok, kendali sebenarnya tetap berada di luar organisasi.

Ketergantungan teknologi selalu dimulai dari ketergantungan pengetahuan.

Masalahnya bukan apakah teknologi berasal dari dalam atau luar negeri. Indonesia tetap perlu menggunakan teknologi global dan bekerja sama dengan mitra internasional. Persoalan strategisnya adalah apakah tenaga Indonesia:

- memahami cara kerja teknologi tersebut;
- dapat menguji klaim keamanan pemasok;
- memiliki akses yang memadai untuk melakukan audit;
- mampu mengoperasikan sistem dalam keadaan krisis;
- dapat memindahkan data dan layanan ke sistem lain;
- mampu memperbaiki atau mengganti komponen bermasalah; dan
- dapat mengembangkan alternatif nasional apabila ketergantungan menjadi tidak dapat diterima.

Dalam referensi internal Onno W. Purbo mengenai pembangunan *Security Operations Center* berbasis perangkat terbuka, penguasaan teknologi tidak berhenti pada pemasangan perangkat. Kompetensi mencakup analisis bukti, penilaian dampak, manajemen kasus, penyusunan kronologi, komunikasi eksekutif, dan pengambilan pelajaran setelah insiden. Ini memperlihatkan bahwa pusat operasi keamanan bukan kumpulan layar dan perangkat lunak, melainkan **organisasi manusia yang dibantu teknologi**.

Keamanan Ketahanan Siber karena itu perlu menempatkan pembangunan manusia sebagai unsur ketahanan nasional, bukan sebagai urusan pelatihan tambahan. Setiap investasi strategis teknologi harus mempunyai komponen pengembangan kemampuan nasional, alih pengetahuan, dokumentasi, pengkaderan tenaga pengganti, dan pengurangan ketergantungan terhadap individu maupun pemasok tertentu.

Pengadaan yang hanya menghasilkan barang akan menambah aset. Pengadaan yang menghasilkan pengetahuan akan menambah kedaulatan.

8.2 Peta Peran dan Kompetensi Nasional

Indonesia membutuhkan satu bahasa nasional untuk menjelaskan pekerjaan siber. Selama setiap kementerian, perusahaan, kampus, dan lembaga sertifikasi menggunakan nama jabatan serta standar kompetensi yang berbeda, negara tidak akan memiliki gambaran yang akurat mengenai tenaga yang tersedia dan kemampuan yang masih kurang.

Kerangka nasional sebaiknya tidak dimulai dari nama sertifikat, tetapi dari tiga pertanyaan: **pekerjaan apa yang harus dilakukan, kemampuan apa yang dibutuhkan, dan tingkat tanggung jawab apa yang menyertainya?**

Pendekatan ini sejalan dengan *NICE Workforce Framework for Cybersecurity* dari NIST, yang menggunakan bahasa bersama untuk mendeskripsikan pekerjaan siber beserta pengetahuan dan keterampilan yang diperlukan. Kerangka tersebut dapat digunakan untuk penyusunan pendidikan, perekrutan, pengembangan karier, serta pemetaan kapasitas tenaga kerja. Indonesia tidak perlu menyalinnya, tetapi dapat memanfaatkannya sebagai pembanding untuk membangun kerangka yang sesuai dengan hukum, kebutuhan sektor, bahasa, dan kondisi nasional. (NIST NICE Framework Resource Center)

Peta kompetensi nasional sekurang-kurangnya harus mencakup beberapa rumpun peran.

Pertama, **pengambil kebijakan dan pemimpin pemerintahan**. Mereka tidak harus menjadi ahli teknis, tetapi harus mampu memahami risiko strategis, menetapkan prioritas, membedakan fakta dari spekulasi, menilai konsekuensi kebijakan, dan mengambil keputusan dalam ketidakpastian.

Kedua, **pemimpin tata kelola dan risiko**. Kelompok ini menerjemahkan ancaman teknis menjadi risiko terhadap layanan, keuangan, keselamatan publik, reputasi, dan tujuan organisasi. Mereka menjembatani ruang mesin dengan ruang rapat.

Ketiga, **arsitek dan perancang sistem**. Mereka memastikan keamanan tidak ditempelkan setelah sistem selesai, tetapi menjadi bagian dari arsitektur, pemilihan komponen, identitas, jaringan, data, pencadangan, interoperabilitas, dan strategi pemulihan.

Keempat, **analis pusat operasi keamanan, responder insiden, dan tenaga forensik**. Mereka harus mampu membedakan peristiwa, peringatan, insiden, dan kasus; memvalidasi bukti; menentukan prioritas berdasarkan dampak; mengelola kronologi; serta menjaga integritas barang bukti.

Kelima, **auditor dan penguji keamanan**. Mereka dibutuhkan untuk memberikan penilaian yang independen, bukan sekadar membenarkan laporan penyedia atau organisasi yang diperiksa.

Keenam, **pengembang perangkat lunak dan insinyur platform yang aman**. Sistem negara tidak akan aman apabila keamanan hanya menjadi tanggung jawab unit keamanan. Pengembang, administrator, pengelola data, dan tenaga operasi harus memahami kewajibannya sepanjang siklus hidup teknologi.

Ketujuh, **peneliti, pendidik, dan pengembang teknologi nasional**. Mereka membangun pengetahuan jangka panjang, menemukan kelemahan, menciptakan metode baru, dan memastikan Indonesia tidak selamanya menjadi konsumen.

Kedelapan, **pemimpin krisis siber**. Ini merupakan kompetensi khusus yang menggabungkan pemahaman teknis, hukum, komunikasi publik, koordinasi lintas lembaga, dan pengambilan keputusan di bawah tekanan.

Pemetaan tersebut harus diterjemahkan menjadi matriks nasional yang menghubungkan peran, tugas, pengetahuan, keterampilan, pengalaman, otoritas, dan tingkat tanggung jawab. Dengan matriks ini, negara dapat mengetahui bukan hanya jumlah tenaga siber, tetapi **kemampuan nyata yang tersedia di setiap sektor dan wilayah**.

8.3 Sertifikasi Bukan Pengganti Pengalaman

Sertifikasi mempunyai fungsi penting. Ia memberikan ukuran awal, membangun bahasa bersama, membantu proses seleksi, dan menetapkan batas kompetensi minimum untuk pekerjaan tertentu. Namun, sertifikasi hanya mengukur bagian tertentu dari kemampuan seseorang pada suatu waktu.

> **Lulus ujian tidak otomatis berarti mampu menangani krisis.**

Insiden nyata jarang hadir dalam bentuk soal dengan empat pilihan jawaban. Informasi sering tidak lengkap, bukti dapat saling bertentangan, tekanan publik meningkat, pimpinan meminta kepastian, sementara keputusan harus dibuat sebelum seluruh fakta diketahui. Dalam situasi seperti ini, pengalaman, disiplin berpikir, kemampuan berkomunikasi, dan integritas menjadi sama pentingnya dengan pengetahuan teknis.

Kompetensi karena itu perlu dinilai melalui kombinasi:

- pengetahuan yang teruji;
- pengalaman menjalankan fungsi yang relevan;
- portofolio pekerjaan yang dapat diverifikasi;
- kinerja dalam simulasi atau latihan;
- kemampuan menjelaskan risiko kepada pengambil keputusan;
- kualitas keputusan ketika menghadapi informasi yang tidak lengkap; dan
- rekam etika serta kepatuhan terhadap hukum.

Portofolio tidak berarti membuka rahasia organisasi atau memamerkan data insiden. Portofolio dapat berbentuk rancangan arsitektur yang telah dianonimkan, analisis kasus simulasi, kontribusi perangkat lunak, tulisan teknis, bahan pembelajaran, metodologi audit, laporan penelitian, atau dokumentasi perbaikan proses.

Untuk jabatan berisiko tinggi, proses penilaian harus memeriksa kemampuan teknis sekaligus kemampuan mengambil keputusan. Seorang calon pemimpin respons insiden, misalnya, perlu dinilai berdasarkan kemampuannya menentukan prioritas, menjaga bukti, mengkoordinasikan organisasi, menjelaskan ketidakpastian, dan memilih kapan layanan perlu dibatasi atau dipulihkan.

Referensi internal Onno W. Purbo tentang pengadaan teknologi informasi menekankan penggunaan matriks peran–kompetensi–sertifikat–pengalaman. Pendekatan ini penting karena persyaratan sertifikasi yang tidak berhubungan langsung dengan pekerjaan dapat berubah menjadi pagar administratif yang menyaring orang berdasarkan kemampuan membayar ujian, bukan kemampuan menyelesaikan persoalan.

> **Sertifikat harus menjadi salah satu alat pembuktian kompetensi, bukan mata uang tunggal profesi siber.**

8.4 Integrasi dengan Sistem Sertifikasi Nasional

Indonesia tidak perlu membangun sistem sertifikasi siber yang terpisah dari keseluruhan sistem kompetensi nasional. Keamanan Ketahanan Siber sebaiknya memberi arah agar kebutuhan kompetensi siber diintegrasikan dengan SKKNI, KKNI, BNSP, lembaga sertifikasi profesi, lembaga pendidikan, serta kebutuhan nyata pemerintah dan industri.

Integrasi tidak berarti penyeragaman secara berlebihan. Bidang siber berubah cepat, sedangkan pembaruan standar formal memerlukan waktu. Sistem nasional harus cukup stabil untuk menjaga mutu, tetapi cukup adaptif untuk mengakui teknologi, pekerjaan, dan metode baru.

Prinsip yang perlu ditetapkan adalah **kesetaraan hasil kompetensi**, bukan keseragaman jalur. Seseorang dapat memperoleh kompetensi melalui pendidikan formal, pelatihan vokasi, pengalaman kerja, pembelajaran mandiri, komunitas, pendidikan kedinasan, sertifikasi nasional, atau sertifikasi internasional. Selama kompetensinya dapat diuji secara objektif, jalur yang berbeda tidak boleh menjadi alasan untuk menutup akses profesi.

Sertifikasi internasional dapat diakui apabila relevan, mutakhir, dapat diverifikasi, dan sesuai dengan kebutuhan pekerjaan. Namun, negara tidak boleh menyerahkan definisi tenaga kompeten kepada perusahaan sertifikasi asing. Sebaliknya, sertifikasi nasional juga tidak boleh diwajibkan hanya untuk membentuk monopoli lembaga tertentu.

Keamanan Ketahanan Siber perlu menerapkan prinsip-prinsip berikut:

Pertama, **persyaratan kompetensi** harus terkait langsung dengan risiko dan tanggung jawab peran.

Kedua, **sertifikasi wajib** hanya diterapkan pada fungsi yang kegagalannya dapat menimbulkan dampak serius.

Ketiga, **bukti pengalaman dan kompetensi** yang setara harus dapat diakui melalui mekanisme yang transparan.

Keempat, **lembaga penilai** harus independen, diaudit, dan tidak mempunyai konflik kepentingan.

Kelima, **standar harus dievaluasi** secara berkala bersama pemerintah, industri, perguruan tinggi, komunitas profesi, dan pengguna tenaga kerja.

Keenam, **biaya sertifikasi** tidak boleh menjadi penghalang bagi talenta daerah, aparatur tingkat bawah, mahasiswa, atau tenaga berpengalaman yang tidak memiliki kemampuan finansial.

Ketujuh, **pemerintah** harus menyediakan mekanisme keberatan dan pengakuan pembelajaran lampau.

Yang harus distandarkan adalah mutu kemampuan, bukan merek sertifikat.

8.5 Penerapan Bertahap

Kewajiban sertifikasi yang diberlakukan sekaligus dapat menghasilkan dua dampak yang tidak diinginkan: kekurangan tenaga secara artifisial dan kenaikan harga sertifikasi tanpa peningkatan kompetensi yang sebanding.

Penerapan karena itu harus dilakukan secara bertahap berdasarkan tingkat risiko peran, ketersediaan tenaga, kesiapan lembaga pendidikan, dan kondisi wilayah.

> Tahap pertama adalah **membangun peta kebutuhan** serta data dasar. Negara perlu mengetahui peran apa yang tersedia, di lembaga mana, pada tingkat kompetensi berapa, dan di wilayah mana kesenjangan paling serius terjadi. Pendataan harus berorientasi pada kemampuan, bukan hanya jumlah pegawai yang ditempatkan dalam unit siber.
>
> Tahap kedua adalah **menetapkan kompetensi minimum** untuk peran dengan konsekuensi paling tinggi, seperti pemimpin respons insiden nasional, arsitek sistem kritikal, pengelola identitas strategis, tenaga forensik yang menangani pembuktian, dan auditor keamanan infrastruktur kritikal.
>
> Tahap ketiga adalah **memperluas penerapan** kepada peran operasional lain setelah kapasitas pendidikan, asesor, dan lembaga sertifikasi mencukupi. Pada tahap ini, pemerintah perlu membiayai pelatihan dan penilaian bagi institusi yang belum mampu, terutama pemerintah daerah dan penyelenggara layanan publik dengan sumber daya terbatas.
>
> Tahap keempat adalah **membangun pembaruan kompetensi berkelanjutan**. Sertifikasi tidak boleh berlaku seolah-olah pengetahuan tidak pernah berubah. Pembaruan sebaiknya dapat dipenuhi melalui pengalaman kerja, pendidikan berkelanjutan, latihan, penelitian, pengajaran, kontribusi profesional, dan ujian ulang apabila diperlukan.

Selama masa transisi, organisasi dapat menggunakan tim gabungan, supervisi tenaga senior, pengakuan pengalaman, atau pemenuhan bertahap. Akan tetapi, masa transisi harus mempunyai batas waktu, sasaran peningkatan, dan evaluasi berkala.

Pendekatan ini harus menghindari dua ekstrem. Negara tidak boleh menunggu seluruh daerah siap sebelum menetapkan standar. Namun, negara juga tidak boleh menetapkan kewajiban yang mustahil dipenuhi lalu menghukum daerah karena kapasitas yang belum pernah dibangun pemerintah pusat.

> **Standar nasional harus tegas mengenai tujuan, tetapi adil mengenai jalan dan waktu pencapaiannya.**

8.6 Akademi Siber Nasional dan Jaringan Daerah

Indonesia memerlukan Akademi Siber Nasional, tetapi akademi tersebut tidak seharusnya menjadi gedung baru yang memusatkan seluruh kegiatan di Jakarta. Yang dibutuhkan adalah **sistem orkestrasi pembelajaran nasional**.

Akademi Siber Nasional sebaiknya berfungsi sebagai jaringan yang menghubungkan perguruan tinggi, politeknik, SMK, lembaga pelatihan, BSSN, kementerian, TNI, Polri, pemerintah daerah, badan usaha, komunitas teknologi, dan organisasi profesi. Pusat nasional menetapkan arah, menjaga mutu, menyediakan sumber belajar bersama, membangun fasilitas latihan, dan mengkoordinasikan pertukaran pengajar. Pelaksanaan pendidikan tersebar di berbagai daerah sesuai kebutuhan serta kekuatan lokal.

Wilayah yang memiliki industri energi dapat memperkuat kompetensi keamanan sistem industri. Daerah dengan pusat data dan ekosistem digital dapat mengembangkan keamanan komputasi awan. Wilayah dengan perguruan tinggi kuat dapat menjadi pusat riset kriptografi, kecerdasan artifisial, forensik, atau perangkat keras. Dengan cara ini, pembangunan talenta sekaligus membangun simpul kemampuan nasional.

Kurikulum juga tidak boleh berhenti pada penggunaan produk. Pendidikan harus mengajarkan fondasi jaringan, sistem operasi, pemrograman, data, arsitektur, kriptografi, tata kelola, hukum, ekonomi keamanan, komunikasi krisis, etika, dan kepemimpinan. Produk dapat berubah; fondasi pengetahuan memungkinkan seseorang memahami perubahan tersebut.

Sekolah dan perguruan tinggi perlu mempunyai jalur pembelajaran yang terhubung dengan pengalaman kerja. Pemerintah dan industri dapat menyediakan magang, program mentor, laboratorium simulasi, latihan lintas sektor, residensi peneliti, serta pertukaran tenaga. NIST juga memasukkan *apprenticeship*, kompetisi, dan pembelajaran berbasis kerja sebagai penggunaan penting kerangka tenaga siber. (NIST NICE Framework Resource Center)

Latihan nasional harus menilai koordinasi manusia, bukan sekadar keberhasilan teknis. Skenario dapat menguji bagaimana pimpinan menerima informasi, bagaimana analis menaikkan eskalasi, bagaimana regulator dan operator berbagi informasi, bagaimana keputusan didokumentasikan, serta bagaimana pemerintah berkomunikasi kepada masyarakat.

Akademi juga harus menyediakan jalur bagi pimpinan tinggi negara. Menteri, kepala badan, direksi, kepala daerah, dan pimpinan sektor kritikal memerlukan pendidikan singkat yang berfokus pada skenario, risiko, kewenangan, dan kualitas keputusan—bukan pelatihan teknis yang tidak relevan dengan perannya.

> **Talenta nasional tidak akan lahir dari satu institusi. Ia lahir dari ekosistem yang memungkinkan pengetahuan bergerak dari pusat ke daerah, dari kampus ke industri, dan dari pengalaman lapangan kembali ke ruang pendidikan.**

8.7 Retensi, Jalur Karier, dan Mobilitas Talenta

Mendidik tenaga siber tanpa strategi retensi sama dengan mengisi wadah yang bocor. Negara dapat menghasilkan lulusan dan pemegang sertifikat, tetapi tetap kehilangan kapasitas apabila jalur karir tidak jelas, remunerasi tidak kompetitif, pekerjaan administratif mendominasi, dan tenaga terbaik tidak memperoleh ruang untuk berkembang.

Tidak seluruh perbedaan remunerasi dengan sektor swasta dapat ditutup. Namun, negara dapat menawarkan nilai lain: misi publik, akses terhadap persoalan strategis, kesempatan belajar, jalur kepakaran, mobilitas lintas lembaga, pengakuan profesional, dan kebebasan melakukan penelitian yang bertanggung jawab.

Aparatur teknis tidak boleh dipaksa meninggalkan keahliannya dan beralih sepenuhnya menjadi pejabat struktural hanya untuk memperoleh kemajuan karier. Negara membutuhkan jalur kepakaran yang memungkinkan arsitek, analis, peneliti, auditor, dan responder mencapai jenjang tinggi tanpa berhenti melakukan pekerjaan substantif.

Mobilitas juga perlu diperluas. Tenaga siber dapat menjalani penugasan sementara antara pemerintah pusat, daerah, BUMN, universitas, dan industri dengan pengaturan konflik kepentingan yang ketat. Mobilitas seperti ini mempercepat penyebaran pengetahuan, mempertemukan perspektif, serta mencegah kemampuan kritikal terkurung di satu lembaga.

Pemerintah perlu membangun korps cadangan keahlian siber yang dapat dimobilisasi secara sah dalam krisis nasional. Anggotanya dapat berasal dari akademisi, industri, komunitas, tenaga purna tugas, atau diaspora. Namun, mobilisasi harus didasarkan pada mandat yang jelas, pemeriksaan kompetensi, perlindungan kerahasiaan, rantai komando, dan batas tanggung jawab.

Perhatian khusus perlu diberikan kepada peneliti keamanan. Peneliti yang menemukan kerentanan dan melaporkannya dengan itikad baik membantu negara memperbaiki kelemahan sebelum dimanfaatkan pihak lain. Organisasi pemerintah dan operator kritikal perlu mempunyai kebijakan pengungkapan kerentanan yang menjelaskan ruang pengujian yang diizinkan, saluran laporan, tenggat respons, larangan penyalahgunaan data, serta perlindungan bagi peneliti yang mematuhi ketentuan.

Prinsip tersebut sejalan dengan pendekatan kebijakan pengungkapan kerentanan CISA, yang mendorong tersedianya proses resmi bagi peneliti untuk melaporkan kelemahan keamanan kepada organisasi. Perlindungan tidak berlaku bagi tindakan pemerasan, perusakan, pengambilan data berlebihan, atau eksploitasi di luar kebutuhan pembuktian. **Itikad baik harus dilindungi, tetapi tidak boleh menjadi dalih untuk menghapus tanggung jawab.**

Retensi akhirnya bukan hanya mempertahankan orang. Retensi adalah memastikan pengetahuan tidak ikut pergi ketika seseorang pindah, pensiun, atau kontraknya berakhir. Dokumentasi, pendampingan, rotasi, pasangan tenaga senior–junior, dan pengelolaan pengetahuan harus menjadi bagian dari tata kelola setiap fungsi kritikal.

8.8 Keputusan Strategis Bab 8

Keamanan Ketahanan Siber perlu menetapkan pembangunan kompetensi siber sebagai kewajiban strategis negara dan penyelenggara fungsi kritikal. Namun, undang-undang tidak seharusnya mencantumkan daftar sertifikat atau merek tertentu yang cepat usang. Norma pokok harus berisi prinsip, tanggung jawab, tata kelola, mekanisme pengakuan kompetensi, serta kewajiban evaluasi.

Keputusan strategis pertama adalah membentuk **Peta Peran dan Kompetensi Siber Nasional** sebagai bahasa bersama bagi pemerintah, industri, pendidikan, dan profesi. Peta ini harus berbasis pekerjaan dan risiko, bukan sekadar nama jabatan.

Keputusan kedua adalah **mengintegrasikan kebutuhan siber** dengan sistem kompetensi nasional sambil mengakui pendidikan, sertifikasi, pengalaman, portofolio, dan pembelajaran lampau sebagai jalur pembuktian yang sah.

Keputusan ketiga adalah **menerapkan kewajiban sertifikasi** secara proporsional dan bertahap. Sertifikasi wajib diprioritaskan untuk fungsi yang mempunyai dampak besar terhadap keselamatan, layanan kritikal, hak warga, pembuktian hukum, dan keamanan nasional.

Keputusan keempat adalah **membangun Akademi Siber Nasional** sebagai jaringan pembelajaran, penelitian, latihan, dan pertukaran tenaga yang hadir di seluruh Indonesia—bukan sebagai satu institusi yang menyedot seluruh sumber daya ke pusat.

Keputusan kelima adalah **membentuk jalur karir** kepakaran, mobilitas lintas sektor, korps cadangan, dan strategi retensi pengetahuan. Negara harus mampu mempertahankan kemampuan, bukan sekadar mempertahankan formasi pegawai.

Keputusan keenam adalah **melindungi penelitian keamanan** yang dilakukan dengan itikad baik melalui mekanisme *coordinated vulnerability disclosure*, tanpa memberi kekebalan terhadap perusakan, pemerasan, atau penyalahgunaan data.

Keputusan ketujuh adalah **mengikat pengadaan teknologi strategis** dengan alih pengetahuan, dokumentasi, pelatihan, kemampuan audit, ketersediaan tenaga pengganti, dan pengurangan ketergantungan pemasok.

Keputusan kedelapan adalah **mengganti indikator keberhasilan** yang dangkal. Jumlah pelatihan, peserta, lulusan, dan sertifikat tetap dapat dicatat, tetapi tidak boleh menjadi ukuran utama.

Ukuran akhir strategi SDM siber adalah kapasitas operasional nasional: seberapa cepat insiden ditemukan, seberapa tepat keputusan dibuat, seberapa baik layanan dipulihkan, seberapa mandiri teknologi dapat diaudit dan dikembangkan, serta seberapa banyak pengetahuan tetap berada di Indonesia.

RANGKUMAN BAB 8

Bidang strategis	Masalah utama	Arah kebijakan	Ukuran keberhasilan
Kedaulatan talenta	Teknologi dibeli tanpa penguasaan pengetahuan	Setiap investasi strategis wajib membangun kemampuan nasional dan alih pengetahuan	Sistem dapat diaudit, diperbaiki, dipulihkan, dan diganti oleh tenaga nasional
Peta kompetensi	Nama jabatan dan standar berbeda antar organisasi	Bentuk Peta Peran dan Kompetensi Siber Nasional berbasis tugas dan risiko	Kebutuhan serta kesenjangan kompetensi dapat dipetakan per sektor dan wilayah
Sertifikasi	Sertifikat diperlakukan sebagai satu-satunya bukti kemampuan	Gunakan kombinasi sertifikasi, pengalaman, portofolio, simulasi, dan rekam etika	Tenaga terpilih terbukti mampu menjalankan pekerjaan nyata
Sistem nasional	Risiko monopoli dan tumpang tindih skema	Integrasikan dengan SKKNI, KKNI, BNSP, LSP, pendidikan, serta kebutuhan industri	Standar diakui lintas sektor tanpa bergantung pada satu merek sertifikat
Penerapan	Kewajiban serentak dapat menciptakan kelangkaan semu	Terapkan bertahap menurut risiko peran, kesiapan wilayah, dan ketersediaan tenaga	Kepatuhan meningkat tanpa melumpuhkan layanan atau menyingkirkan talenta daerah
Pendidikan	Pengembangan talenta terpusat dan terlalu berorientasi produk	Bangun Akademi Siber Nasional sebagai jaringan pusat–daerah	Tersedia simpul kompetensi khusus di berbagai wilayah Indonesia
Karier dan retensi	Tenaga terbaik pergi dan pengetahuan ikut hilang	Sediakan jalur kepakaran, mobilitas, remunerasi layak, mentor, dan dokumentasi	Kompetensi kritikal bertahan melampaui pergantian orang dan kontrak
Penelitian keamanan	Peneliti beritikad baik menghadapi ketidakpastian hukum	Bentuk kebijakan pengungkapan kerentanan dan perlindungan bersyarat	Kerentanan dilaporkan lebih dini serta diperbaiki secara bertanggung jawab
Pengukuran nasional	Keberhasilan dinilai dari jumlah sertifikat	Ukur kesiapan, mutu keputusan, pemulihan, inovasi, dan kemandirian teknologi	**Indonesia mampu menangani insiden dan membangun teknologinya sendiri**

Penutup

> **Negara yang hanya mempunyai teknologi akan selalu bergantung kepada pihak yang memahami teknologi itu. Negara yang mempunyai manusia berpengetahuan dapat memilih, mengubah, memperbaiki, bahkan menciptakan teknologinya sendiri.**

Itulah inti kedaulatan siber. Bukan menutup diri dari dunia, melainkan memastikan Indonesia bekerja sama dengan dunia dari posisi mampu, sadar, dan berdaya tawar. Sertifikat dapat menjadi pintu masuk, tetapi manusia yang teruji, beretika, terus belajar, dan mampu membangun adalah benteng yang sebenarnya.

Referensi Bab 8

- Onno W. Purbo, “Open Source SOC Mastery: Membangun Security Operations Center Modern dengan Tools Gratis”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo, “Panduan Praktis Pengadaan Barang dan Jasa Bidang IT”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo, “Strategic Blueprint AI Integration in Corporate SOC”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo, “CEH Mastery: AI-Assisted OSINT”, 2026. Referensi internal ChatGPT Library.
- National Institute of Standards and Technology, “NICE Workforce Framework for Cybersecurity”. (NIST)
- European Union Agency for Cybersecurity, “European Cybersecurity Skills Framework”. (ENISA)
- Cybersecurity and Infrastructure Security Agency, “Vulnerability Disclosure Policy Platform”. (CISA)

BAB 9 - NEGARA YANG KUAT HARUS TETAP TERBATAS OLEH HUKUM

Tujuan bab: memastikan pengawasan teknis dan sanksi memperkuat keamanan tanpa mengorbankan privasi, kebebasan, serta prinsip negara hukum.

Keamanan siber membutuhkan negara yang mampu bertindak. Ketika rumah sakit berhenti beroperasi, jaringan energi terganggu, sistem keuangan diserang, atau data strategis dicuri, pemerintah tidak boleh menjadi penonton. Negara harus dapat meminta informasi, melakukan pemeriksaan, mengoordinasikan pemulihan, dan menjatuhkan sanksi.

Namun, kemampuan teknis yang besar membawa risiko kekuasaan yang besar pula. Sistem yang dibangun untuk membaca pola serangan dapat pula digunakan untuk membaca kehidupan warga. Kewenangan yang semula ditujukan menghadapi keadaan darurat dapat berubah menjadi praktik rutin. Data yang dikumpulkan untuk satu tujuan dapat digunakan kembali untuk tujuan lain tanpa diketahui pemiliknya.

Karena itu, pertanyaan strategisnya bukan apakah negara boleh mempunyai kewenangan pengawasan. Pertanyaannya adalah: **kapan kewenangan itu dapat digunakan, terhadap siapa, untuk tujuan apa, selama berapa lama, dengan data apa, siapa yang memberikan izin, dan siapa yang memeriksa penyalahgunaannya?**

TOR RDPU Keamanan Ketahanan Siber secara tepat menempatkan proporsionalitas sanksi, prinsip *ultimum remedium*, perlindungan privasi, hak atas informasi, dan kebebasan berekspresi sebagai persoalan yang harus diperdalam. Keamanan Ketahanan Siber harus memperkuat negara dalam menghadapi ancaman, tetapi tidak boleh menciptakan kekuasaan siber yang berada di luar hukum.

> **Negara yang kuat bukan negara yang dapat melihat semuanya. Negara yang kuat adalah negara yang mengetahui batas tentang apa yang boleh dilihat, kapan boleh melihatnya, dan bagaimana mempertanggungjawabkannya.**

9.1 Dilema Keamanan dan Kebebasan

Keamanan dan kebebasan sering digambarkan sebagai dua kepentingan yang selalu bertentangan. Gambaran tersebut terlalu sederhana. Masyarakat tidak dapat menikmati kebebasan ketika layanan publik lumpuh, identitas dicuri, sistem keuangan terganggu, atau infrastruktur kritikal dikuasai penyerang. Sebaliknya, keamanan kehilangan makna apabila untuk memperolehnya negara harus membangun pengawasan permanen terhadap warga.

Tujuan kebijakan bukan memilih keamanan atau kebebasan. Tujuannya adalah **membangun keamanan yang melindungi kebebasan**.

Dalam operasi siber, negara membutuhkan data untuk memperoleh *situational awareness*. Data tersebut dapat berupa informasi kerentanan, alamat jaringan, identitas aset, catatan aktivitas sistem, indikator kompromi, pola komunikasi mesin, kronologi insiden, dan informasi mengenai teknik serangan. Tanpa data yang memadai, negara akan bergerak dalam kegelapan.

Masalah muncul ketika batas antara data teknis dan data tentang manusia menjadi kabur. Alamat jaringan dapat dihubungkan dengan perangkat tertentu. Catatan autentikasi dapat menunjukkan aktivitas pegawai. Metadata komunikasi dapat memperlihatkan hubungan antara pihak. Lokasi, waktu, identitas perangkat, dan pola akses yang digabungkan dapat menghasilkan gambaran rinci mengenai perilaku seseorang, meskipun isi komunikasinya tidak dibaca.

Karena itu, anggapan bahwa metadata selalu tidak sensitif adalah keliru. **Risiko privasi tidak hanya ditentukan oleh satu potongan data, tetapi juga oleh kemampuan negara menghubungkan banyak potongan data menjadi profil seseorang.**

Keamanan Ketahanan Siber harus membedakan paling sedikit empat kategori informasi:

1. Data teknis agregat yang tidak mengidentifikasi individu.
2. Data teknis yang dapat dikaitkan dengan perangkat atau organisasi.
3. Data pribadi yang dapat mengidentifikasi atau membuat seseorang dapat diidentifikasi.
4. Isi komunikasi dan data pribadi spesifik yang mempunyai tingkat sensitivitas tinggi.

Semakin dekat data tersebut kepada identitas, perilaku, isi komunikasi, kesehatan, biometrik, keuangan, atau kehidupan pribadi seseorang, semakin ketat dasar hukum, otorisasi, pembatasan penggunaan, dan pengawasannya.

Undang-Undang Nomor 27 Tahun 2022 menempatkan pelindungan data pribadi sebagai upaya untuk menjamin hak konstitusionalional subjek data. Undang-undang tersebut juga mengatur hak subjek data, pemrosesan, kewajiban pengendali dan prosesor, transfer, sanksi, serta larangan penggunaan data pribadi. Keamanan Ketahanan Siber tidak boleh membangun jalur pemrosesan data yang mengabaikan kerangka tersebut. (UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi)

Pengecualian untuk kepentingan keamanan negara, pertahanan, atau penegakan hukum tidak boleh ditulis sebagai pengecualian tanpa batas. Pengecualian harus tetap mempunyai tujuan tertentu, otoritas yang jelas, kebutuhan yang dapat dibuktikan, pembatasan waktu, pengamanan data, dan mekanisme pertanggungjawaban.

> **Pengecualian terhadap suatu kewajiban bukan pengecualian terhadap prinsip negara hukum.**

9.2 Batas Kewenangan Pemantauan dan Audit

Istilah “pemantauan”, “pemeriksaan”, “audit teknis”, “akses data”, dan “pengumpulan informasi” tidak boleh digunakan secara bergantian. Setiap tindakan mempunyai tingkat intrusi, tujuan, risiko, dan kebutuhan otorisasi yang berbeda.

Pemantauan keamanan jaringan milik pemerintah berbeda dari akses terhadap jaringan perusahaan. Pemeriksaan kepatuhan berbeda dari penyelidikan insiden. Permintaan laporan berbeda dari pengambilan data. Analisis indikator serangan berbeda dari pembacaan isi komunikasi. Audit konfigurasi berbeda dari penyitaan perangkat.

Jika seluruh tindakan tersebut diletakkan di bawah istilah luas “pengawasan siber”, Keamanan Ketahanan Siber akan menciptakan kewenangan yang sulit dibatasi dan mudah diperluas melalui interpretasi.

Keamanan Ketahanan Siber perlu membentuk **matriks kewenangan berdasarkan tingkat intrusi**. Setiap tindakan harus menjawab unsur berikut:

Objek. Sistem, jaringan, data, perangkat, atau organisasi apa yang dapat diperiksa?

Tujuan. Apakah tindakan dilakukan untuk pencegahan, pemeriksaan kepatuhan, respons insiden, pemulihan, penyelidikan administratif, penyidikan pidana, intelijen, atau pertahanan?

Jenis data. Apakah yang diakses berupa data agregat, metadata, log teknis, data pribadi, isi komunikasi, atau data rahasia?

Dasar pemicu. Apakah tindakan dilakukan secara rutin, berdasarkan indikator risiko, laporan insiden, bukti awal pelanggaran, atau status krisis tertentu?

Pejabat pemberi izin. Siapa yang dapat menyetujui tindakan tersebut dan pada tingkat jabatan apa?

Pelaksana. Lembaga mana yang berwenang dan tenaga dengan kompetensi apa yang boleh melaksanakannya?

Durasi. Berapa lama pemantauan atau akses dapat berlangsung?

Penyimpanan. Di mana data disimpan, siapa yang dapat mengaksesnya, dan bagaimana integritasnya dijaga?

Penggunaan lanjutan. Apakah data boleh diteruskan kepada lembaga lain atau digunakan untuk tujuan berbeda?

Pemusnahan. Kapan data harus dihapus, siapa yang memerintahkan, dan bagaimana pemusnahannya dapat dibuktikan?

Pemulihan hak. Bagaimana seseorang atau organisasi dapat meminta koreksi, mengajukan keberatan, atau menuntut pemulihan apabila kewenangan digunakan secara tidak sah?

Audit teknis sebaiknya menggunakan pendekatan bertingkat. Untuk pengawasan rutin, regulator cukup meminta pernyataan kepatuhan, hasil penilaian risiko, ringkasan insiden, atau bukti kontrol tertentu. Pemeriksaan lebih dalam baru dilakukan ketika terdapat risiko tinggi, inkonsistensi, indikasi pelanggaran, atau insiden material.

Prinsip yang harus dijaga adalah **meminta bukti secukupnya, bukan mengambil seluruh data karena teknologi memungkinkan**.

Keamanan Ketahanan Siber juga perlu melarang praktik pengumpulan data tanpa tujuan yang terdefinisi, atau *collect first, justify later*. Pengumpulan data secara massal untuk kemungkinan penggunaan pada masa depan menciptakan risiko kebocoran, penyalahgunaan internal, perluasan tujuan, dan pengawasan terhadap pihak yang tidak terkait dengan ancaman.

Setiap akses harus meninggalkan *audit trail* yang setidaknya mencatat dasar kewenangan, identitas pemberi izin, identitas pelaksana, waktu, sistem yang diakses, kategori data, tindakan yang dilakukan, penerima data, dan waktu penghapusan.

Data audit tidak boleh dapat diubah oleh pelaksana yang sedang diperiksa. Namun, pencatatan audit juga tidak boleh berubah menjadi sistem penyimpanan baru yang menggandakan seluruh data sensitif. Yang dibutuhkan adalah **jejak pertanggungjawaban**, bukan salinan kehidupan digital warga.

9.3 Prinsip Necessity dan Proportionality

Kewenangan yang mempunyai tujuan sah belum tentu digunakan dengan cara yang sah. Negara masih harus membuktikan bahwa tindakan tersebut benar-benar diperlukan dan sebanding dengan ancaman yang dihadapi.

> Prinsip ***necessity*** menuntut jawaban atas pertanyaan: apakah tindakan tersebut memang dibutuhkan untuk mencapai tujuan keamanan yang sah? Jika tujuan dapat dicapai dengan data yang lebih sedikit, periode yang lebih singkat, atau teknik yang kurang intrusif, negara harus memilih cara tersebut.
>
> Prinsip ***proportionality*** menuntut keseimbangan antara manfaat keamanan yang diharapkan dan kerugian terhadap hak, privasi, ekonomi, serta layanan masyarakat. Semakin intrusif suatu tindakan, semakin kuat bukti kebutuhan dan semakin tinggi tingkat otorisasi yang harus dipersyaratkan.

Sebelum tindakan pemantauan atau audit intrusif dilakukan, sedikitnya harus tersedia lima pengujian:

1. **Tujuan yang sah.** Tujuan harus berkaitan dengan fungsi keamanan dan ketahanan siber yang ditentukan undang-undang.
2. **Hubungan rasional.** Tindakan harus mempunyai hubungan yang masuk akal dengan ancaman atau tujuan yang hendak ditangani.
3. **Kebutuhan.** Tidak tersedia pilihan lain yang sama efektifnya tetapi lebih sedikit membatasi hak.
4. **Kesebandingan.** Manfaat yang diharapkan sebanding dengan dampak terhadap individu, organisasi, layanan, dan kepentingan publik.
5. **Batas waktu.** Tindakan berakhir ketika tujuan telah tercapai atau dasar kebutuhannya tidak lagi ada.

Indonesia telah mengesahkan *International Covenant on Civil and Political Rights* melalui Undang-Undang Nomor 12 Tahun 2005. Hal ini memperkuat kebutuhan agar pembatasan hak dalam kebijakan siber tidak dibuat secara kabur, sewenang-wenang, atau lebih luas daripada tujuan yang sah. (UU Nomor 12 Tahun 2005 tentang Pengesahan ICCPR)

Proporsionalitas juga harus berlaku terhadap organisasi. Audit terhadap operator infrastruktur kritikal nasional tidak dapat disamakan dengan pemeriksaan terhadap usaha kecil berisiko rendah. Permintaan data yang dapat dipenuhi perusahaan besar belum tentu dapat dipenuhi pemerintah daerah atau UMKM tanpa menghentikan operasinya.

Namun, keterbatasan kapasitas tidak menghapus kewajiban dasar. Negara perlu membedakan antara ketidakpatuhan yang disengaja dan ketidakmampuan yang masih dapat diperbaiki. Untuk organisasi yang beritikad baik tetapi belum mampu, respons pertama negara seharusnya berupa arahan, bantuan, dan perintah perbaikan. Untuk organisasi yang menyembunyikan resiko besar atau mengabaikan keselamatan publik, tindakan yang lebih keras menjadi wajar.

Prinsip ini dapat dirumuskan secara tajam:

> **Ambil data sesedikit mungkin. Batasi akses sesempit mungkin. Simpan sesingkat mungkin. Gunakan hanya untuk tujuan yang disahkan. Pertanggung Jawabkan setiap penyimpangan.**

9.4 Due Process dan Pengawasan Independen

Kewenangan tidak boleh hanya sah di atas kertas. Ia harus dijalankan melalui prosedur yang dapat diperiksa.

Due process dalam konteks keamanan siber berarti bahwa tindakan pemerintah harus mempunyai dasar hukum, alasan yang terdokumentasi, otorisasi yang tepat, kesempatan untuk memberikan penjelasan, mekanisme keberatan, dan akses terhadap pemulihan. Prosedur dapat berbeda menurut tingkat urgensi, tetapi urgensi tidak menghapus akuntabilitas.

Untuk audit kepatuhan biasa, organisasi harus menerima pemberitahuan mengenai dasar pemeriksaan, ruang lingkup, dokumen yang diminta, jadwal, identitas pemeriksa, dan hak untuk memberikan tanggapan. Temuan awal harus dapat dikoreksi apabila terdapat kesalahan fakta.

Untuk keadaan mendesak, tindakan dapat dilakukan lebih cepat dan, dalam kondisi tertentu, tanpa pemberitahuan sebelumnya. Namun, pengecualian tersebut harus sempit. Harus tersedia persetujuan berjenjang, pencatatan alasan, durasi singkat, serta peninjauan setelah tindakan dilakukan.

Tindakan yang memasuki isi komunikasi, data pribadi spesifik, atau ruang privat memerlukan standar lebih tinggi daripada pemeriksaan konfigurasi keamanan. Semakin besar intrusinya, semakin kuat kebutuhan akan otorisasi yudisial atau mekanisme independen lain yang mempunyai kewenangan nyata untuk menolak, membatasi, dan memeriksa tindakan.

Pengawasan independen tidak berarti membocorkan teknik operasi atau data sensitif kepada publik. Pengawasan dapat dilakukan oleh pihak yang memiliki izin keamanan, kompetensi teknis, independensi kelembagaan, dan kewajiban menjaga kerahasiaan. Yang penting, lembaga pelaksana tidak menjadi satu-satunya pihak yang menentukan bahwa tindakannya sendiri telah benar.

Undang-Undang Nomor 30 Tahun 2014 tentang Administrasi Pemerintahan menempatkan tindakan dan keputusan pejabat dalam kerangka peraturan perundang-undangan dan Asas-Asas Umum Pemerintahan yang Baik. Semangatnya adalah pemerintahan yang demokratis, objektif, profesional, transparan, efisien, serta memberikan keadilan dan kepastian hukum. Arsitektur kewenangan Keamanan Ketahanan Siber seharusnya dibaca dalam kerangka tersebut. (UU Nomor 30 Tahun 2014 tentang Administrasi Pemerintahan)

Pengawasan idealnya bekerja dalam empat lapis:

> **Pengendalian internal.** Persetujuan berjenjang, pemisahan tugas, pencatatan akses, pemeriksaan kepatuhan, dan mekanisme pelaporan pelanggaran.
>
> **Pengawasan eksekutif independen.** Inspektorat atau unit pengawasan yang tidak berada di bawah komando operasi yang diperiksa.
>
> **Pengawasan yudisial atau kuasi-yudisial.** Terutama untuk tindakan sangat intrusif, sengketa kewenangan, dan permohonan pemulihan hak.
>
> **Pengawasan demokratis.** Pelaporan berkala kepada Presiden dan DPR dalam bentuk yang melindungi rahasia operasi, tetapi tetap memperlihatkan skala penggunaan kewenangan, jenis tindakan, pelanggaran, dan tindakan koreksi.

Publik tidak harus mengetahui target operasi yang sedang berlangsung. Namun, publik berhak mengetahui bagaimana kekuasaan digunakan secara agregat: berapa permintaan yang dibuat, kategori kewenangan yang digunakan, berapa yang ditolak, berapa lama data disimpan, berapa pelanggaran ditemukan, dan bagaimana pelanggaran ditindaklanjuti.

> **Kerahasiaan operasi tidak boleh berubah menjadi kerahasiaan pertanggungjawaban.**

9.5 Tangga Sanksi Administratif

Tujuan utama sanksi administratif adalah menghasilkan kepatuhan, mengurangi risiko, memulihkan keamanan, dan mencegah pengulangan. Sanksi bukan sekadar simbol bahwa negara sedang bertindak.

Keamanan Ketahanan Siber membutuhkan tangga sanksi yang memungkinkan regulator merespons sesuai tingkat kesalahan dan dampak. Urutan yang dapat dipertimbangkan adalah:

1. Peringatan tertulis.
2. Perintah penyusunan dan pelaksanaan rencana perbaikan.
3. Kewajiban audit tambahan atau penilaian independen.
4. Peningkatan frekuensi pelaporan dan pengawasan.
5. Pembatasan sementara terhadap fungsi, produk, atau pemrosesan tertentu.
6. Denda administratif berbasis tingkat pelanggaran dan dampak.
7. Penghentian sementara kegiatan berisiko tinggi.
8. Pencabutan izin sebagai tindakan terakhir untuk pelanggaran yang sangat serius atau terus berulang.

Tangga ini bukan berarti regulator selalu harus memulai dari tingkat pertama. Pelanggaran dengan dampak besar, kesengajaan, penyembunyian, pengulangan, atau ancaman terhadap keselamatan dapat langsung menerima sanksi yang lebih berat. Sebaliknya, kegagalan pertama yang segera dilaporkan dan diperbaiki tidak patut diperlakukan sama dengan pelanggaran yang disembunyikan.

Penentuan sanksi perlu mempertimbangkan:

- tingkat risiko dan dampak aktual;
- jumlah orang, sistem, sektor, atau wilayah yang terdampak;
- sifat dan sensitivitas data;
- durasi pelanggaran;
- kesengajaan atau tingkat kelalaian;
- keuntungan yang diperoleh dari pelanggaran;
- tindakan pencegahan yang telah dilakukan;
- kecepatan pelaporan dan pemulihan;
- kualitas kerja sama dengan otoritas;
- riwayat pelanggaran; dan
- kemampuan ekonomi pelanggar.

Denda dengan nominal yang sama dapat terlalu berat bagi usaha kecil, tetapi tidak berarti bagi perusahaan global. Karena itu, desain denda dapat mempertimbangkan skala usaha atau ukuran ekonomi yang relevan, dengan batas minimum dan maksimum yang jelas. Denda tidak boleh menjadi biaya operasional murah bagi perusahaan besar, tetapi juga tidak boleh mematikan organisasi kecil yang masih dapat diperbaiki.

Setiap sanksi harus disertai alasan tertulis, dasar hukum, fakta yang digunakan, pertimbangan pemberat dan peringan, serta mekanisme keberatan. Publikasi keputusan perlu memperhatikan kepentingan masyarakat, proses yang masih berjalan, kerahasiaan keamanan, reputasi pihak yang belum terbukti bersalah, dan risiko memperlihatkan kerentanan baru.

Referensi internal Onno W. Purbo mengenai risiko kebocoran data menempatkan denda bukan sebagai satu-satunya akibat. Insiden dapat memicu hilangnya kepercayaan, biaya pemulihan, pemeriksaan, gangguan operasi, dan gugatan. Karena konsekuensinya luas, sanksi harus mendorong perbaikan nyata—bukan sekadar menghasilkan pembayaran kepada negara.

> **Sanksi yang baik mengubah perilaku. Sanksi yang buruk hanya menambah ketakutan, biaya, dan kecenderungan menyembunyikan insiden.**

9.6 Pidana sebagai Ultimum Remedium

Sistem digital yang kompleks tidak mungkin dijamin bebas dari kegagalan. Organisasi yang telah berupaya secara wajar tetap dapat menjadi korban serangan. Kerentanan baru dapat ditemukan setelah produk beroperasi. Kesalahan konfigurasi dapat terjadi tanpa niat jahat. Serangan dapat mengalahkan kontrol yang sebelumnya dianggap memadai.

Jika setiap kegagalan teknis segera ditarik ke wilayah pidana, organisasi akan terdorong untuk menyembunyikan insiden, membatasi dokumentasi, dan menghindari komunikasi terbuka. Negara justru kehilangan informasi yang dibutuhkan untuk mencegah serangan berikutnya.

Karena itu, pidana dalam Keamanan Ketahanan Siber perlu ditempatkan sebagai *ultimum remedium*: instrumen terakhir untuk perilaku yang memang layak memperoleh celaan pidana, bukan respons otomatis terhadap setiap hasil keamanan yang buruk.

Pidana dapat diarahkan pada perbuatan seperti:

- serangan atau akses tanpa hak yang dilakukan dengan sengaja;
- sabotase terhadap layanan kritikal;
- pencurian, penjualan, atau penyalahgunaan data;
- penipuan terkait kepatuhan atau sertifikasi keamanan;
- penghancuran atau pemalsuan barang bukti;
- penyembunyian informasi material secara sadar;
- pemberian laporan palsu kepada otoritas;
- pembiaran sadar terhadap risiko serius yang telah diketahui; dan
- kelalaian berat dalam keadaan ketika pelaku memahami kemungkinan dampak serius tetapi tetap mengabaikannya.

Keamanan Ketahanan Siber harus berhati-hati menggunakan istilah “kelalaian”. Tidak semua kesalahan adalah kelalaian berat. Penilaian harus mempertimbangkan standar kewajaran, kemampuan organisasi, pengetahuan yang tersedia pada saat keputusan dibuat, tingkat risiko, langkah pencegahan, kecepatan respons, dan upaya pemulihan.

Perlu dibedakan secara tegas:

> **Kegagalan yang tidak dapat dihindari**, meskipun kontrol wajar telah diterapkan.
>
> **Kelalaian biasa**, ketika terdapat kekurangan yang dapat diperbaiki melalui tindakan administratif.
>
> **Kelalaian berat**, ketika risiko serius telah jelas tetapi diabaikan secara tidak patut.
>
> **Kesengajaan**, ketika pelaku memang menghendaki, membantu, menyembunyikan, atau mengambil manfaat dari pelanggaran.

Pertanggungjawaban pidana juga tidak boleh dibebankan otomatis kepada pimpinan hanya karena jabatannya. Harus dibuktikan hubungan antara kewenangan, pengetahuan, keputusan, tindakan atau pembiaran, dan akibat yang terjadi. Sebaliknya, struktur organisasi

tidak boleh digunakan untuk menyembunyikan individu yang secara sadar memerintahkan pelanggaran.

Penggunaan pidana harus memenuhi rumusan yang jelas. Istilah seperti “tidak menjaga keamanan secara memadai”, “mengganggu ketahanan siber”, atau “tidak membantu pemerintah” terlalu luas apabila tidak disertai unsur, standar, dan batas yang dapat dipahami sebelumnya.

> **Hukum pidana yang kabur tidak menghasilkan keamanan; ia menghasilkan ketakutan, penegakan selektif, dan ketidakpastian investasi.**

9.7 Perlindungan Peneliti Keamanan dan Responsible Disclosure

Peneliti keamanan sering menemukan kelemahan sebelum pelaku kejahatan menemukannya. Namun, tanpa kepastian hukum dan saluran pelaporan yang baik, peneliti dapat memilih diam, mempublikasikan temuan terlalu cepat, atau menyerahkan informasi kepada pihak yang salah.

Perlindungan peneliti bukan hadiah bagi peretas. Ia adalah strategi untuk mengubah pengetahuan tentang kelemahan menjadi perbaikan sebelum kelemahan tersebut menimbulkan korban.

Keamanan Ketahanan Siber perlu mengenali *coordinated vulnerability disclosure* sebagai bagian dari ekosistem keamanan nasional. Pemerintah, operator IIK, dan penyedia produk berisiko tinggi perlu mempunyai kebijakan yang mudah ditemukan dan memuat:

- ruang lingkup sistem yang boleh diuji;
- tindakan yang diperbolehkan dan dilarang;
- saluran pelaporan yang aman;
- informasi minimum yang diperlukan;
- jangka waktu konfirmasi penerimaan;
- proses validasi dan perbaikan;
- aturan komunikasi dan publikasi;
- perlindungan data yang mungkin tidak sengaja ditemukan;
- mekanisme eskalasi jika laporan tidak ditanggapi; dan
- bentuk perlindungan bagi peneliti yang bertindak dengan itikad baik.

Perlindungan hukum tidak dapat hanya bergantung pada label “peneliti”. Penilaian perlu didasarkan pada perilaku. Peneliti beritikad baik harus:

1. bertindak dalam ruang lingkup kewenangan atau kebijakan yang tersedia;
2. menggunakan cara yang proporsional untuk membuktikan kerentanan;
3. menghentikan pengujian ketika menemukan data sensitif atau risiko kerusakan;
4. tidak mengubah, menghapus, menjual, atau menyalahgunakan data;
5. tidak mengganggu layanan lebih dari yang diperlukan;
6. tidak melakukan pemerasan;
7. menyampaikan laporan melalui saluran yang ditetapkan; dan
8. memberi waktu yang wajar untuk mitigasi sebelum publikasi.

Referensi internal Onno W. Purbo, terutama “AI Assisted Penetration Test” dan “CEH Mastery: AI-Assisted OSINT”, menegaskan bahwa kemampuan teknis harus beroperasi dalam *scope* yang sah, berbasis izin, disertai pencatatan, serta dikendalikan oleh etika. Hasil pencarian atau indikasi teknis juga harus diperlakukan sebagai petunjuk yang perlu diverifikasi, bukan sebagai bukti final.

Prinsip ini penting karena sistem otomatis dan AI dapat menghasilkan dugaan yang salah. Seseorang tidak boleh dituduh menyerang hanya karena alamat jaringan atau pola teknis tertentu muncul dalam sistem. Bukti harus divalidasi, konteks harus diperiksa, dan rantai penguasaan bukti harus dijaga.

Kebijakan pengungkapan kerentanan yang baik memberikan *safe harbor* terbatas: organisasi menyatakan tidak akan mengambil tindakan hukum terhadap penelitian yang dilakukan dengan itikad baik dan sesuai kebijakan. Namun, *safe harbor* tidak melindungi pemerasan, pengambilan data secara berlebihan, penjualan akses, sabotase, atau tindakan di luar ruang lingkup.

CISA menyediakan model kebijakan pengungkapan kerentanan yang memperjelas ruang lingkup, cara pelaporan, ekspektasi terhadap peneliti, dan komitmen organisasi dalam menangani laporan. Indonesia dapat mengadaptasi prinsip tersebut ke dalam hukum nasional, bukan menyalinnya secara mekanis. (CISA Vulnerability Disclosure Policy Platform)

Negara juga dapat membentuk koordinator nasional untuk laporan yang melibatkan banyak produk atau lembaga. Koordinator membantu menghubungkan peneliti, penyedia, operator, dan regulator; menjaga kerahasiaan selama masa perbaikan; serta mencegah saling lempar tanggung jawab.

> **Peneliti yang bertanggung jawab adalah sensor dini bagi negara. Mengkriminalkan mereka secara serampangan berarti mematikan alarm sebelum kebakaran terjadi.**

9.8 Keputusan Strategis Bab 9

Keamanan Ketahanan Siber harus memberikan kewenangan yang cukup bagi negara untuk menghadapi ancaman siber, tetapi kewenangan itu harus ditulis bersama batasnya. Norma kewenangan yang luas dan norma pengawasan yang lemah akan menciptakan ketimpangan kekuasaan yang berbahaya.

Keputusan strategis pertama adalah **membedakan secara tegas pemantauan keamanan, audit kepatuhan, respons insiden, penyelidikan administratif, penyidikan pidana, intelijen, dan operasi pertahanan**. Setiap fungsi harus mempunyai tujuan, pelaksana, dasar kewenangan, serta mekanisme pengawasan masing-masing.

Keputusan strategis kedua adalah **menetapkan klasifikasi tindakan** berdasarkan tingkat intrusi. Permintaan informasi agregat tidak boleh diperlakukan sama dengan akses terhadap data pribadi atau isi komunikasi. Semakin intrusif tindakan, semakin tinggi standar bukti, otorisasi, dan pengawasannya.

Keputusan strategis ketiga adalah **menormakan prinsip** *necessity*, *proportionality*, pembatasan tujuan, minimalisasi data, pembatasan penyimpanan, dan keamanan data. Prinsip-prinsip ini tidak boleh diserahkan seluruhnya kepada peraturan pelaksanaan karena merupakan pagar utama terhadap penyalahgunaan kekuasaan.

Keputusan strategis keempat adalah **mewajibkan *audit trail*** untuk setiap penggunaan kewenangan khusus. Tidak boleh ada akses tanpa identitas pelaksana, dasar, waktu, tujuan, dan catatan tindakan.

Keputusan strategis kelima adalah **menyediakan pengawasan independen dan mekanisme pemulihan**. Warga atau organisasi yang dirugikan harus dapat mengajukan keberatan, meminta koreksi, memperoleh penjelasan yang layak, dan menuntut pemulihan melalui jalur yang efektif.

Keputusan strategis keenam adalah **membangun tangga sanksi administratif** yang berorientasi pada koreksi perilaku. Berat sanksi harus memperhitungkan dampak, kesengajaan, kelalaian, riwayat pelanggaran, kerja sama, tindakan pemulihan, dan kemampuan ekonomi pelanggar.

Keputusan strategis ketujuh adalah **menempatkan pidana** sebagai *ultimum remedium*. Rumusan pidana harus ditujukan kepada kesengajaan, penipuan, sabotase, penyembunyian material, pembiaran sadar, atau kelalaian berat—bukan kepada setiap insiden dan kegagalan teknis.

Keputusan strategis kedelapan adalah **memberikan kepastian hukum** bagi penelitian keamanan beritikad baik melalui *responsible disclosure*, *coordinated vulnerability disclosure*, dan *safe harbor* yang terbatas serta terukur.

Keamanan Ketahanan Siber juga perlu mengatur pertanggungjawaban pemerintah apabila kewenangan disalahgunakan. Sanksi tidak boleh hanya ditujukan kepada penyelenggara dan penyedia teknologi. Pejabat atau pelaksana yang mengakses, menggunakan, menyebarkan, atau mempertahankan data tanpa dasar yang sah harus ikut bertanggung jawab.

Inilah keseimbangan yang dibutuhkan: **negara memperoleh kemampuan untuk bertindak cepat, tetapi tidak memperoleh cek kosong; penyelenggara diwajibkan bertanggung jawab, tetapi tetap memperoleh proses yang adil; peneliti dilindungi ketika beritikad baik, tetapi tidak dibebaskan dari batas hukum.**

RANGKUMAN BAB 9

Bidang strategis	Risiko utama	Norma yang harus dimuat dalam Keamanan Ketahanan Siber	Keputusan kebijakan
Keamanan dan kebebasan	Pemantauan keamanan berkembang menjadi pengawasan warga	Tujuan sah, batas objek, kategori data, dan perlindungan hak	Keamanan harus dirancang untuk melindungi kebebasan, bukan menghapusnya
Batas pemantauan	Istilah kewenangan terlalu luas dan mudah ditafsirkan	Definisi pemantauan, audit, akses data, pemeriksaan, dan penyelidikan	Bentuk matriks kewenangan berdasarkan fungsi dan tingkat intrusi
Minimalisasi data	Pengumpulan data berlebihan dan penggunaan di luar tujuan awal	Pembatasan tujuan, minimalisasi, retensi, akses, dan pemusnahan	Ambil data secukupnya dan simpan hanya selama diperlukan
Necessity dan proportionality	Tindakan sah digunakan secara berlebihan	Uji tujuan sah, hubungan rasional, kebutuhan, kesebandingan, dan durasi	Gunakan cara yang efektif dengan pembatasan hak paling kecil
Due process	Audit atau tindakan intrusif dilakukan tanpa prosedur yang dapat diuji	Dasar hukum, otorisasi, pemberitahuan, tanggapan, keberatan, dan pemulihan	Tingkat perlindungan prosedural mengikuti tingkat intrusi
Pengawasan independen	Lembaga pelaksana menilai sendiri legalitas tindakannya	Audit internal, pengawasan independen, yudisial, dan demokratis	Kerahasiaan operasi tidak boleh menghapus pertanggungjawaban
Sanksi administratif	Sanksi seragam tidak menghasilkan kepatuhan yang adil	Tangga sanksi dan faktor pemberat serta peringan	Sanksi diarahkan untuk memperbaiki, mencegah, dan memulihkan
Pidana	Setiap kegagalan teknis berpotensi dikriminalisasi	Unsur perbuatan, kesengajaan, kelalaian berat, hubungan kausal, dan pembuktian	Pidana menjadi ultimum remedium, bukan respons pertama
Peneliti keamanan	Temuan disembunyikan karena takut dikriminalisasi	Responsible disclosure, ruang lingkup, saluran laporan, dan safe harbor	Lindungi penelitian beritikad baik, tindak penyalahgunaan secara tegas
Akuntabilitas negara	Sanksi hanya menyasar industri dan warga	Tanggung jawab pejabat atas akses dan penggunaan data yang tidak sah	**Kekuasaan negara harus tunduk pada sanksi dan pemulihan yang nyata**

PENUTUP

Keamanan siber bukan alasan untuk menangguhkan negara hukum. Justru karena teknologi memungkinkan negara mengawasi dengan skala, kecepatan, dan kedalaman yang belum pernah ada sebelumnya, hukum harus membangun pagar yang lebih presisi.

Indonesia membutuhkan aparat yang berdaya, regulator yang tegas, dan lembaga keamanan yang mampu melihat ancaman sebelum menjadi bencana. Namun, Indonesia juga membutuhkan warga yang tidak hidup dalam ketakutan bahwa setiap aktivitas digitalnya dapat diperiksa tanpa alasan dan tanpa jalan untuk menggugat.

> **Semakin besar kewenangan yang diberikan, semakin rinci batas penggunaannya. Semakin rahasia operasinya, semakin kuat audit independennya. Semakin berat sanksinya, semakin tinggi standar pembuktiannya.**

Kekuatan tanpa batas melahirkan ketakutan. Batas tanpa kemampuan melahirkan kelumpuhan. Keamanan Ketahanan Siber harus menghindari keduanya dengan membangun negara yang kuat, cepat, dan kompeten—sekaligus terbatas, dapat diaudit, dan bertanggung jawab.

> **Kedaulatan siber bukan hanya kemampuan mempertahankan negara dari serangan. Kedaulatan siber juga berarti kemampuan mempertahankan warga dari penyalahgunaan kekuasaan digital.**

REFERENSI BAB 9

- Undang-Undang Dasar Negara Republik Indonesia Tahun 1945, khususnya Pasal 28D, Pasal 28G, dan Pasal 28J.
- Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi. (Database Peraturan BPK)
- Undang-Undang Nomor 30 Tahun 2014 tentang Administrasi Pemerintahan sebagaimana telah diubah. (Database Peraturan BPK)
- Undang-Undang Nomor 12 Tahun 2005 tentang Pengesahan *International Covenant on Civil and Political Rights*. (Database Peraturan BPK)
- National Institute of Standards and Technology. “Privacy Framework.” (NIST)
- Cybersecurity and Infrastructure Security Agency. “Vulnerability Disclosure Policy Platform.” (CISA)
- Onno W. Purbo. “AI Assisted Penetration Test”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo. “CEH Mastery: AI-Assisted OSINT”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo. “Kalau Data Pribadi Bocor, Apa Risikonya?”, 2025. Referensi internal ChatGPT Library.
- Komisi I DPR RI. “TOR RDPU Pakar Regulasi Keamanan dan Ketahanan Siber”, 2026.

BAB 10 - KEAMANAN KETAHANAN SIBER UNTUK DUNIA TANPA BATAS DAN INDONESIA YANG BERDAULAT

Tujuan bab: menyatukan seluruh gagasan menjadi arsitektur hukum, diplomasi, dan peta jalan nasional yang dapat dilaksanakan.

Serangan siber tidak berhenti di pos pemeriksaan perbatasan. Sebuah serangan terhadap rumah sakit di Indonesia dapat dikendalikan dari negara pertama, menggunakan infrastruktur komputasi di negara kedua, memanfaatkan akun pembayaran di negara ketiga, menjalankan perangkat lunak buatan perusahaan di negara keempat, serta menyimpan hasil curian di negara kelima.

Sementara itu, korban, penyidik, regulator, penyedia layanan, dan pengadilan berada di bawah hukum yang berbeda. Bukti dapat hilang dalam hitungan jam, sedangkan permintaan bantuan hukum dapat membutuhkan waktu berbulan-bulan.

Inilah tantangan terakhir Keamanan Ketahanan Siber: **bagaimana hukum nasional dapat melindungi Indonesia dalam ruang digital yang tidak mengenal batas geografis, tanpa mengklaim kewenangan yang tidak mungkin ditegakkan?**

Jawabannya bukan memperluas yurisdiksi tanpa batas. Jawabannya adalah membangun titik kait hukum yang jelas, kemampuan atribusi yang dapat dipercaya, kerja sama internasional yang cepat, dan kapasitas teknologi nasional yang membuat Indonesia tidak selalu meminta bantuan kepada pihak lain.

Kedaulatan siber bukan berarti menutup jaringan, memindahkan seluruh data ke dalam negeri, atau membuat semua teknologi sendiri. **Kedaulatan berarti Indonesia tetap mampu menentukan kebijakan, menguasai data strategis, menjaga layanan kritikal, memeriksa teknologi, memulihkan sistem, mengganti pemasok, dan mempertahankan kepentingan nasional ketika kerja sama internasional terganggu.**

Keamanan Ketahanan Siber harus menjadi fondasi bagi negara yang terbuka untuk bekerja sama, tetapi tidak mudah dikendalikan; terhubung dengan dunia, tetapi tidak kehilangan kemampuan menentukan arah.

10.1 Mengapa Serangan Siber Melampaui Yurisdiksi Negara

Dalam kejahatan konvensional, lokasi pelaku, korban, alat, dan bukti relatif lebih mudah ditentukan. Dalam serangan siber, unsur-unsur tersebut dapat tersebar di berbagai wilayah hukum secara bersamaan.

Pelaku dapat tinggal di luar Indonesia, menggunakan identitas palsu, memanfaatkan perangkat korban yang telah dikuasai, menyewa layanan komputasi dengan mata uang kripto, dan mengarahkan serangan melalui beberapa lapis infrastruktur. Alamat jaringan yang terlihat oleh korban belum tentu menunjukkan lokasi pelaku sebenarnya.

Server yang menjadi bagian serangan juga belum tentu dimiliki pelaku. Server tersebut dapat merupakan sistem sah yang telah diretas, layanan komputasi yang disewa menggunakan identitas palsu, jaringan perangkat konsumen, atau infrastruktur pihak ketiga yang tidak mengetahui bahwa layanannya sedang disalahgunakan.

Data menambah kerumitan. Satu aplikasi dapat digunakan di Indonesia, dikelola perusahaan di negara lain, memproses data melalui beberapa pusat data, menggunakan layanan analitik pihak ketiga, dan menyimpan cadangan di yurisdiksi yang berbeda. Lokasi hukum data tidak selalu dapat disederhanakan menjadi lokasi fisik satu server.

Rantai bukti juga mudah terputus. Catatan akses dapat disimpan oleh penyedia pertama, identitas pelanggan oleh penyedia kedua, transaksi oleh penyedia pembayaran, dan komunikasi oleh platform lain. Setiap pihak mempunyai kebijakan retensi, standar pembuktian, dan kewajiban hukum yang berbeda.

Karena itu, negara tidak dapat mengandalkan satu indikator teknis untuk menentukan yurisdiksi. Setidaknya terdapat tujuh unsur yang perlu dinilai:

1. Lokasi korban dan dampak utama.
2. Kewarganegaraan atau kedudukan hukum korban.
3. Lokasi sistem dan data yang terdampak.
4. Lokasi pelaku atau pengendali operasi.
5. Lokasi infrastruktur yang digunakan.
6. Negara tempat penyedia layanan atau perusahaan didirikan.
7. Lokasi bukti serta pihak yang menguasainya.

Satu perkara dapat memberikan dasar kepentingan hukum kepada beberapa negara. Hal ini membuka kebutuhan koordinasi, tetapi juga risiko konflik yurisdiksi. Dua negara dapat sama-sama merasa berwenang, sementara negara tempat bukti berada belum tentu mempunyai kepentingan untuk bertindak cepat.

> **Di ruang siber, masalah terbesar sering bukan ketiadaan yurisdiksi, melainkan terlalu banyak yurisdiksi yang tidak terkoordinasi.**

Keamanan Ketahanan Siber tidak dapat menyelesaikan seluruh persoalan hukum internasional. Namun, undang-undang ini dapat menetapkan siapa yang mewakili Indonesia, bagaimana bukti dipertahankan, kapan bantuan internasional diminta, bagaimana informasi

dibagikan, dan siapa yang mengambil keputusan ketika kepentingan beberapa lembaga bertemu dalam satu insiden.

10.2 Ekstrateritorialitas yang Dapat Ditegakkan

Asas ekstrateritorial memungkinkan hukum Indonesia menjangkau perbuatan tertentu yang terjadi di luar wilayah Indonesia. Namun, asas ini hanya bermakna apabila mempunyai titik kait yang jelas dan didukung kemampuan penegakan.

Keamanan Ketahanan Siber perlu menghindari rumusan yang menyatakan bahwa seluruh perbuatan di ruang siber yang “berkaitan dengan Indonesia” otomatis tunduk pada hukum Indonesia. Frasa seperti ini terlalu luas, sulit diprediksi, dan berisiko menimbulkan konflik dengan negara lain.

Ekstrateritorialitas sebaiknya didasarkan pada titik kait yang dapat diverifikasi, antara lain:

- serangan menimbulkan dampak material di wilayah Indonesia;
- korban utama merupakan warga negara atau badan hukum Indonesia;
- sasaran serangan adalah pemerintahan, pertahanan, atau Infrastruktur Informasi Kritikal Indonesia;
- produk atau layanan secara sengaja ditawarkan kepada pasar Indonesia;
- data pribadi warga Indonesia diproses atau terdampak;
- keputusan bisnis yang menimbulkan pelanggaran dibuat oleh perusahaan yang mempunyai kehadiran atau perwakilan di Indonesia; atau
- perbuatan di luar negeri menjadi bagian substansial dari tindak pidana yang akibat utamanya terjadi di Indonesia.

Titik kait tersebut perlu dibedakan menurut jenis tindakan. Yurisdiksi untuk kewajiban administratif terhadap penyedia layanan tidak selalu sama dengan yurisdiksi pidana terhadap individu. Kewajiban memberikan pembaruan keamanan tidak dapat diperlakukan sama dengan permintaan penyerahan isi komunikasi. Setiap tindakan mempunyai dasar hukum, standar bukti, dan mekanisme kerja sama yang berbeda.

Agar dapat ditegakkan, penyedia asing yang menawarkan layanan berisiko tinggi atau mengelola fungsi kritikal di Indonesia perlu mempunyai titik kontak hukum dan operasional yang dapat dihubungi. Untuk layanan tertentu, kewajiban menunjuk perwakilan dapat dipertimbangkan berdasarkan skala, risiko, jumlah pengguna, jenis data, dan kekritisan layanan.

Namun, perwakilan domestik tidak boleh diposisikan sebagai sandera hukum atas seluruh tindakan perusahaan global. Tanggung jawabnya harus dibatasi secara jelas pada fungsi, informasi, dan kewajiban yang berada dalam penguasaannya.

Efektivitas ekstrateritorialitas dapat diukur melalui empat pertanyaan:

1. Apakah subjek hukum dapat diidentifikasi?
2. Apakah perintah hukum dapat disampaikan secara sah?
3. Apakah bukti dapat diperoleh dan diterima di pengadilan?
4. Apakah putusan atau sanksi dapat dilaksanakan?

Jika keempatnya tidak dapat dijawab, perluasan yurisdiksi hanya menghasilkan pasal yang terlihat tegas tetapi lemah dalam pelaksanaan.

Keamanan Ketahanan Siber juga perlu membedakan antara pemblokiran sebagai tindakan perlindungan sementara dan pemblokiran sebagai sanksi. Tindakan perlindungan dapat dilakukan untuk membatasi serangan yang sedang berlangsung, tetapi harus mempunyai ruang lingkup sempit, durasi tertentu, evaluasi dampak, dan mekanisme penghentian. Pemblokiran tidak boleh menjadi pengganti proses hukum terhadap perusahaan yang sebenarnya dapat dimintai pertanggungjawaban.

> **Ekstrateritorialitas yang baik bukan yang paling luas, melainkan yang mempunyai hubungan nyata dengan Indonesia dan dapat dilaksanakan melalui hukum, teknologi, pasar, serta diplomasi.**

10.3 Atribusi Bukan Tebakan Politik

Mengetahui bahwa serangan terjadi berbeda dari mengetahui siapa yang melakukannya. Menghubungkan serangan dengan kelompok, organisasi, atau negara tertentu merupakan proses atribusi yang mengandung ketidakpastian.

Pelaku dapat menggunakan perangkat milik pihak lain, menanam petunjuk palsu, meniru teknik kelompok tertentu, menggunakan bahasa asing, atau melakukan serangan pada waktu yang sengaja disesuaikan dengan zona waktu negara lain. Kesamaan alat, alamat jaringan, atau gaya kode tidak otomatis membuktikan identitas pelaku.

Referensi internal Onno W. Purbo, “CEH Mastery: AI-Assisted OSINT”, menegaskan bahwa AI tidak boleh dijadikan sumber fakta atau alat atribusi otomatis. Setiap klaim penting harus mempunyai bukti dan *provenance*, sedangkan tingkat keyakinan harus dibedakan dari tingkat dampak.

Prinsip tersebut sangat penting pada tingkat negara. **Dampak tinggi tidak otomatis berarti atribusi mempunyai keyakinan tinggi.** Sebuah serangan dapat sangat merusak tetapi pelakunya belum diketahui. Sebaliknya, identitas pelaku dapat diketahui dengan keyakinan tinggi pada serangan yang dampaknya terbatas.

Atribusi nasional sebaiknya menggunakan kombinasi beberapa kelompok bukti:

> **Bukti teknis**, seperti infrastruktur, perangkat lunak, sertifikat digital, pola komunikasi, metode persistensi, serta kesamaan kode.
>
> **Bukti operasional**, seperti pilihan sasaran, waktu serangan, tahapan operasi, disiplin pelaku, dan pola kampanye.
>
> **Bukti finansial**, seperti pembayaran infrastruktur, aliran dana, monetisasi hasil serangan, atau keterkaitan dengan organisasi tertentu.
>
> **Bukti manusia**, termasuk informasi dari korban, saksi, pelaku, infiltrasi, atau sumber intelijen.
>
> **Bukti strategis**, berupa kesesuaian operasi dengan kepentingan, doktrin, atau kampanye aktor tertentu.

Bukti strategis hanya memberikan konteks. Motif bukan bukti identitas. Negara tidak boleh menyimpulkan “siapa yang diuntungkan” sebagai “siapa yang melakukan”.

Keamanan Ketahanan Siber perlu memisahkan sedikitnya tiga tingkat keluaran atribusi:

1. **Atribusi teknis**, yang menghubungkan aktivitas dengan infrastruktur, alat, atau kelompok aktivitas tertentu.
2. **Atribusi hukum**, yang harus memenuhi standar pembuktian untuk mengenakan tanggung jawab kepada individu atau badan hukum.
3. **Atribusi politik atau kenegaraan**, yang menghubungkan operasi dengan negara atau pihak yang bertindak atas nama negara dan dapat menimbulkan konsekuensi diplomatik.

Ketiga proses tersebut tidak selalu menghasilkan kesimpulan yang sama pada waktu yang sama. Tim teknis dapat mempunyai indikasi kuat mengenai suatu kelompok, sementara bukti yang dapat dibuka di pengadilan masih belum cukup. Intelijen dapat mempunyai sumber rahasia yang memperkuat keyakinan, tetapi tidak dapat dipublikasikan.

Karena itu, pernyataan pemerintah harus menggunakan bahasa keyakinan yang disiplin, misalnya:

- terkonfirmasi berdasarkan bukti yang dapat dibuka;
- sangat mungkin;
- kemungkinan besar;
- terdapat indikasi;
- belum dapat ditentukan; atau
- informasi tidak memadai.

Pernyataan publik juga harus membedakan fakta yang teramati, interpretasi teknis, penilaian intelijen, dan keputusan politik. Tingkat keyakinan, keterbatasan data, serta kemungkinan perubahan penilaian harus disampaikan sejauh tidak membuka sumber dan metode sensitif.

Atribusi terhadap negara asing sebaiknya diputuskan melalui mekanisme lintas lembaga yang melibatkan unsur teknis, intelijen, penegakan hukum, pertahanan, dan diplomasi. Keputusan tidak boleh hanya dibuat oleh lembaga yang pertama kali menemukan insiden.

> **Atribusi yang tergesa-gesa dapat mengubah kegagalan teknis menjadi krisis diplomatik. Atribusi yang terlalu lambat dapat menghilangkan daya tangkal. Indonesia membutuhkan atribusi yang cepat, tetapi tetap jujur terhadap ketidakpastian.**

10.4 Kerja Sama Internasional

Tidak ada negara yang dapat membangun ketahanan siber sendirian. Infrastruktur global, perusahaan multinasional, jaringan pembayaran, rantai pasokan, dan bukti elektronik membuat kerja sama internasional menjadi kebutuhan operasional, bukan sekadar agenda diplomasi.

Indonesia membutuhkan beberapa jalur kerja sama yang berjalan paralel.

Pertama, **jalur teknis antartim respons insiden**. Jalur ini digunakan untuk berbagi indikator, memperingatkan mitra, mengoordinasikan mitigasi, meminta pengamanan sistem, dan menghentikan penyebaran serangan.

Kedua, **jalur penegakan hukum**. Jalur ini digunakan untuk preservasi bukti, permintaan data, identifikasi pelaku, bantuan penyidikan, penyitaan aset, bantuan hukum timbal balik, dan ekstradisi sesuai hukum yang berlaku.

Ketiga, **jalur regulator**. Regulator sektor dapat bekerja sama dengan mitranya di negara lain ketika insiden melibatkan bank, telekomunikasi, transportasi, kesehatan, energi, penyedia komputasi awan, atau rantai pasokan lintas negara.

Keempat, **jalur intelijen dan pertahanan**. Jalur ini menangani ancaman terhadap keamanan nasional, operasi yang didukung negara, spionase, dan kegiatan yang tidak selalu dapat diselesaikan melalui proses pidana biasa.

Kelima, **jalur diplomatik**. Kementerian Luar Negeri perlu memastikan tindakan teknis dan hukum selaras dengan posisi internasional Indonesia, kewajiban perjanjian, kepentingan ASEAN, serta pencegahan eskalasi antarnegara.

Keenam, **jalur industri dan komunitas**. Banyak bukti serta kemampuan teknis berada pada penyedia layanan, perusahaan keamanan, operator jaringan, perguruan tinggi, dan komunitas peneliti. Negara membutuhkan prosedur yang memungkinkan kerja sama tanpa mengubah perusahaan menjadi perpanjangan tangan pengawasan yang tidak terkendali.

Kecepatan menjadi persoalan utama. Bukti elektronik dapat dihapus oleh sistem otomatis sebelum permintaan formal selesai. Karena itu, Keamanan Ketahanan Siber perlu membedakan permintaan preservasi dari permintaan penyerahan. Preservasi meminta penyedia menjaga data yang sudah ada agar tidak hilang; akses atau penyerahan tetap memerlukan dasar hukum dan prosedur yang sesuai.

Konvensi PBB Menentang Kejahatan Siber, yang diadopsi Majelis Umum PBB pada 2024 dan dibuka untuk penandatanganan di Hanoi pada Oktober 2025, menyediakan kerangka mengenai kriminalisasi tertentu, bukti elektronik, bantuan hukum, ekstradisi, preservasi data, dan kerja sama internasional. Sebelum mengikatkan diri atau mengimplementasikan ketentuannya, Indonesia tetap perlu menilai kesesuaiannya dengan konstitusi, hukum nasional, pelindungan data, kebebasan berekspresi, penelitian keamanan, dan kepentingan kedaulatan. (UN Convention against Cybercrime)

Keamanan Ketahanan Siber tidak perlu menggandakan seluruh hukum bantuan timbal balik dan ekstradisi. Undang-undang ini perlu membangun jembatan operasional: siapa yang menerima permintaan, bagaimana urgensi dinilai, siapa yang menyetujui pembagian informasi teknis, bagaimana data pribadi dilindungi, serta bagaimana permintaan asing ditolak apabila bertentangan dengan hukum atau kepentingan fundamental Indonesia.

Indonesia juga perlu mempunyai titik kontak siber nasional yang beroperasi sepanjang waktu. Titik kontak bukan satu orang atau satu nomor telepon, melainkan mekanisme antar lembaga yang mampu:

- menerima dan memvalidasi permintaan;
- menentukan lembaga yang berwenang;
- melakukan preservasi awal;
- menghubungkan jalur teknis dan jalur hukum;
- menjaga klasifikasi informasi;
- mencatat seluruh tindakan; dan
- memastikan tindak lanjut tidak berhenti pada pergantian jam kerja.

Kerja sama internasional harus dibangun berdasarkan resiprositas dan kepentingan nasional. Indonesia tidak boleh hanya menjadi pemasok data dan pasar teknologi. Indonesia harus menjadi penghasil intelijen ancaman, peserta aktif dalam penyusunan standar, mitra riset, sumber talenta, dan penyedia teknologi.

> **Diplomasi siber yang kuat dimulai dari kemampuan teknis dalam negeri. Negara yang selalu meminta bantuan akan sulit menentukan syarat kerja samanya sendiri.**

10.5 Harmonisasi Hukum Nasional

Keamanan Ketahanan Siber tidak boleh menjadi pulau hukum baru. Ia akan beroperasi di tengah berbagai peraturan yang telah mengatur sistem elektronik, data pribadi, telekomunikasi, administrasi pemerintahan, pertahanan, intelijen, kepolisian, keterbukaan informasi, serta hukum pidana.

Paling sedikit, Keamanan Ketahanan Siber perlu diharmonisasikan dengan:

- Undang-Undang Informasi dan Transaksi Elektronik beserta perubahannya;
- Undang-Undang Pelindungan Data Pribadi;
- peraturan mengenai penyelenggaraan sistem dan transaksi elektronik;
- Kitab Undang-Undang Hukum Pidana dan hukum acara pidana;
- undang-undang mengenai bantuan timbal balik dan ekstradisi;
- undang-undang mengenai pertahanan, TNI, Polri, dan intelijen;
- Undang-Undang Keterbukaan Informasi Publik;
- Undang-Undang Administrasi Pemerintahan;
- regulasi telekomunikasi; dan
- regulasi sektoral pada keuangan, energi, kesehatan, transportasi, pemerintahan daerah, dan layanan publik lainnya.

Undang-Undang Nomor 1 Tahun 2024 merupakan perubahan kedua atas UU ITE. Basis data resmi BPK juga mencatat sejumlah putusan Mahkamah Konstitusi yang memberikan pemaknaan bersyarat terhadap norma tertentu. Artinya, harmonisasi tidak cukup dilakukan terhadap teks lama; perancang Regulasi harus menggunakan **hukum yang berlaku setelah perubahan dan putusan pengadilan yang relevan**. (UU Nomor 1 Tahun 2024)

UU PDP mengatur hak subjek data, kewajiban pengendali dan prosesor, pemrosesan, transfer data, sanksi, kelembagaan, serta kerja sama internasional. Keamanan Ketahanan Siber harus menjelaskan hubungan antara pelaporan insiden siber dan pemberitahuan kegagalan pelindungan data pribadi. Tidak semua insiden siber melibatkan data pribadi, dan tidak semua pelanggaran data pribadi berasal dari serangan siber. Namun, satu kejadian dapat memenuhi kedua kategori sekaligus. (UU Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi)

PP Nomor 71 Tahun 2019 telah mengatur Penyelenggaraan Sistem dan Transaksi Elektronik. Keamanan Ketahanan Siber perlu menggunakan istilah dan konsep yang konsisten atau menjelaskan secara eksplisit apabila memperkenalkan kategori baru. (PP Nomor 71 Tahun 2019)

Harmonisasi perlu menghasilkan matriks yang memetakan:

1. objek yang diatur;
2. subjek kewajiban;
3. lembaga yang berwenang;
4. jenis laporan;
5. tenggat waktu;
6. kewenangan pemeriksaan;
7. jenis sanksi;
8. mekanisme keberatan; dan
9. aturan yang berlaku apabila terjadi pertentangan.

Keamanan Ketahanan Siber juga perlu memuat ketentuan transisi yang jelas. Organisasi harus mengetahui kewajiban mana yang tetap berlaku, mana yang berubah, kapan sistem pelaporan terpadu mulai digunakan, serta bagaimana izin, sertifikasi, dan penetapan IIK lama diperlakukan.

Harmonisasi bukan berarti memasukkan seluruh regulasi digital ke dalam satu undang-undang. Tujuannya adalah menghilangkan kontradiksi, duplikasi, kekosongan tanggung jawab, dan kewajiban pelaporan berulang.

> **Satu negara tidak boleh meminta satu insiden dilaporkan melalui lima pintu, diperiksa dengan lima standar, dan dihukum melalui lima interpretasi yang tidak saling berbicara.**

10.6 Norma yang Wajib Berada dalam Undang-Undang

Undang-undang harus memuat pilihan politik hukum yang mendasar. Peraturan pelaksanaan digunakan untuk rincian yang teknis, operasional, dan mudah berubah. Peraturan pelaksanaan tidak boleh diberi cek kosong untuk menentukan sendiri ruang lingkup kekuasaan negara atau beban utama warga dan industri.

Norma berikut harus berada dalam batang tubuh Keamanan Ketahanan Siber:

Definisi pokok, termasuk keamanan siber, ketahanan siber, insiden, krisis, Infrastruktur Informasi Kritikal, penyelenggara, penyedia produk dengan elemen digital, serta operasi pengaruh terkoordinasi.

Subjek kewajiban, yaitu pihak mana yang tunduk kepada kewajiban tertentu dan berdasarkan titik kait apa.

Kelembagaan, termasuk pembagian fungsi antara BSSN, BIN, Polri, TNI, Komdigi, Kemendagri, kementerian teknis, dan regulator sektoral.

Jenis kewenangan, seperti koordinasi, peringatan dini, permintaan informasi, audit, respons insiden, dan aktivasi krisis.

Batas kewenangan, termasuk tujuan, tingkat intrusi, otorisasi, durasi, penggunaan data, retensi, audit, serta pertanggungjawaban.

Pembatasan hak, yang harus mempunyai dasar, tujuan sah, kebutuhan, proporsionalitas, jangka waktu, dan mekanisme keberatan.

Tingkat kondisi nasional, yaitu Normal, Eskalasi, Tegang, dan Darurat, beserta indikator umum, pejabat penetap, akibat hukum, durasi, perpanjangan, dan pengakhiran.

Prinsip kewajiban berbasis risiko, agar standar dapat dibedakan menurut dampak, kekritisan, skala organisasi, jenis data, dan kemampuan nasional.

Prinsip pelaporan insiden, meliputi ambang materialitas, pelaporan bertahap, saluran terpadu, kerahasiaan, dan perlindungan pelapor beritikad baik.

Prinsip sanksi, termasuk faktor pemberat dan peringan, tangga sanksi administratif, serta pidana sebagai *ultimum remedium*.

Pengawasan dan pemulihan, meliputi audit independen, pelaporan kepada Presiden dan DPR, mekanisme keberatan, koreksi keputusan, dan tanggung jawab atas penyalahgunaan kewenangan.

Hal-hal yang dapat ditempatkan dalam peraturan pelaksanaan antara lain format laporan, struktur data pertukaran, standar teknis, metode penilaian, prosedur komunikasi, daftar indikator operasional, mekanisme sertifikasi rinci, dan tata cara latihan.

Namun, delegasi harus menyebutkan siapa yang membuat peraturan, materi apa yang boleh diatur, konsultasi apa yang diperlukan, tenggat penyusunan, dan bagaimana regulasi lintas lembaga diselaraskan.

> **Undang-undang menetapkan pagar. Peraturan pelaksanaan mengatur cara berjalan di dalam pagar tersebut. Jangan membiarkan peraturan pelaksanaan menentukan sendiri di mana pagar akan dibangun.**

10.7 Peta Jalan Kedaulatan Siber 2026–2035

Kedaulatan siber tidak dapat dibangun dalam satu tahun anggaran. Ia membutuhkan kesinambungan lintas kabinet, kepemimpinan lembaga, dan siklus pengadaan. Karena itu, Keamanan Ketahanan Siber perlu diikuti peta jalan nasional sampai 2035 dengan sasaran, penanggung jawab, pendanaan, serta indikator yang dapat diaudit.

Tahap I: 2026–2027 — Menertibkan Tata Kelola dan Mengetahui Apa yang Dimiliki

Prioritas tahap pertama adalah membangun fondasi hukum dan gambaran nasional.

Agenda utamanya mencakup:

- menetapkan pembagian fungsi dan rantai koordinasi nasional;
- membentuk National Cyber Situation Room;
- memetakan aset, fungsi kritikal, data strategis, dan dependensi lintas sektor;
- menetapkan klasifikasi IIK berbasis risiko;
- menyusun protokol Normal–Eskalasi–Tegang–Darurat;
- membangun satu pintu pelaporan insiden;
- memetakan regulasi yang tumpang tindih;
- menyusun peta peran dan kompetensi siber; dan
- menetapkan indikator dasar ketahanan nasional.

Hasil yang diharapkan bukan jumlah perangkat baru, melainkan **negara mengetahui apa yang harus dilindungi, siapa yang bertanggung jawab, dan bagaimana keputusan dibuat ketika insiden terjadi**.

Tahap II: 2028–2030 — Memperkuat Kapasitas Nasional

Tahap kedua berfokus pada kemampuan manusia dan organisasi.

Agenda utamanya meliputi:

- memperkuat CSIRT pemerintah, sektor, dan daerah;
- membangun Akademi Siber Nasional sebagai jaringan;
- mengembangkan pusat latihan dan simulasi lintas sektor;
- memperkuat kemampuan forensik serta preservasi bukti elektronik;
- membangun mekanisme pertukaran intelijen ancaman;
- menerapkan pengadaan berbasis keamanan dan interoperabilitas;
- memperluas riset kriptografi, keamanan AI, perangkat keras, dan sistem industri;
- mengembangkan skema pengungkapan kerentanan nasional; dan
- membangun kemampuan pemulihan layanan kritikal tanpa ketergantungan tunggal.

Indikator keberhasilan harus mengukur waktu deteksi, waktu koordinasi, kecepatan pemulihan, kualitas keputusan, kesiapan cadangan, dan kemampuan audit—bukan hanya jumlah pelatihan.

Tahap III: 2031–2033 — Menguasai Rantai Pasokan Strategis

Pada tahap ketiga, Indonesia harus berpindah dari pengguna yang semakin mahir menjadi negara yang menguasai bagian-bagian strategis rantai pasokan.

Prioritasnya adalah:

- inventaris komponen perangkat lunak, perangkat keras, firmware, API, model AI, dan data latih pada sistem kritikal;
- kemampuan audit dan pengujian independen;
- kendali atas identitas digital serta kunci kriptografi strategis;
- portabilitas data, model, konfigurasi, dan aturan deteksi;
- pengembangan komponen nasional pada titik yang mempunyai nilai keamanan dan ekonomi tinggi;
- penguatan industri keamanan siber domestik;
- kemampuan operasi terbatas ketika layanan eksternal terganggu; dan
- pengujian berkala atas strategi keluar dari pemasok.

Referensi internal “Strategic Blueprint: AI Integration in the Corporate SOC” menekankan bahwa ketergantungan tidak hanya berasal dari perangkat lunak tertutup. Ketergantungan juga dapat muncul pada teknologi terbuka ketika hanya satu orang memahami sistem, dokumentasi tidak tersedia, atau proyek tidak lagi dipelihara.

Karena itu, **kedaulatan bukan soal memilih *open source* atau *proprietary*. Kedaulatan adalah kemampuan mengaudit, mengendalikan, memindahkan, memulihkan, dan mengganti.**

Tahap IV: 2034–2035 — Menjadi Produsen dan Mitra Strategis Dunia

Tahap keempat menempatkan Indonesia sebagai produsen teknologi, pengetahuan, standar, serta diplomasi siber.

Agenda utamanya meliputi:

- mengekspor produk dan layanan keamanan siber;
- memperluas pengakuan kompetensi tenaga Indonesia;
- memimpin latihan siber regional;
- memperkuat bantuan teknis bagi negara berkembang;
- mengusulkan standar internasional yang mewakili kepentingan negara berpenduduk besar dan ekonomi berkembang;
- membangun pusat riset berkelas dunia;
- memperluas diplomasi norma perilaku negara di ruang siber; dan
- menjadikan ASEAN sebagai ruang pertahanan kolektif yang menghormati kedaulatan masing-masing negara.

Pada tahap ini, keberhasilan Indonesia tidak hanya terlihat dari berkurangnya serangan. Keberhasilan terlihat ketika teknologi Indonesia dipercaya, ahli Indonesia diminta memimpin, standar Indonesia menjadi rujukan, dan posisi diplomatik Indonesia didukung oleh kemampuan teknis yang nyata.

Peta jalan perlu ditinjau sedikitnya setiap dua tahun. Teknologi, ancaman, dan geopolitik berubah terlalu cepat untuk menunggu satu dekade. Namun, perubahan peta jalan tidak boleh menghapus tujuan besarnya: **pada 2035 Indonesia harus mempunyai kemampuan menentukan nasib digitalnya sendiri.**

10.8 Sepuluh Keputusan untuk Pemimpin Negara

Bab ini ditutup dengan sepuluh keputusan yang merangkum keseluruhan buku. Keputusan ini bukan daftar keinginan teknis. Ini adalah pilihan strategis yang harus dibuat oleh Presiden, DPR, menteri, kepala badan, pimpinan sektor, dan pemimpin nasional.

Keputusan 1 — Tetapkan Satu Komando, Bukan Satu Penguasa

Tetapkan satu mekanisme komando nasional dengan pembagian fungsi yang jelas. BSSN menjadi koordinator teknis nasional; BIN menjalankan fungsi intelijen; Polri menangani penyidikan pidana; TNI menjalankan pertahanan sesuai mandat; Komdigi mengatur ekosistem digital; Kemendagri mengoordinasikan kesiapan daerah; dan regulator sektoral tetap bertanggung jawab pada sektornya.

Dalam kondisi normal digunakan koordinasi federatif. Dalam krisis nasional diaktifkan satu rantai komando yang terbatas, sementara, terukur, dan dapat diaudit.

Keputusan 2 — Lindungi Fungsi Kritikal, Bukan Sekadar Nama Institusi

Tentukan IIK berdasarkan dampak kegagalan, ketergantungan, waktu pemulihan, keselamatan manusia, layanan publik, ekonomi, dan keamanan nasional.

Daftar institusi yang statis akan cepat usang. Negara harus mengetahui fungsi apa yang tidak boleh berhenti dan rantai ketergantungan apa yang dapat menimbulkan dampak kaskade.

Keputusan 3 — Bangun Tangga Krisis yang Terukur

Normakan empat kondisi: **Normal, Eskalasi, Tegang, dan Darurat**. Setiap tingkat harus mempunyai indikator, pejabat penetap, kewenangan, pemimpin, durasi, mekanisme komunikasi, pengawasan, dan syarat kembali ke kondisi normal.

Status darurat tidak boleh berlaku tanpa batas. Setiap perpanjangan harus mempunyai alasan tertulis dan mekanisme pengawasan.

Keputusan 4 — Atur Berdasarkan Risiko, Bukan Ketakutan

Tetapkan kewajiban dasar bagi semua penyelenggara, kemudian tingkatkan kewajiban sesuai kekritisan, dampak, skala, jenis data, jumlah pengguna, dan kemampuan mengendalikan risiko.

Regulasi harus keras terhadap risiko besar, membantu pelaku yang kekurangan kapasitas, dan tidak mengubah keamanan menjadi hambatan masuk bagi inovator Indonesia.

Keputusan 5 — Satu Insiden, Satu Laporan, Satu Gambaran Nasional

Bangun saluran nasional terpadu dengan ambang materialitas, laporan bertahap, format bersama, kerahasiaan, serta penerusan yang sah kepada otoritas berwenang.

Pelaporan harus diselaraskan dengan UU PDP dan regulasi sektoral. Tujuan pertama laporan adalah pertolongan dan pembelajaran, bukan perburuan pihak yang dapat dipermalukan.

Keputusan 6 — Pertahankan Ruang Informasi Tanpa Membungkam Demokrasi

Atur operasi pengaruh berdasarkan perilaku manipulatif, koordinasi tersembunyi, penyamaran, otomatisasi, pendanaan, dan amplifikasi tidak autentik.

Kritik, satire, oposisi, dan perbedaan pendapat tidak boleh otomatis diperlakukan sebagai ancaman siber. **Negara harus menindak manipulasi, bukan ketidaksukaan terhadap isi.**

Keputusan 7 — Kuasai AI dan Rantai Pasokan melalui Kemampuan Keluar

Wajibkan pengawasan manusia untuk keputusan berisiko tinggi, pengujian risiko AI, pencatatan keputusan, keamanan model, pembaruan, inventaris komponen, serta tanggung jawab sepanjang siklus hidup produk.

Setiap sistem strategis harus mempunyai *sovereign exit strategy*: data dapat dipindahkan, sistem dapat diganti, model dapat diaudit, layanan dapat dipulihkan, dan pengetahuan tetap berada di Indonesia.

Keputusan 8 — Bangun Manusia, Jangan Mengejar Jumlah Sertifikat

Bentuk Peta Peran dan Kompetensi Siber Nasional. Integrasikan sertifikasi dengan sistem nasional, kebutuhan industri, pengalaman, portofolio, simulasi, dan rekam etika.

Keberhasilan strategi SDM diukur dari kemampuan menangani insiden, mengambil keputusan, mengaudit sistem, dan membangun teknologi—bukan dari jumlah sertifikat yang diterbitkan.

Keputusan 9 — Berikan Kewenangan, tetapi Bangun Pagar Hukum

Setiap pemantauan, audit, akses data, dan tindakan intrusif harus mempunyai tujuan, objek, dasar hukum, otorisasi, durasi, batas penggunaan, retensi, pemusnahan, serta *audit trail*.

Sanksi administratif harus bertingkat. Pidana digunakan sebagai *ultimum remedium* untuk kesengajaan, sabotase, penipuan, penyembunyian material, pembiaran sadar, atau kelalaian berat. Peneliti keamanan yang bertindak dalam batas kewenangan dan beritikad baik harus memperoleh kepastian hukum.

Keputusan 10 — Jadikan Kedaulatan sebagai Kemampuan, Bukan Slogan

Bangun yurisdiksi yang mempunyai titik kait dan dapat ditegakkan. Perkuat atribusi berbasis bukti. Sediakan titik kontak internasional 24/7. Percepat preservasi bukti, bantuan hukum, respons insiden, dan koordinasi diplomatik.

Pada saat yang sama, kuasai data, identitas, kriptografi, komputasi, kemampuan audit, pemulihan, dan teknologi strategis. Indonesia harus mampu bekerja sama dengan siapa pun tanpa menjadi bergantung sepenuhnya kepada siapa pun.

Sepuluh keputusan ini harus dibaca sebagai satu arsitektur. Komando tanpa batas hukum berbahaya. Kewajiban tanpa talenta tidak dapat dilaksanakan. Pelaporan tanpa kepercayaan akan gagal. AI tanpa penguasaan rantai pasokan akan memperbesar ketergantungan. Ekstrateritorialitas tanpa diplomasi dan bukti tidak dapat ditegakkan.

RANGKUMAN BAB 10

Bidang strategis	Masalah yang harus diselesaikan	Keputusan utama	Hasil yang dituju
Yurisdiksi siber	Pelaku, korban, sistem, data, pembayaran, dan bukti tersebar di berbagai negara	Gunakan beberapa titik kait yang jelas dan dapat diverifikasi	Yurisdiksi Indonesia kuat secara hukum dan realistis untuk ditegakkan
Ekstrateritorialitas	Pasal yang terlalu luas berpotensi tidak efektif dan memicu konflik	Bedakan kewajiban administratif, perdata, pidana, serta tindakan perlindungan	Penegakan lintas batas tepat sasaran dan dapat dilaksanakan
Atribusi	Indikator teknis mudah dipalsukan atau disalahartikan	Gabungkan bukti teknis, operasional, finansial, manusia, dan strategis	Pernyataan negara akurat, terukur, dan dapat dipercaya
Kerja sama internasional	Bukti dapat hilang sebelum prosedur formal selesai	Bentuk titik kontak 24/7 serta pisahkan preservasi dari penyerahan data	Respons cepat tanpa mengabaikan hukum dan privasi
Harmonisasi nasional	Kewajiban dan kewenangan tersebar dalam banyak regulasi	Selaraskan Keamanan Ketahanan Siber dengan UU PDP, UU ITE, PP PSTE, hukum pidana, dan regulasi sektoral	Tidak ada laporan, audit, atau sanksi yang saling bertentangan
Norma undang-undang	Materi pokok berisiko diserahkan kepada peraturan pelaksanaan	Tempatkan definisi, kewenangan, batas HAM, krisis, sanksi, pengawasan, dan hak keberatan dalam undang-undang	Kepastian hukum dan kontrol demokratis terhadap kekuasaan siber
Tahap 2026–2027	Negara belum mempunyai gambaran serta tata kelola terpadu	Bangun komando, inventaris, klasifikasi IIK, tangga krisis, dan pelaporan terpadu	Negara mengetahui apa yang dilindungi dan siapa yang bertanggung jawab
Tahap 2028–2030	Kapasitas manusia dan organisasi belum merata	Perkuat CSIRT, akademi, latihan, forensik, riset, dan pengadaan aman	Kemampuan nasional meningkat dan tersebar ke daerah
Tahap 2031–2033	Ketergantungan rantai pasokan tetap tinggi	Kuasai audit, portabilitas, identitas, kriptografi, pemulihan, dan komponen strategis	Indonesia mampu mengendalikan dan mengganti teknologi kritikal
Tahap 2034–2035	Indonesia masih dominan sebagai pasar teknologi	Ekspor teknologi, pengetahuan, standar, dan kepemimpinan diplomatik	Indonesia menjadi produsen serta mitra strategis dunia
Ukuran kedaulatan	Kedaulatan mudah berhenti sebagai slogan politik	Ukur kemampuan mengambil keputusan, mengaudit, memindahkan, memulihkan, dan mengganti	Ketahanan digital yang terbukti melalui kemampuan nyata

PENUTUP

Keamanan Ketahanan Siber tidak boleh lahir hanya sebagai reaksi terhadap ketakutan. Undang-undang ini harus lahir dari keyakinan bahwa Indonesia mampu membangun masa depan digitalnya sendiri.

> **Keamanan siber bukan proyek satu lembaga.** Ia adalah kemampuan kolektif negara untuk mencegah, bertahan, merespons, memulihkan, belajar, dan menjadi lebih kuat setelah mengalami gangguan.
>
> **Ketahanan siber bukan jumlah perangkat yang dibeli.** Ia adalah kemampuan layanan publik untuk tetap berjalan ketika sebagian teknologi gagal.
>
> **Kedaulatan siber bukan pemutusan hubungan dengan dunia.** Ia adalah kemampuan bekerja sama tanpa kehilangan kendali atas keputusan, data, pengetahuan, dan masa depan.

Karena itu, keberhasilan Keamanan Ketahanan Siber tidak boleh dinilai dari panjangnya undang-undang, banyaknya peraturan turunan, besarnya anggaran, atau kerasnya ancaman pidana. Keberhasilannya harus dilihat dari pertanyaan yang lebih mendasar:

- Apakah keputusan dapat diambil lebih cepat?
- Apakah kewenangan menjadi lebih jelas?
- Apakah infrastruktur kritikal lebih terlindungi?
- Apakah insiden lebih cepat dilaporkan dan dipulihkan?
- Apakah inovator domestik memperoleh ruang untuk tumbuh?
- Apakah hak warga tetap terlindungi?
- Apakah Indonesia mampu mengaudit dan mengganti teknologi strategis?
- Apakah talenta Indonesia mampu membangun solusi sendiri?
- Apakah negara dapat bekerja sama dengan dunia dari posisi yang setara?

Jika jawabannya “ya”, Keamanan Ketahanan Siber telah menjadi instrumen kedaulatan. Jika jawabannya hanya “lebih banyak laporan, lebih banyak izin, lebih banyak alat, dan lebih banyak ancaman sanksi”, maka Indonesia hanya menambah birokrasi tanpa menambah ketahanan.

> **Indonesia tidak kekurangan ancaman. Indonesia membutuhkan keberanian untuk menentukan prioritas, kedisiplinan untuk membatasi kekuasaan, dan konsistensi untuk membangun kemampuan nasional selama satu dekade.**

Pada akhirnya, teknologi akan terus berubah. AI akan berkembang, kriptografi akan bergeser, rantai pasokan akan berpindah, dan teknik serangan akan semakin canggih. Undang-undang tidak mungkin mengejar setiap perangkat dan metode.

Yang dapat dibangun oleh undang-undang adalah fondasi yang bertahan: pembagian tanggung jawab yang jelas, pengelolaan risiko, penghormatan terhadap hak, akuntabilitas kekuasaan, kemampuan manusia, keterbukaan standar, penguasaan pengetahuan, dan keberanian untuk mandiri.

> **Negara yang berdaulat bukan negara yang memiliki semua teknologi. Negara yang berdaulat adalah negara yang memahami teknologi yang digunakannya, mampu menentukan arah penggunaannya, dan selalu mempunyai pilihan ketika ketergantungan berubah menjadi ancaman.**

REFERENSI BAB 10

- Undang-Undang Nomor 1 Tahun 2024 tentang Perubahan Kedua atas Undang-Undang Nomor 11 Tahun 2008 tentang Informasi dan Transaksi Elektronik. (Database Peraturan BPK)
- Undang-Undang Nomor 27 Tahun 2022 tentang Pelindungan Data Pribadi. (Database Peraturan BPK)
- Peraturan Pemerintah Nomor 71 Tahun 2019 tentang Penyelenggaraan Sistem dan Transaksi Elektronik. (Database Peraturan BPK)
- United Nations Office on Drugs and Crime. “United Nations Convention against Cybercrime.” (UNODC)
- Onno W. Purbo. “CEH Mastery: AI-Assisted OSINT”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo. “Strategic Blueprint: AI Integration in the Corporate SOC”, 2026. Referensi internal ChatGPT Library.
- Onno W. Purbo. “Framework Peringkat Keamanan Siber dan Kepatuhan Data Pribadi untuk Dunia Perbankan Indonesia”, 2025. Referensi internal ChatGPT Library.
- A. Ikhwanudin dan Onno W. Purbo. “Panduan Praktis Kepatuhan UU PDP dan Keamanan Data Institusi: Open Source Approach”, 2025. Referensi internal ChatGPT Library.

PENUTUP BUKU

INDONESIA TIDAK CUKUP HANYA AMAN — INDONESIA HARUS TANGGUH DAN BERDAULAT

Penutup menegaskan bahwa:

1. Tidak ada sistem yang sepenuhnya kebal dari serangan.
2. Ketahanan ditentukan oleh kemampuan mendeteksi, merespons, memulihkan, dan belajar.
3. Kedaulatan tidak berarti menutup diri dari dunia.
4. Kedaulatan berarti Indonesia tetap dapat mengambil keputusan, mengaudit teknologi, menguasai data, memulihkan layanan, dan mengganti pemasok ketika kepentingan nasional menuntutnya.
5. Keamanan Ketahanan Siber harus menghasilkan kapabilitas nyata, bukan menambah birokrasi, formulir kepatuhan, dan ketergantungan teknologi.

GLOSSARY

Istilah	Definisi
Akuntabilitas	Kewajiban lembaga, pejabat, dan penyelenggara sistem untuk menjelaskan, membuktikan, serta mempertanggungjawabkan keputusan, tindakan, penggunaan data, dan hasil pengelolaan keamanan siber.
Algoritma	Urutan aturan atau langkah komputasi untuk mengolah masukan menjadi keluaran. Dalam kebijakan publik, penggunaan algoritma harus memperhatikan keamanan, transparansi, bias, hak warga, dan pertanggungjawaban.
Ambang batas insiden	Ukuran yang menentukan kapan suatu gangguan harus dilaporkan, di eskalasikan, atau ditetapkan sebagai krisis berdasarkan dampak, luas gangguan, durasi, jumlah korban, dan kekritisan layanan.
Amplifikasi tidak autentik	Peningkatan jangkauan atau popularitas informasi secara artifisial melalui akun palsu, bot, jaringan terkoordinasi, atau manipulasi sistem rekomendasi sehingga terlihat sebagai dukungan publik yang alami.
Arsitektur hibrida	Penggunaan kombinasi teknologi lokal, komputasi awan, sumber terbuka, dan produk komersial sesuai klasifikasi data, risiko, kebutuhan operasi, dan tingkat kendali yang diperlukan.
Aset digital	Data, perangkat keras, perangkat lunak, identitas, akun, jaringan, model AI, konfigurasi, layanan, dan pengetahuan yang mempunyai nilai bagi organisasi atau negara.

Atribusi	Proses menghubungkan suatu serangan dengan infrastruktur, kelompok, organisasi, individu, atau negara berdasarkan kombinasi bukti teknis, operasional, finansial, hukum, dan intelijen.
Audit keamanan	Pemeriksaan sistematis terhadap tata kelola, arsitektur, konfigurasi, proses, bukti, dan kontrol keamanan untuk menentukan kesesuaian, efektivitas, serta tingkat risiko.
Audit trail	Catatan berurutan mengenai siapa yang melakukan tindakan, kapan tindakan dilakukan, sistem atau data yang diakses, dasar kewenangan, dan perubahan yang dihasilkan.
Baseline keamanan	Sekumpulan kontrol minimum yang wajib diterapkan oleh seluruh penyelenggara, seperti pengelolaan akses, pembaruan keamanan, pencadangan, pencatatan, manajemen risiko, dan respons insiden.
Bot	Program otomatis yang menjalankan aktivitas pada jaringan atau platform digital. Bot tidak selalu berbahaya; legalitas dan risikonya ditentukan oleh tujuan, perilaku, penyamaran, koordinasi, dan dampaknya.
BSSN	Badan Siber dan Sandi Negara, lembaga pemerintah yang menjalankan tugas pemerintahan di bidang keamanan siber dan persandian sesuai ketentuan peraturan perundang-undangan. Dalam buku ini, BSSN diarahkan sebagai koordinator teknis keamanan siber nasional.
Chain of custody	Dokumentasi yang menjaga keterlacakan penguasaan barang bukti sejak ditemukan, dikumpulkan, dipindahkan, dianalisis, disimpan, sampai disampaikan dalam proses hukum.
Cloud computing	Model penyediaan sumber daya komputasi—seperti server, penyimpanan, basis data, dan aplikasi—melalui jaringan secara fleksibel dan sesuai kebutuhan.

Command and control	Mekanisme pengendalian yang digunakan penyerang untuk berkomunikasi dengan perangkat atau sistem yang telah dikuasai. Dalam konteks kelembagaan, istilah ini juga dapat merujuk pada struktur pemberian perintah dan pengendalian operasi.
Confidentiality	Prinsip yang memastikan informasi hanya dapat diakses oleh pihak yang memiliki kewenangan. Bersama integritas dan ketersediaan, kerahasiaan merupakan unsur dasar keamanan informasi.
Coordinated inauthentic behavior	Perilaku terkoordinasi yang menyembunyikan identitas, sumber, atau hubungan antar aktor untuk memanipulasi percakapan dan persepsi publik. Penilaiannya berfokus pada perilaku, bukan isi pendapat.
Coordinated vulnerability disclosure	Proses terkoordinasi antara peneliti, penyedia, operator, dan otoritas untuk memvalidasi, memperbaiki, serta mengungkapkan kerentanan secara bertanggung jawab.
CSIRT	*Computer Security Incident Response Team*, yaitu tim yang menerima laporan, menganalisis, mengoordinasikan, dan membantu penanganan serta pemulihan insiden keamanan siber dalam lingkup tertentu.
Cyber crisis management	Tata kelola untuk mengenali, menetapkan, mengendalikan, mengomunikasikan, dan mengakhiri krisis siber yang berdampak lintas organisasi, sektor, wilayah, atau fungsi negara.
Cyber resilience	Kemampuan organisasi atau negara untuk mengantisipasi, bertahan, merespons, memulihkan, beradaptasi, dan tetap menjalankan fungsi penting ketika menghadapi gangguan siber.
Data pribadi	Data tentang orang perseorangan yang teridentifikasi atau dapat diidentifikasi, baik secara langsung maupun melalui penggabungan dengan informasi lain.

Data residency	Ketentuan atau keputusan mengenai negara atau wilayah tempat data disimpan dan diproses secara fisik. Lokasi data tidak dengan sendirinya menjamin kedaulatan atau keamanan.
Defense-in-depth	Strategi pertahanan berlapis yang menggunakan beberapa kontrol teknis dan organisasi agar kegagalan satu kontrol tidak langsung menyebabkan kegagalan seluruh sistem.
Dependensi kritikal	Ketergantungan suatu fungsi penting terhadap penyedia, sistem, data, jaringan, komponen, atau tenaga tertentu yang kegagalannya dapat menimbulkan gangguan besar.
Deteksi	Kemampuan menemukan aktivitas, kelemahan, perubahan, atau pola yang dapat menunjukkan adanya ancaman maupun insiden keamanan.
Due process	Prinsip bahwa tindakan negara harus memiliki dasar hukum, otorisasi yang tepat, prosedur yang adil, pencatatan, kesempatan memberikan tanggapan, mekanisme keberatan, dan akses terhadap pemulihan.
Eksfiltrasi data	Pemindahan data secara tidak sah dari suatu sistem atau organisasi menuju pihak atau lokasi yang tidak berwenang.
Explainability	Kemampuan untuk memberikan penjelasan yang dapat dipahami mengenai cara sistem AI menghasilkan rekomendasi atau keputusan, termasuk faktor utama, keterbatasan, dan tingkat ketidakpastiannya.
Ekstrateritorialitas	Penerapan hukum nasional terhadap perbuatan, subjek, layanan, atau dampak yang berada di luar wilayah negara berdasarkan titik kait yang diakui dan dapat ditegakkan.

False positive	Peringatan yang menunjukkan seolah-olah terdapat ancaman atau pelanggaran, padahal setelah diperiksa aktivitas tersebut tidak berbahaya.
Forensik digital	Proses memperoleh, menjaga, memeriksa, menganalisis, dan menyajikan bukti digital dengan metode yang dapat dipertanggungjawabkan.
Good-faith security research	Penelitian keamanan yang dilakukan dengan itikad baik, dalam batas kewenangan, menggunakan metode proporsional, tidak menyalahgunakan data, serta bertujuan memperbaiki keamanan.
Hak subjek data	Hak seseorang atas data pribadinya, termasuk memperoleh informasi, mengakses, memperbaiki, menghapus, atau menggunakan hak lain sesuai hukum yang berlaku.
Human-in-the-loop	Tata kelola yang mempertahankan keterlibatan manusia secara bermakna dalam peninjauan dan pengambilan keputusan, terutama untuk tindakan berisiko tinggi atau yang mempengaruhi hak warga.
Indikator kompromi	Data teknis yang menunjukkan kemungkinan sistem telah disusupi, seperti hash berbahaya, domain, alamat jaringan, nama berkas, atau pola aktivitas tertentu. Indikator merupakan petunjuk yang tetap harus diverifikasi.
Infrastruktur Informasi Kritikal	sistem elektronik yang memanfaatkan teknologi informasi dan/atau teknologi operasional, baik berdiri sendiri maupun saling bergantung dengan sistem lain, yang gangguan atau kerusakannya dapat berdampak serius terhadap kepentingan umum, pelayanan publik, pertahanan dan keamanan, atau perekonomian nasional.
Integritas	Prinsip yang memastikan data, perangkat lunak, konfigurasi, dan catatan tidak diubah atau dirusak tanpa kewenangan.

Intelijen ancaman siber	Pengetahuan yang telah dianalisis mengenai pelaku, kemampuan, infrastruktur, sasaran, teknik, dan pola ancaman untuk mendukung keputusan keamanan.
Interoperabilitas	Kemampuan sistem, organisasi, dan proses yang berbeda untuk bertukar informasi serta bekerja bersama tanpa ketergantungan yang tidak perlu terhadap satu pemasok.
Jejak keputusan	Rekaman mengenai informasi yang digunakan, pilihan yang dipertimbangkan, pihak yang menyetujui, waktu keputusan, serta alasan suatu tindakan diambil.
Kedaulatan data	Kemampuan negara atau organisasi mengendalikan akses, penggunaan, perlindungan, pemindahan, pemulihan, dan yurisdiksi atas data strategisnya.
Kedaulatan teknologi	Kemampuan menentukan arah teknologi, memahami dan mengaudit sistem, menguasai data serta pengetahuan, menjaga operasi, dan mengganti teknologi atau pemasok ketika diperlukan.
Keamanan rantai pasokan	Perlindungan terhadap risiko yang berasal dari perangkat keras, *firmware*, perangkat lunak, pustaka, layanan awan, API, model AI, data, pembaruan, integrator, pemasok, dan tenaga pemeliharaan.
Keadaan darurat siber	Tingkat tertinggi dalam tangga krisis ketika kesinambungan pemerintahan, keselamatan publik, ekonomi nasional, pertahanan, atau fungsi kritikal menghadapi ancaman serius.
Kegagalan berantai	Gangguan yang menyebar dari satu sistem, pemasok, atau sektor kepada sistem dan sektor lain karena hubungan ketergantungan.

Kerentanan	Kelemahan pada teknologi, proses, konfigurasi, desain, atau manusia yang dapat dimanfaatkan untuk mengganggu kerahasiaan, integritas, atau ketersediaan sistem.
Ketersediaan	Prinsip yang memastikan sistem, data, dan layanan dapat digunakan oleh pihak yang berwenang ketika dibutuhkan.
Komando krisis	Rantai kepemimpinan yang diaktifkan secara terbatas ketika terjadi krisis untuk mempercepat keputusan, koordinasi sumber daya, komunikasi, dan pemulihan.
Komputasi berdaulat	Kapasitas komputasi yang yurisdiksi, data, identitas, kunci, operasi, serta kesinambungannya dapat dikendalikan sesuai kepentingan nasional.
Least privilege	Prinsip pemberian hak akses minimum yang benar-benar diperlukan seseorang, perangkat, aplikasi, atau layanan untuk menjalankan tugasnya.
Lock-in individual	Ketergantungan organisasi kepada satu atau beberapa orang karena pengetahuan kritikal tidak didokumentasikan, tidak dibagikan, atau tidak memiliki tenaga pengganti.
Manajemen insiden	Proses terkoordinasi untuk menemukan, memvalidasi, membatasi, menangani, memulihkan, mendokumentasikan, dan mengambil pelajaran dari insiden.
Manajemen risiko	Proses mengidentifikasi, menganalisis, mengevaluasi, menangani, memantau, dan mengkomunikasikan resiko sesuai tujuan organisasi atau negara.
Materialitas insiden	Tingkat kepentingan suatu insiden berdasarkan dampak aktual atau potensial terhadap layanan, manusia, data, ekonomi, sektor, wilayah, reputasi, dan keamanan nasional.

Metadata	Data yang menjelaskan data atau aktivitas lain, misalnya waktu, lokasi, identitas perangkat, alamat jaringan, ukuran berkas, dan hubungan komunikasi. Metadata dapat menjadi sensitif ketika digabungkan.
Minimalisasi data	Prinsip untuk mengumpulkan, mengakses, membagikan, dan menyimpan hanya data yang benar-benar diperlukan bagi tujuan yang sah.
National Cyber Situation Room	Pusat situasi nasional yang menyatukan gambaran ancaman, status layanan kritikal, eskalasi, keputusan, dan koordinasi respons tanpa harus memusatkan seluruh data mentah.
Necessity	Prinsip bahwa tindakan yang membatasi hak atau mengakses data hanya boleh dilakukan apabila benar-benar diperlukan untuk mencapai tujuan sah dan tidak tersedia cara lain yang sama efektif tetapi kurang intrusif.
Operasi pengaruh asing	Upaya yang diarahkan atau didukung pihak asing untuk mempengaruhi persepsi, perilaku, atau keputusan masyarakat dan negara sasaran melalui metode tersembunyi atau manipulatif.
Operasi pengaruh terkoordinasi	Kegiatan terorganisasi untuk memanipulasi distribusi informasi, persepsi, atau perilaku publik melalui koordinasi tersembunyi, penyamaran identitas, otomatisasi, pendanaan, atau amplifikasi tidak autentik.
Open source	Perangkat lunak yang kode sumbernya tersedia untuk digunakan, diperiksa, dimodifikasi, dan didistribusikan berdasarkan ketentuan lisensinya. Keterbukaan kode tidak otomatis menjamin keamanan atau kedaulatan.
Otorisasi	Persetujuan sah yang menentukan siapa boleh melakukan tindakan, terhadap sistem atau data apa, untuk tujuan apa, dan dalam batas waktu berapa lama.

Pelaporan bertahap	Mekanisme pelaporan insiden yang dimulai dengan fakta minimum, dilanjutkan dengan pembaruan perkembangan, dan diakhiri dengan laporan final setelah investigasi lebih matang.
Pemrosesan data	Setiap tindakan terhadap data, termasuk memperoleh, mengumpulkan, mencatat, menyimpan, memperbaiki, menganalisis, mengungkapkan, memindahkan, menghapus, atau memusnahkan.
Penilaian dampak	Analisis sistematis mengenai kemungkinan akibat suatu teknologi, kebijakan, pemrosesan data, insiden, atau tindakan pemerintah terhadap keamanan, hak, layanan, dan masyarakat.
Penilaian risiko	Proses menentukan kemungkinan terjadinya ancaman dan besarnya dampak dengan mempertimbangkan aset, kerentanan, kontrol, ketergantungan, dan kemampuan pemulihan.
Peraturan pelaksanaan	Peraturan di bawah undang-undang yang mengatur rincian teknis dan operasional. Ia tidak boleh digunakan untuk menciptakan kewenangan pokok atau pembatasan hak yang tidak mempunyai dasar jelas dalam undang-undang.
Preservasi bukti	Tindakan menjaga data atau bukti yang telah ada agar tidak diubah, ditimpa, atau dihapus sambil menunggu proses hukum untuk memperoleh atau menyerahkannya.
Privacy by design	Prinsip yang menempatkan perlindungan privasi sejak tahap perencanaan dan desain sistem, bukan sebagai tambahan setelah sistem beroperasi.
Proporsionalitas	Prinsip bahwa kewajiban, pemantauan, pembatasan hak, atau sanksi harus sebanding dengan tingkat risiko, tujuan yang sah, kemampuan pihak yang diatur, dan dampak tindakan.

Provenance	Informasi mengenai asal-usul data, bukti, model, perangkat lunak, atau hasil analisis beserta perubahan yang terjadi sepanjang siklus hidupnya.
Pusat operasi keamanan	Fungsi organisasi yang memantau, mendeteksi, menganalisis, mengoordinasikan, dan mendokumentasikan penanganan ancaman serta insiden keamanan. Sering disebut *Security Operations Center* atau SOC.
Ransomware	Perangkat lunak atau operasi berbahaya yang mengenkripsi, mencuri, atau menguasai data dan sistem untuk menuntut pembayaran atau konsesi dari korban.
Rantai komando	Susunan kewenangan yang menjelaskan siapa memberikan perintah, siapa melaksanakan, siapa mengoordinasikan, dan siapa mempertanggungjawabkan keputusan.
Redundansi	Penyediaan komponen, jalur, tenaga, atau fasilitas pengganti agar fungsi penting tetap berjalan ketika komponen utama gagal.
Regulasi berbasis risiko	Pendekatan yang membedakan kewajiban dan intensitas pengawasan berdasarkan kemungkinan ancaman, besarnya dampak, kekritisan fungsi, skala, serta kemampuan organisasi.
Responsible disclosure	Pengungkapan kerentanan secara bertanggung jawab kepada pihak yang berwenang dengan bukti minimum, komunikasi terkoordinasi, pelindungan data, dan waktu perbaikan yang wajar sebelum publikasi.
Retensi data	Jangka waktu penyimpanan data sebelum data dihapus atau dimusnahkan sesuai tujuan, kebutuhan, klasifikasi, dan dasar hukum.

Risiko sistemik	Risiko yang kegagalannya dapat menyebar serta mengganggu banyak organisasi, sektor, wilayah, atau fungsi negara secara bersamaan.
Safe harbor	Jaminan perlindungan terbatas bagi pihak yang bertindak dengan itikad baik dan mematuhi syarat tertentu, misalnya organisasi yang melaporkan insiden atau peneliti yang mengungkapkan kerentanan secara bertanggung jawab.
Sandbox regulasi	Lingkungan kebijakan terkendali yang memungkinkan teknologi atau model bisnis diuji dengan batas, pengawasan, serta evaluasi tertentu sebelum diterapkan lebih luas.
Secure by default	Prinsip bahwa konfigurasi awal produk atau layanan telah menggunakan pilihan keamanan yang memadai tanpa mengharuskan pengguna mengaktifkannya sendiri.
Secure by design	Prinsip yang menjadikan keamanan sebagai bagian dari desain, pengembangan, pengujian, pengadaan, operasi, pemeliharaan, dan penghentian produk sejak awal.
Security Operations Center	Lihat **Pusat operasi keamanan**.
Severity	Ukuran tingkat keparahan teknis atau operasional suatu kerentanan, ancaman, atau insiden. *Severity* perlu dibedakan dari tingkat keyakinan atribusi dan materialitas pelaporan.
Single point of failure	Satu komponen, penyedia, tenaga, atau jalur yang kegagalannya dapat menghentikan keseluruhan fungsi karena tidak tersedia alternatif.

Situational awareness	Pemahaman bersama dan mutakhir mengenai ancaman, aset terdampak, status layanan, tindakan respons, kemampuan pemulihan, dan kemungkinan perkembangan situasi.
Sovereign exit strategy	Strategi yang memastikan data dapat dipindahkan, sistem dapat diganti, model dapat diaudit, layanan dapat dipulihkan, dan kompetensi tetap dikuasai ketika hubungan dengan pemasok berakhir.
Software Bill of Materials	Inventaris terstruktur mengenai komponen, pustaka, dependensi, dan versi yang membentuk suatu perangkat lunak, sehingga risiko serta kerentanan rantai pasokan dapat ditelusuri.
Sunset clause	Ketentuan yang membuat status, kewenangan, atau kebijakan khusus berakhir secara otomatis pada waktu tertentu kecuali diperpanjang melalui evaluasi dan persetujuan yang sah.
Supply-chain security	Lihat **Keamanan rantai pasokan**.
Tanggung jawab sepanjang siklus hidup	Kewajiban penyedia untuk menjaga keamanan sejak desain, produksi, distribusi, operasi, pembaruan, penanganan kerentanan, sampai penghentian dukungan produk.
Threat intelligence	Lihat **Intelijen ancaman siber**.
Titik kait yurisdiksi	Hubungan faktual dan hukum yang menjadi dasar penerapan hukum suatu negara, misalnya lokasi dampak, korban, pasar yang dilayani, sistem kritikal, atau data warga yang diproses.
Traffic Light Protocol	Skema penandaan yang membantu menentukan sejauh mana informasi keamanan boleh dibagikan kepada pihak lain. Protokol ini tidak menggantikan klasifikasi resmi atau kewajiban hukum.

Ultimum remedium	Prinsip yang menempatkan pidana sebagai sarana terakhir setelah instrumen pencegahan, pembinaan, perbaikan, dan sanksi administratif dinilai tidak memadai, khususnya untuk kesengajaan atau pelanggaran berat.
Vendor lock-in	Keadaan ketika organisasi sulit mengganti penyedia karena format tertutup, biaya migrasi tinggi, ketergantungan identitas, keterbatasan ekspor data, atau hilangnya pengetahuan internal.
Vulnerability disclosure policy	Kebijakan yang menjelaskan sistem yang boleh diuji, aktivitas yang diizinkan, saluran laporan, penanganan data, komunikasi, tenggat respons, dan perlindungan bagi penelitian beritikad baik.
Waktu pemulihan	Lama waktu yang dibutuhkan untuk mengembalikan fungsi atau layanan ke tingkat operasi yang dapat diterima setelah gangguan.
Zero trust	Pendekatan keamanan yang tidak memberikan kepercayaan hanya karena pengguna atau perangkat berada di dalam jaringan. Setiap akses harus diverifikasi berdasarkan identitas, konteks, kondisi perangkat, risiko, dan hak minimum yang diperlukan.

REFERENSI

Cybersecurity and Infrastructure Security Agency. (2023). Shifting the balance of cybersecurity risk: Principles and approaches for security-by-design and default. U.S. Department of Homeland Security. https://www.cisa.gov/resources-tools/resources/secure-by-design

Cybersecurity and Infrastructure Security Agency. (n.d.). Vulnerability disclosure policy platform. U.S. Department of Homeland Security. https://www.cisa.gov/resources-tools/services/vulnerability-disclosure-policy-vdp-platform

European Union Agency for Cybersecurity. (2022). European cybersecurity skills framework role profiles. Publications Office of the European Union. https://www.enisa.europa.eu/publications/european-cybersecurity-skills-framework-role-profiles

European Union Agency for Cybersecurity. (2022). European cybersecurity skills framework: User manual. Publications Office of the European Union. https://www.enisa.europa.eu/publications/european-cybersecurity-skills-framework-ecsf

European Parliament & Council of the European Union. (2022). Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union (NIS2 Directive). Official Journal of the European Union, L 333, 80–152. Publications Office of the European Union. https://eur-lex.europa.eu/eli/dir/2022/2555/oj

European Parliament & Council of the European Union. (2024). Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act). Official Journal of the European Union. Publications Office of the European Union. https://eur-lex.europa.eu/eli/reg/2024/1689/oj

European Parliament & Council of the European Union. (2024). Regulation (EU) 2024/2847 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act). Official Journal of the European Union. Publications Office of the European Union. https://eur-lex.europa.eu/eli/reg/2024/2847/oj

Ikhwanudin, A., & Purbo, O. W. (2025). Panduan praktis kepatuhan UU PDP & keamanan data institusi: Open source approach [Naskah elektronik]. Terbit mandiri.

International Organization for Standardization. (2022). Information security, cybersecurity and privacy protection—Information security management systems—Requirements (ISO/IEC Standard No. 27001:2022). ISO. https://www.iso.org/standard/27001

International Organization for Standardization. (2023). Information technology—Artificial intelligence—Management system (ISO/IEC Standard No. 42001:2023). ISO. https://www.iso.org/standard/81230.html

Komisi I Dewan Perwakilan Rakyat Republik Indonesia. (2026). Kerangka acuan kerja rapat dengar pendapat umum Panitia Kerja Rancangan Undang-Undang tentang Keamanan dan Ketahanan Siber [Dokumen kerja internal]. Komisi I DPR RI.

National Institute of Standards and Technology. (2012). Computer security incident handling guide (NIST Special Publication 800-61 Revision 2). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-61r2

National Institute of Standards and Technology. (2020). NIST privacy framework: A tool for improving privacy through enterprise risk management, version 1.0. U.S. Department of Commerce. https://doi.org/10.6028/NIST.CSWP.01162020

National Institute of Standards and Technology. (2020). Zero trust architecture (NIST Special Publication 800-207). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-207

National Institute of Standards and Technology. (2020). Workforce framework for cybersecurity (NICE Framework) (NIST Special Publication 800-181 Revision 1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-181r1

National Institute of Standards and Technology. (2022). Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities (NIST Special Publication 800-218). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-218

National Institute of Standards and Technology. (2023). Artificial intelligence risk management framework (AI RMF 1.0) (NIST AI 100-1). U.S. Department of Commerce. https://doi.org/10.6028/NIST.AI.100-1

National Institute of Standards and Technology. (2024). The NIST cybersecurity framework (CSF) 2.0 (NIST Cybersecurity White Paper 29). U.S. Department of Commerce. https://doi.org/10.6028/NIST.CSWP.29

Organisation for Economic Co-operation and Development. (2024). Recommendation of the Council on artificial intelligence. OECD Legal Instruments. https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449

Purbo, O. W. (2025). AI dalam cyber security: Dari teori hingga praktik pertahanan digital [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2025). Framework peringkat keamanan siber & kepatuhan data pribadi untuk dunia perbankan Indonesia [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2025). Kalau data pribadi bocor, apa risikonya? [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2026). AI-assisted penetration test [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2026). CEH mastery: AI-assisted OSINT [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2026). CEH mastery: Server korban untuk latihan penetration test [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2026). Open source SOC mastery: Membangun security operations center modern dengan tools gratis [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2026). Panduan praktis pengadaan barang dan jasa bidang IT [Naskah elektronik]. Terbit mandiri.

Purbo, O. W. (2026). Strategic blueprint: AI integration in the corporate SOC—A CISO's roadmap for cognitive cyber defense, digital sovereignty, and business resilience [Naskah elektronik]. Terbit mandiri.

Republik Indonesia. (1945). Undang-Undang Dasar Negara Republik Indonesia Tahun 1945. Sekretariat Negara Republik Indonesia. https://www.dpr.go.id/jdih/uu1945

Republik Indonesia. (2005). Undang-Undang Republik Indonesia Nomor 12 Tahun 2005 tentang pengesahan International Covenant on Civil and Political Rights (Kovenan Internasional tentang Hak-Hak Sipil dan Politik). Lembaran Negara Republik Indonesia Tahun 2005 Nomor 119. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/40261/uu-no-12-tahun-2005

Republik Indonesia. (2006). Undang-Undang Republik Indonesia Nomor 1 Tahun 2006 tentang bantuan timbal balik dalam masalah pidana. Lembaran Negara Republik Indonesia Tahun 2006 Nomor 18. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/40191/uu-no-1-tahun-2006

Republik Indonesia. (2008). Undang-Undang Republik Indonesia Nomor 11 Tahun 2008 tentang informasi dan transaksi elektronik. Lembaran Negara Republik Indonesia Tahun 2008 Nomor 58. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/37589/uu-no-11-tahun-2008

Republik Indonesia. (2008). Undang-Undang Republik Indonesia Nomor 14 Tahun 2008 tentang keterbukaan informasi publik. Lembaran Negara Republik Indonesia Tahun 2008 Nomor 61. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/39047/uu-no-14-tahun-2008

Republik Indonesia. (2014). Undang-Undang Republik Indonesia Nomor 30 Tahun 2014 tentang administrasi pemerintahan. Lembaran Negara Republik Indonesia Tahun 2014 Nomor 292. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/38695/uu-no-30-tahun-2014

Republik Indonesia. (2016). Undang-Undang Republik Indonesia Nomor 19 Tahun 2016 tentang perubahan atas Undang-Undang Nomor 11 Tahun 2008 tentang informasi dan transaksi elektronik. Lembaran Negara Republik Indonesia Tahun 2016 Nomor 251. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/37582/uu-no-19-tahun-2016

Republik Indonesia. (2018). Peraturan Presiden Republik Indonesia Nomor 95 Tahun 2018 tentang sistem pemerintahan berbasis elektronik. Lembaran Negara Republik Indonesia

Tahun 2018 Nomor 182. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/96913/perpres-no-95-tahun-2018

Republik Indonesia. (2019). Peraturan Pemerintah Republik Indonesia Nomor 71 Tahun 2019 tentang penyelenggaraan sistem dan transaksi elektronik. Lembaran Negara Republik Indonesia Tahun 2019 Nomor 185. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/122030/pp-no-71-tahun-2019

Republik Indonesia. (2022). Peraturan Presiden Republik Indonesia Nomor 82 Tahun 2022 tentang perlindungan Infrastruktur Informasi Vital. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 129. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/211184/perpres-no-82-tahun-2022

Republik Indonesia. (2022). Undang-Undang Republik Indonesia Nomor 27 Tahun 2022 tentang pelindungan data pribadi. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 196. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/229798/uu-no-27-tahun-2022

Republik Indonesia. (2023). Peraturan Presiden Republik Indonesia Nomor 47 Tahun 2023 tentang strategi keamanan siber nasional dan manajemen krisis siber. Lembaran Negara Republik Indonesia Tahun 2023 Nomor 95. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/255542/perpres-no-47-tahun-2023

Republik Indonesia. (2024). Undang-Undang Republik Indonesia Nomor 1 Tahun 2024 tentang perubahan kedua atas Undang-Undang Nomor 11 Tahun 2008 tentang informasi dan transaksi elektronik. Lembaran Negara Republik Indonesia Tahun 2024 Nomor 1. Sekretariat Negara Republik Indonesia. https://peraturan.bpk.go.id/Details/274494/uu-no-1-tahun-2024

United Nations. (1966). International Covenant on Civil and Political Rights. United Nations Treaty Series, 999, 171. United Nations. https://www.ohchr.org/en/instruments-mechanisms/instruments/international-covenant-civil-and-political-rights

United Nations. (2024). United Nations Convention against Cybercrime: Strengthening international cooperation for combating certain crimes committed by means of information and communications technology systems and for the sharing of evidence in electronic form of serious crimes (A/RES/79/243). United Nations. https://docs.un.org/A/RES/79/243

United Nations Office on Drugs and Crime. (2025). United Nations Convention against Cybercrime. United Nations. https://www.unodc.org/unodc/en/cybercrime/convention/home.html

CATATAN PENGGUNAAN REFERENSI

E-book karya Onno W. Purbo yang bisa di download dari s.id/free-owp-ebooks/ digunakan untuk membangun pemahaman mengenai ancaman siber, perspektif penyerang dan pertahanan, pemanfaatan AI, pembangunan SOC, keamanan data, pengadaan teknologi, resiliensi, pengembangan talenta, teknologi terbuka, risiko ketergantungan pemasok, serta kedaulatan digital. **Bagian tutorial, perintah teknis, dan konfigurasi operasional tidak dimasukkan ke dalam buku kebijakan ini.**

NIST Cybersecurity Framework 2.0 digunakan sebagai **kerangka pengelolaan risiko**, bukan sebagai undang-undang Amerika Serikat. Kerangka ini bersifat fleksibel, tidak menentukan satu cara implementasi, dan dapat digunakan secara sukarela atau diadopsi melalui kebijakan serta regulasi.

NIST Artificial Intelligence Risk Management Framework merupakan kerangka sukarela. Buku ini menggunakan prinsip tata kelola, pemetaan risiko, pengukuran, dan pengendaliannya tanpa menyatakan bahwa seluruh ketentuannya mempunyai kekuatan hukum wajib.

NIS2 merupakan direktif Uni Eropa yang digunakan sebagai referensi komparatif mengenai cakupan sektor kritikal, tata kelola risiko, pelaporan insiden, pengawasan, pertanggungjawaban pimpinan, dan kerja sama lintas negara.

Cyber Resilience Act digunakan sebagai referensi komparatif mengenai keamanan produk dengan elemen digital, tanggung jawab produsen, penanganan kerentanan, pembaruan keamanan, dan kewajiban sepanjang siklus hidup produk.

Perpres Nomor 47 Tahun 2023 telah mengatur Strategi Keamanan Siber Nasional dan Manajemen Krisis Siber. Karena itu, Keamanan Ketahanan Siber harus memperkuat dan mengharmonisasikan kerangka yang telah tersedia serta menaikkan norma fundamental ke tingkat undang-undang, **bukan membentuk sistem paralel yang memperbesar fragmentasi kelembagaan**.

Perpres Nomor 82 Tahun 2022 menggunakan istilah “Infrastruktur Informasi Vital”. Apabila Keamanan Ketahanan Siber menggunakan istilah “Infrastruktur Informasi Kritikal”, hubungan, perbedaan, transisi, serta akibat hukumnya harus dijelaskan secara eksplisit agar tidak menimbulkan dua rezim penetapan yang tumpang tindih.

TENTANG PENULIS



Onno W. Purbo, saat ini bertugas sebagai rektor di Institut Teknologi Tangerang Selatan (ITTS). Onno memperoleh gelar Ph.D bidang Electrical Engineering dari University of Waterloo, Canada, adalah seorang copyleft, educator dan ICT evangelist. Dia sudah mempublikasikan ratusan buku, termasuk free ICT ebook untuk sekolah tahun 2008. 23 eBook AI untuk sekolah di tahun 2025. Sekitar 300 eBook tulisannya di sharing free di singkat.in/free-owp-ebooks / s.id/free-owp-ebooks/

Beberapa buku terakhirnya antara lain "Internet-TCP/IP: Konsep Dan Implementasi", 2018; "Sistem Operasi, Konsep Dan Membuat Linux OpenWRT Dan ROM Android", 2019; "IPv6 Untuk Mendukung Operasi Jaringan Dan Domain Name System", 2019; "Kubernetes untuk Pemula", 2024 dan "Membuat Operator Seluler 5G Sendiri", 2024.

Dia memimpin sambungan pertama Internet di Institut Teknologi Bandung, tahun 1993-2000, dan menggunakannya untuk membuat jaringan Internet pendidikan yang pertama di Indonesia. Dia membebaskan frekuensi WiFi, memperkenalkan RT/RW-net, antenna Wajanbolic dan jaringan selular OpenBTS dan private 5G sendiri. Dia memimpin jaringan telepon pertama di atas Internet, VoIP Merdeka, yang kemudian hari dikenal sebagai VoIP Rakyat berbasis SIP dan menggunakan kode area +62520 dan +62521. Dia saat ini aktif memperkenalkan e-Learning, dan menjalankan server e-Learning di http://lms.onnocenter.or.id/moodle/ 66,000++ siswa / mahasiswa dan https://opencourse.itts.ac.id 39.000+ mahasiswa secara gratis. Email: onno@indo.net.id